**CYBERULTRON CONSULTING PRIVATE LIMITED**

C3iHub, 2nd Floor, Technopark Phase I, IIT Kanpur, Kanpur - 208016, Uttar Pradesh, India

Ph - +91 - 94574 54866 | www.cyberultron.ai

COMMERCIAL - IN - CONFIDENCE

**EOI Reference No.:** DGTM/01/100010/M/48/VAF/PC1 Submission Date: 19 June 2026

**RESPONSE TO EXPRESSION OF INTEREST**

Submitted under the Technology Development Fund (TDF) Scheme · Ministry of Defence, Government of India

# Sovereign LLM Vulnerability Assessment and Certification Framework

*EOI Title: "Comprehensive Vulnerability Assessment Framework for Large Language Models"*

**PART-II RESPONSE · ITEMS 1 TO 18**

| | |
|---|---|
| **SUBMITTED TO** | Director, Technology Development Fund (TDF)<br>Dte. of Technology Development Fund, DRDO Bhawan, Rajaji Marg, New Delhi – 110011 |
| **SUBMITTED BY** | Cyberultron Consulting Private Limited<br>CIN: U72900UR2022PTC013576 · GSTIN: 05AAKCC0894R1ZZ · DPIIT: DIPP96348<br>Registered office: C3iHub, 2nd Floor, Technopark Phase I, IIT Kanpur, Kanpur – 208016, Uttar Pradesh, India<br>Point of Contact & Authorised Signatory: Krishna Mohan Sharma, Head of Technology · +91 94574 54866 · krishna@cyberultron.com |
| **SCHEME / TRACK** | Technology Development Fund (TDF), Ministry of Defence — Grant-in-Aid · Eligibility track: MSME / Startup · Project duration: up to 24 months |

**CONFIDENTIALITY AND AUTHENTICITY**

This response and its contents are confidential and submitted solely for evaluation under the referenced Expression of Interest. All statutory particulars (CIN, GSTIN, PAN, TAN, DPIIT registration) and the registered-office address are furnished from the company's certified records and are not intended for public distribution.

**CYBERULTRON CONSULTING PRIVATE LIMITED**

C3iHub, 2nd Floor, Technopark Phase I, IIT Kanpur, Kanpur - 208016, Uttar Pradesh, India

Ph - +91 - 94574 54866 | www.cyberultron.ai

Ref: CCPL/DRDO-TDF/VAF/2026/001 Date: _____

To,
The Director,
Directorate of Technology Development Fund (TDF), DRDO,
DRDO Bhawan, Rajaji Marg, New Delhi – 110011

**Subject: Submission of Part-II Response (Items 1–18) against the Expression of Interest — "Comprehensive Vulnerability Assessment Framework for Large Language Models"**

**Reference:** EOI Ref. No. DGTM/01/100010/M/48/VAF/PC1

Respected Sir / Madam,

1. With reference to the captioned Expression of Interest, we are pleased to submit the Part-II response of **Cyberultron Consulting Private Limited**, covering Items 1 to 18 with Annexures A to AC, for the development of a sovereign, air-gapped Vulnerability Assessment and Certification Framework for Large Language Models under the Technology Development Fund (TDF) Scheme.

2. Cyberultron Consulting Private Limited is an Indian-owned and -controlled private limited company incorporated under the Companies Act, 2013 on 9 February 2022 (CIN: U72900UR2022PTC013576; GSTIN: 05AAKCC0894R1ZZ; PAN: AAKCC0894R), with its registered office at C3iHub, 2nd Floor, Technopark Phase I, IIT Kanpur, Kanpur – 208016, Uttar Pradesh, India. The company is a DPIIT-recognised Startup (Certificate No. DIPP96348) and is MSME-registered, and is accordingly eligible under the MSME / Startup track of the TDF Scheme.

3. The response contains the complete technical proposal, development estimates, programme and risk-management plans, and the required declarations and undertakings. No commercial or cost information is included; effort is expressed in person-months. All statements are true and correct to the best of our knowledge and belief; the underlying certificates will be produced in original whenever called for.

4. For all correspondence in this connection, our Point of Contact shall be **Krishna Mohan Sharma**, Head of Technology (Mobile: +91 94574 54866; E-mail: krishna@cyberultron.com). The undersigned shall remain available for any presentation, clarification or technical discussion the Directorate may require.

Thanking you,

Yours faithfully,
**For Cyberultron Consulting Private Limited**

**(Krishna Mohan Sharma)**
Head of Technology & Authorised Signatory
Mobile: +91 94574 54866 · E-mail: krishna@cyberultron.com

**Encl.:** EOI Part-II Response — Items 1 to 18, with Annexures A to AC.

CYBERULTRON CONSULTING PRIVATE LIMITED

C3iHub, 2nd Floor, Technopark Phase I, IIT Kanpur, Kanpur - 208016, Uttar Pradesh, India

Ph - +91 - 94574 54866 | www.cyberultron.ai

## CONTENTS


- Executive Summary

**1** Name of the Firm

**2** Contact Details

**3** Title of the Project

**4** Project Description

- **4.i** Broad understanding of the problem statement
- **4.ii** Critical technologies under the project
- **4.iii** Additional technology items
- **4.iv** Block diagram and process
- **4.v** Technical Approach and Capability Evidence
- **4.v.1** Transformer-based LLM Approach
- **4.v.2** Supervised Fine-Tuning and Instruction-Tuning Evidence
- **4.v.3** Cybersecurity Corpus Curation
- **4.v.4** Retrieval-Augmented Generation (RAG) Design
- **4.v.5** Agentic AI Framework Design
- **4.v.6** Air-Gapped Deployment Strategy
- **4.v.7** Vulnerability Detection and Evaluation Plan
- **4.v.8** Malware Analysis and Reverse-Engineering Capability
- **4.v.9** Secure Code Patching Approach

**5** Development Estimates (with respect to time)

- **5.1** Estimated development time and schedule [Item 5(i)]
- **5.2** Development methodology and governance
- **5.3** Programme organisation and manpower
- **5.4** Infrastructure, network and security architecture
- **5.5** Technology stack
- **5.6** Milestone-wise development plan (M1–M8)
- **5.7** Consolidated deliverables register
- **5.8** Verification, validation and acceptance
- **5.9** Risk management
- **5.10** Standards and compliance mapping
- **5.11** Effort and value analysis
- **5.12** Schedule assumptions, dependencies and critical path
- **5.13** Data governance and Indian-language corpus management
- **5.14** Benchmarking methodology and baseline comparison
- **5.15** Quality, configuration and change management
- **5.16** Scalability and performance engineering
- **5.17** Knowledge transfer, training and sustainment
- **5.18** Detailed activity schedule (month-by-month)
- **5.19** Assumptions, constraints and exclusions
- **5.20** Suo-moto design and development [Item 5(ii)]
- **5.21** Proof-of-Concept Plan [Type-I / Type-II]
- **5.22** Testing and Qualification Plan

**6** Academic Partners and R&D; Support Required

- **6.1** Technologies where academic support is needed
- **6.2** Candidate academic / R&D; institutions

**7** Existing Academic / Research-Institute Support

**8** Indigenous Content in the Proposed Solution

- **8.1** Indigenous content by component
- **8.2** Indigenous content by category

**9** Risk Identification and Mitigation Plan
- **9.1** Risk-management methodology
- **9.2** Risk distribution and register
- **9.3** Principal residual risks — treatment detail

**10** Additional Infrastructure Requiring Funding Support
- **10.1** Infrastructure inventory — essential, available and funded
- **10.2** Funded infrastructure — technical justification

**11** Experience in Design & Development, including Associated Tools
- **11.1** Technology and tool familiarity
- **11.2** Substantiation by criterion

**12** Essential Test Infrastructure for the Solution

**13** Availability of Experienced Manpower
- **13.1** Role-coverage matrix

**14** Management Capabilities

**15** Undertaking by the Firm

**16** Organization Structure, Legal Status and Commitments
- **16.a** Corporate
- **16.b** Corporate Structure
- **16.c** Shareholding Pattern and Major Investors

**17** Financial Capabilities

**18** Litigation / Arbitration History

■ Capability and Infrastructure Evidence (Supporting Detail)

**A** Annexure A — References and Evidence Base

**B** Annexure B — Abbreviations and Glossary

**C** Annexure C — Requirements Traceability Matrix

**D** Annexure D — Threat Model and Attack-Surface Coverage

**E** Annexure E — Detailed Compliance Control Mapping

**F** Annexure F — Resource Loading and Staffing Profile

**G** Annexure G — Programme Governance, KPIs and Reporting

**H** Annexure H — Weaknesses of Existing Approaches and Mitigations

**I** Annexure I — Performance Projection and Scalability Benchmark

**J** Annexure J — Indicative Test Catalogue

**K** Annexure K — Reference Standards Summary

**L** Annexure L — Indicative Environment Specification

**M** Annexure M — EOI Compliance Checklist

**N** Annexure N — Academic Engagement, IP and Data-Handling Protocol

**O** Annexure O — Indigenous Content and Supply-Chain Assurance

**P** Annexure P — Extended Risk Register and RAID Log

**Q** Annexure Q — Funded Infrastructure Specification and Provisioning Plan

**R** Annexure R — TDF Eligibility and Capability Evidence

**S** Annexure S — Document Control and Revision History

**T** Annexure T — Per-Engine Technical Design Notes

**U** Annexure U — Capability Maturity and Gap Analysis

**V** Annexure V — Deliverables Acceptance Index

**W** Annexure W — Programme Communications and Reporting Plan

**X** Annexure X — Detailed Work Breakdown Structure and Effort Distribution

**Y** Annexure Y — Security Operations and Incident-Response Plan

**Z** Annexure Z — Innovation and Sovereign-IP Register

**AA** Annexure AA — Indicative Acceptance Test Plan (ATP)

**AB** Annexure AB — Glossary of Key Technical Concepts and Methods

**AC** Annexure AC — EOI Item-to-Response Crosswalk

**LIST OF FIGURES**

**Fig 1.** Six-stage sovereign assessment pipeline

**Fig 2.** Layered system architecture

**Fig 3.** Data-flow diagrams (context & Level-1)

**Fig 4.** UML sequence for an assessment run

**Fig 5.** Operational workflow (swimlanes)

**Fig 6.** Deployment view

**Fig 7.** Work breakdown structure

**Fig 8.** Attack-success rate by language

**Fig 9.** Transformer model fine-tuning pipeline

**Fig 10.** Cybersecurity corpus curation pipeline

**Fig 11.** Retrieval-augmented generation (RAG) architecture

**Fig 12.** Agentic vulnerability-analysis & PoC-chain workflow

**Fig 13.** Vulnerability detection & evaluation pipeline

**Fig 14.** Malware analysis & reverse-engineering workflow

**Fig 15.** Secure code patching workflow

**Fig 16.** 24-month master schedule (Gantt)

**Fig 17.** Development methodology (stage-gate)

**Fig 18.** Programme organisation

**Fig 19.** Network topology

**Fig 20.** Security architecture (defence-in-depth)

**Fig 21.** Deployment topology

**Fig 22.** Technology stack

**Fig 23.** Verification & validation (V-model)

**Fig 24.** Programme risk matrix

**Fig 25.** Milestone dependency & critical path

**Fig 26.** UML state machine for an assessed model

**Fig 27.** UML use-case diagram

**Fig 28.** Resource-loading profile

**Fig 29.** Performance projection & scalability

**Fig 30.** Academic collaboration model

**Fig 31.** Indigenous-content composition

**Fig 32.** Risk-management lifecycle

**Fig 33.** Risk distribution by category

**Fig 34.** Infrastructure — existing versus funded

**Fig 35.** Funded-infrastructure provisioning timeline

**Fig 36.** Capability and evidence map

**Fig 37.** Development and test infrastructure topology

**Fig 38.** Isolated / air-gappable test environment (network)

**Fig 39.** Inference serving topology (in-enclave)

**Fig 40.** Source-control repository structure & secure CI/CD

**Fig 41.** Secure data-ingestion SOP

**Fig 42.** Code-analysis sandbox design

**Fig 43.** AI / ML / LLM project evidence map

Tables are numbered sequentially (Table 1, Table 2, …) and captioned in place with title, source and interpretation.

## EXECUTIVE SUMMARY

India's defence and strategic establishment is adopting Large Language Models rapidly, yet the capability to **security-test those models before classified deployment does not exist domestically**, and every commercial tool that performs such testing is foreign-owned, cloud-tied and unable to operate in an air-gapped environment. This response proposes a **sovereign, air-gapped Vulnerability Assessment and Certification Framework for LLMs** that closes that gap end-to-end.

The framework comprises **six integrated assessment engines** — static model-artifact scanning, prompt-injection and jailbreak generation, gradient-based adversarial attacks, agentic multi-turn red-teaming, privacy / inference-API / embedding analysis, and a certification-and-scoring engine — operating wholly within a secure enclave with zero external dependency or telemetry. Findings are mapped to the OWASP LLM Top-10, MITRE ATLAS and the NIST AI RMF and issued as a signed, accreditation-ready certificate. The system is engineered to assess a 7-billion-parameter model with the full suite in under four hours, with target weights protected in use by confidential computing.

Its principal differentiators relative to existing approaches are: **fully air-gapped operation** (no commercial tool offers this); **native Indian-language coverage**, addressing the well-documented multilingual safety gap that English-centric tools miss; **confidential computing** so that classified weights are never exposed during testing; **accreditation-grade certification** rather than cloud dashboards; and **≈100% indigenous content** from an Indian MSME, making it eligible under the scheme where foreign tools are not. Each engine is designed to remedy a specific, documented weakness of prior art (Annexures H and U).

Delivery is structured as a **24-month programme of eight stage-gated milestones** (M1–M8), executed as a single critical chain with four continuous workstreams and binding exit-criteria at each gate (§5, Figure 16). The technology readiness level advances from a sovereign platform (TRL 4) to an independently-validated, pilot-proven, accreditation-ready capability (TRL 7–8). Risk is managed through a thirty-item register across eight categories (§9, Annexure P), with every medium-residual risk paired with a concrete fallback so that no single risk can breach the 24-month ceiling.

The applicant, Cyberultron Consulting Private Limited, is an Indian-owned MSME incubated within the IIT Kanpur ecosystem (§7), with existing AI-security capability and a Python-native engineering stack. Academic support is sought, under a strict data/IP boundary, for four research-forward areas — the Indian-language harm taxonomy, embedding analysis, membership-inference theory and advanced attack methods (§6). Funding support is requested only for the specialised **air-gapped and confidential-computing infrastructure** that no commodity environment can provide and that the industry does not currently hold (§10, Annexure Q); the broad development, software and expertise base is contributed by the applicant.

**RESPONSE SCOPE AND CONFORMANCE.**

This document is the EOI Part-II technical response covering **Items 1 to 18**, prepared to the standard of a formal Government of India tender response. It contains **no commercial or cost information** (effort is expressed in person-months), all data and intellectual property remain within the Indian perimeter, and statutory identifiers are furnished from the company's certified records. A full requirements-traceability matrix (Annexure C) and EOI compliance checklist (Annexure M) demonstrate clause-by-clause conformance.

## 1 NAME OF THE FIRM

This document is the formal response of **Cyberultron Consulting Private Limited** to Items 1–4 of Part-II of the referenced Expression of Interest. Cyberultron is an Indian-owned and -controlled entity holding MSME / Startup status and is therefore eligible under the TDF Scheme. Statutory identifiers and the registered-office address are furnished below from the company's certified records — the Certificate of Incorporation (MCA), the GST registration and the DPIIT Startup-recognition certificate.

| | |
|---|---|
| **Registered name** | Cyberultron Consulting Private Limited |
| **Legal status** | Private Limited Company (limited by shares), incorporated under the Companies Act, 2013 on 9 February 2022 |
| **MSME / Startup status** | MSME-registered; DPIIT-recognised Startup — Certificate No. DIPP96348 (Startup India) |
| **CIN / GSTIN** | CIN: U72900UR2022PTC013576 · GSTIN: 05AAKCC0894R1ZZ · PAN: AAKCC0894R · TAN: MRTC05110A |
| **Ownership / control** | Owned and controlled by resident Indian citizens; foreign investment within the <49% eligibility limit |

## 2 CONTACT DETAILS

| | |
|---|---|
| **i. Email** | krishna@cyberultron.com |
| **ii. Point of Contact** | **Krishna Mohan Sharma** — Head of Technology & Authorised Signatory · +91 94574 54866 |
| **iii. Address** | Registered office: C3iHub, 2nd Floor, Technopark Phase I, IIT Kanpur, Kanpur – 208016, Uttar Pradesh, India |

## 3 TITLE OF THE PROJECT

**Sovereign LLM Vulnerability Assessment and Certification Framework**

Cyberultron's response to the EOI titled “Comprehensive Vulnerability Assessment Framework for Large Language Models.” The framework is the offensive / assessment counterpart to Cyberultron's existing AI-security capabilities (runtime guardrails and a multi-model security gateway), and is delivered as a self-contained, air-gapped system.

# 4 PROJECT DESCRIPTION

## 4.i Broad understanding of the problem statement

### The problem, the gap, and the solution thesis

India's defence and strategic establishment is adopting Large Language Models at speed, yet the capability required to **security-test those models before classified deployment does not exist domestically.** Under the IndiaAI Mission (sanctioned in 2024), the Government has already funded **twelve organisations** — Sarvam AI, the IIT-Bombay-led BharatGen consortium (Param2, a 17B mixture-of-experts model spanning 22 scheduled languages), Gnani.ai, Fractal and others — to build sovereign foundation models, several now live on the national AIKosh platform. Every one of these models, and every model procured from abroad, must be adversarially assessed for AI-specific vulnerabilities before it can be trusted in a national-security context.

The tools that perform this assessment are, today, **without exception foreign-controlled and cloud-oriented.** The most widely cited LLM vulnerability scanner is NVIDIA's; the leading multi-turn red-teaming framework is Microsoft's; the leading model-artifact scanner is Protect AI's. The commercial market has consolidated under foreign mega-vendors: Protect AI was acquired by Palo Alto Networks (2025); Robust Intelligence by Cisco (2024); Lakera by Check Point (2025). India's own best-in-class AI red-teaming startup, SydeLabs (Bengaluru), was acquired by Protect AI in 2024 and now sits inside that US stack. Independent 2026 vendor analyses explicitly note that **none of these platforms offers an air-gapped deployment.**

| | | | | |
|---|---|---|---|---|
| **12** sovereign LLMs funded under IndiaAI | **0** Indian, air-gapped LLM test frameworks | **3** leading AI-sec vendors acquired 2024–25 | **~3×** harm uplift, low-resource Indic attacks | **<4 hr** full suite on a 7B model (target) |

**THE CAPABILITY GAP THIS PROJECT CLOSES**

For a sovereign or classified Indian model, using any foreign tool means routing the model's **weights, behaviours, prompts and discovered zero-day findings through foreign-controlled software** — negating the rationale for building the model sovereignly and exposing weights, training-data signals and vulnerabilities to external infrastructure. As the EOI states, deploying an unvetted LLM in national security is equivalent to deploying untested software with known remote-code-execution vulnerabilities. **There is no Indian-owned, fully air-gapped, defence-grade framework** that tests any LLM across the full attack surface — prompt injection, jailbreak, data leakage, model inversion, supply-chain / artifact compromise and safety bypass — with zero external dependency, and none that tests India-specific surfaces (multilingual attacks, defence harm taxonomies). Cyberultron's framework closes precisely this gap.

**The India-specific surface is empirically real, not rhetorical.** Safety alignment in modern LLMs is trained predominantly on English. Peer-reviewed work (Yong et al., Brown University; Deng et al., DAMO Academy) shows low-resource languages are roughly **three times more likely** to elicit harmful output, that Hindi and Bengali rank among the highest-success attack languages, and that combined / code-switching attacks reach approximately **79% success** on standard benchmarks. 2026 follow-up studies show that even where single-turn translation has been patched, multi-turn conversational attacks in low-resource languages remain highly effective. No foreign tool ships a curated Indian-language harm corpus (Figure 8).

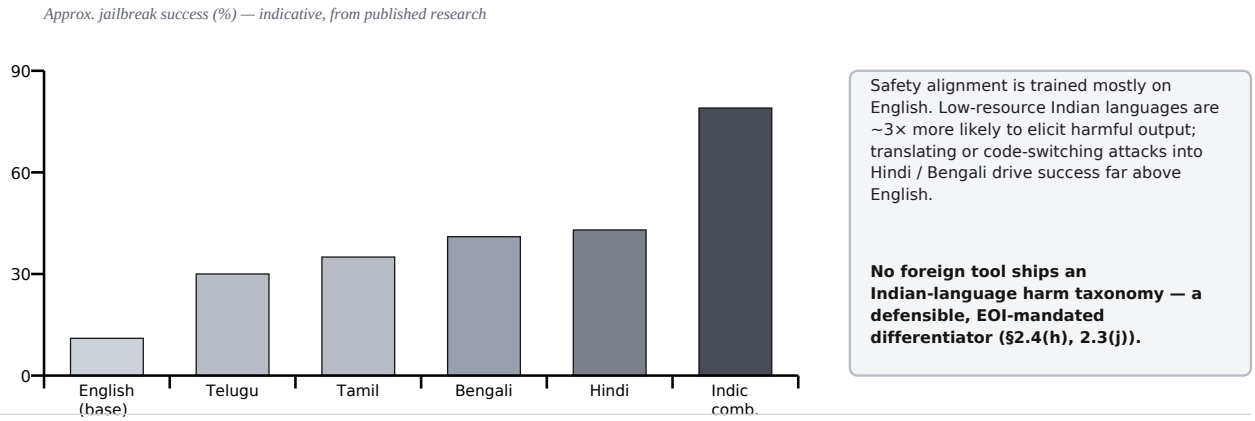



*Figure 8. Attack-success-rate by language (indicative; Yong et al., Brown Univ.; Deng et al., DAMO; 2026 multi-turn low-resource studies). Values illustrate the relative English-versus-Indic gap, not a single benchmark.*

**Why Cyberultron.** Cyberultron Consulting is an AI-native cybersecurity, privacy and GRC firm headquartered in Bengaluru and incubated within the IIT Kanpur ecosystem. Its existing AI-security capabilities — runtime guardrails and a multi-model security gateway — already address LLM threat surfaces in production on a fully Python-native, self-hostable stack (vLLM, LiteLLM, OPA / Rego, FastAPI, PostgreSQL, Redis, Prometheus / Grafana). The proposed framework is the offensive / assessment counterpart to that work, drawing on Cyberultron's red-teaming knowledge, its compliance depth (ISO/IEC 27001, ISO/IEC 42001, NIST AI RMF) and its air-gapped on-premise deployment experience.

**Solution shape.** The framework is a single, self-contained, air-gapped system organised as **six engines operating as a pipeline** (Figure 1; architecture in §4.iv): (1) secure model ingestion; (2) static artifact scanning; (3) adversarial attack generation; (4) agentic multi-turn red-teaming; (5) privacy, API and embedding audit; (6) automated certification mapped to OWASP LLM Top-10, MITRE ATLAS and NIST AI RMF. A full security suite on a 7B-parameter model completes in **under four hours**, producing 100+ validated vulnerability test cases and a signed certification report — entirely within the secure perimeter.

### Competitive positioning — the defensible white space

The matrix maps the framework against the foreign tools and products that define the technical baseline. The pattern is decisive: foreign tools are **structurally ineligible** (not Indian MSME/startup, cloud/telemetry-tied, no air-gap), and no single offering combines offensive testing, artifact scanning, privacy auditing, Indic coverage, sovereign air-gapped operation and defence-grade certification. That intersection is the white space.

| Capability axis | NVIDIA | Microsoft | Protect AI / Palo Alto | Lakera / Check Pt | Hidden Layer | Mind gard | Cyberultron VAF |
|---|---|---|---|---|---|---|---|
| Eligible Indian MSME / startup | ○ | ○ | ○ | ○ | ○ | ○ | ● |
| Air-gapped, zero-telemetry operation | ◐ | ◐ | ○ | ○ | ○ | ○ | ● |
| Static model-artifact / supply-chain scan | ○ | ○ | ● | ○ | ● | ◐ | ● |
| Prompt-injection and jailbreak battery | ● | ● | ◐ | ● | ◐ | ● | ● |
| Gradient / white-box attacks (GCG class) | ● | ◐ | ○ | ○ | ○ | ◐ | ● |
| Agentic multi-turn red-teaming | ◐ | ● | ◐ | ○ | ○ | ● | ● |
| Privacy / membership-inference audit | ◐ | ◐ | ○ | ○ | ◐ | ◐ | ● |
| Indian-language harm taxonomy | ○ | ○ | ○ | ○ | ○ | ○ | ● |
| OWASP / ATLAS / NIST certification output | ◐ | ◐ | ● | ○ | ◐ | ● | ● |
| Defence-accreditation integration | ○ | ○ | ○ | ○ | ○ | ○ | ● |

Legend: ● full ◐ partial / conditional ○ absent. Capabilities reflect public documentation and 2026 vendor analyses; all foreign offerings are cloud-oriented and ineligible under TDF.

**Table 1.** Comparative capability matrix — proposed framework versus principal foreign LLM-security tools and products. *Source:* Public product documentation and 2026 vendor analyses. *Interpretation:* Foreign tools are individually capable but structurally ineligible (cloud / telemetry, no air-gap, non-Indian); only the proposed framework satisfies every capability axis.

### Work Breakdown Structure (technology / module / sub-system / software / hardware)

The programme decomposes into six functional modules plus a cross-cutting workstream. Figure 7 shows the hierarchy; the table specifies, for each module, its sub-systems and the principal software and hardware components.

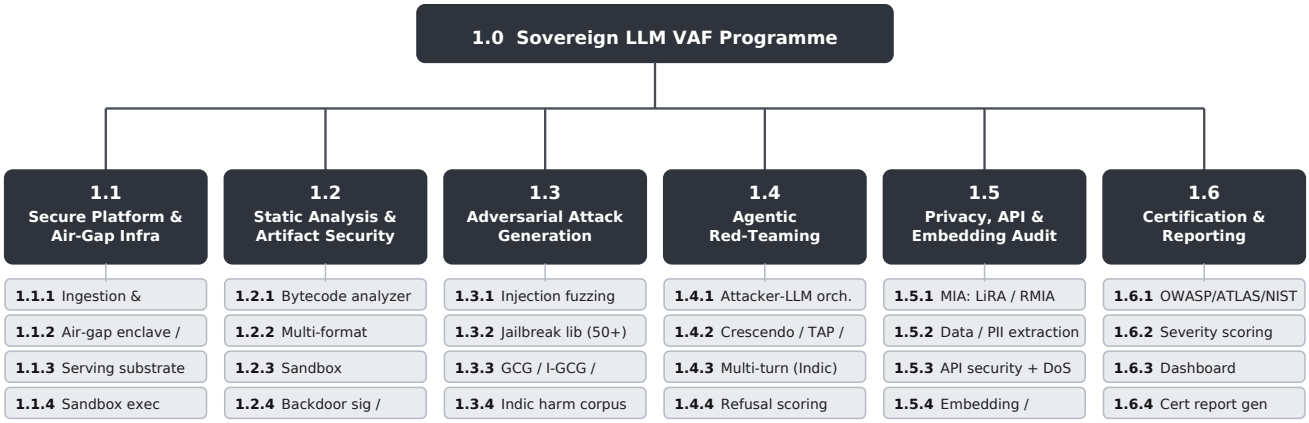



*Figure 7. Work Breakdown Structure: programme → six modules → sub-systems, over a cross-cutting governance / MLOps / accreditation workstream.*

| WBS | Module | Sub-systems | Principal software | Hardware / infra |
|---|---|---|---|---|
| **1.1** | **Secure Platform & Air-Gap Infrastructure** | Model ingestion & provenance; air-gap enclave; serving substrate; sandbox execution | FastAPI control plane; signing/checksum; OPA-Rego; vLLM/TGI/Triton; container runtime | Air-gapped segment (deny-all egress); GPU node; confidential-computing GPU; storage |
| **1.2** | **Static Analysis & Artifact Security** | Bytecode analyzer; multi-format scanner; sandbox detonation; backdoor-signature DB / SBOM | Pickle-bytecode parser; safetensors/ONNX/H5/checkpoint readers; structure-aware fuzzer | Disposable VM/container sandbox; isolated scan host |
| **1.3** | **Adversarial Attack Generation** | Injection fuzzing; jailbreak library (50+); gradient attacks; Indic harm corpus | Fuzzing engine; GCG/I-GCG/AutoDAN; AdvBench/HarmBench/XSTest harness; Indic corpus tooling | GPU for gradient optimisation (7B-scale) |
| **1.4** | **Agentic Red-Teaming** | Attacker-LLM orchestrator; multi-turn strategies; refusal/alignment scoring | Agentic loop (LangChain/AutoGen-style); Crescendo/TAP/PAIR; locally-served attacker model | GPU to host attacker + target models in-enclave |
| **1.5** | **Privacy, API & Embedding Audit** | Membership inference; data/PII extraction; inference-API security; embedding/backdoor analysis | LiRA/RMIA shadow-model harness; canary suites; API fuzzer; representation-analysis toolkit | GPU for shadow-model training; compute for embedding analysis |
| **1.6** | **Certification & Reporting** | Compliance-mapping engine; vulnerability scoring; dashboard; report generator | Rules engine (OWASP/ATLAS/NIST); severity model; PDF/HTML pipeline (ReportLab/WeasyPrint) | Control workstation; evidence store |
| **1.7** | **Cross-cutting (governance & delivery)** | Test-corpus & data governance; MLOps/CI-CD; documentation; DRDO accreditation integration; IV&V; | Git + CI; data-version control; accreditation-export adapter | Source-control + build infra (in-enclave mirror) |

**Table 2.** Work Breakdown Structure — modules, sub-systems, principal software and hardware. *Source:* Cyberultron solution architecture; EOI §2.2–2.3. *Interpretation:* Each EOI-mandated capability maps to a discrete module with defined software and hardware, enabling milestone-based delivery and acceptance.

### 4.ii Critical technologies under the project

The framework integrates eleven critical technologies. Each is mapped to the EOI's stated technology set (§2.3 a–j) and to the principal OWASP LLM Top-10 (2025) risk it exercises. “Building blocks” denotes published methods and permissively-licensed open-source references used at development time; in the delivered system every component is forked, fully self-hosted and air-gapped, with no runtime foreign dependency or telemetry (see Indigenous Content, §4.iv).

| # | Critical technology (EOI ref) | Function in the framework | SOTA methods / building blocks | TRL | OWASP |
|---|---|---|---|---|---|
| **CT1** | **Multilingual injection & jailbreak fuzzing (a)** | Generate/mutate prompt-injection & jailbreak inputs, incl. Indian languages | Fuzzing + adversarial generation; AdvBench/HarmBench/XSTest; open-source-equivalent probes (self-hosted) | 5 | 01,05 |
| **CT2** | **Gradient-based adversarial-suffix generation (b)** | White-box optimisation of jailbreak/inversion suffixes against indigenous models | GCG, I-GCG (improved), AutoDAN (hierarchical genetic) | 4 | 01 |
| **CT3** | **Membership inference & privacy validation (c)** | Quantify training-data leakage / privacy boundary | LiRA (shadow models), RMIA (reference population), RaMIA | 4 | 02 |
| **CT4** | **Static analysis of serialized artifacts (d)** | Detect malicious objects, telemetry, backdoors in model files | Pickle-bytecode analysis; multi-format (safetensors/ONNX/H5); structure-aware fuzzing; sandbox detonation | 5 | 03,04 |
| **CT5** | **Dynamic instrumentation of inference APIs (e)** | Auth bypass, rate-limit flaws, function-calling abuse, DoS | API fuzzing + classical AppSec adapted to model serving | 6 | 06,10 |
| **CT6** | **Embedding-space & representation analysis (f)** | Detect sleeper agents, backdoor triggers, poisoning | Anomalous-cluster detection; representation probing | 3 | 04,08 |
| **CT7** | **Agentic multi-turn red-teaming (g)** | Attacker-LLM orchestration of conversational attacks | Crescendo, TAP, PAIR; LangChain/AutoGen-style loop; air-gapped attacker model | 5 | 01,07 |
| **CT8** | **Compliance mapping & scoring (h)** | Auto-map findings to frameworks; severity scoring | Rules engine (OWASP/ATLAS/NIST); severity model | 6 | All |
| **CT9** | **Air-gapped deployment architecture (i)** | Operate with zero external dependency / telemetry | Deny-all egress; signed audit; hermetic, reproducible deploy | 6 | 03 |
| **CT10** | **Multilingual harm taxonomy & corpus (j)** | Indian defence harm categories + Indic prompt corpus | Curated taxonomy + native-language corpus (linguistics partner) | 3 | 01,09 |
| **CT11** | **Confidential computing / TEE (added)** | Protect target model weights during testing | NVIDIA GPU CC mode + HW attestation (<7% overhead); Intel TDX / AMD SEV-SNP; confidential containers | 5 | 03 |

TRL = indicative Technology Readiness Level at proposal stage (qualification targets TRL 5–6 for integrated modules; CT6 and CT10 are deliberately research-forward and the strongest candidates for academic collaboration). OWASP abbreviates LLM01…LLM10 (2025).

**Table 3.** Critical technologies — EOI mapping, state-of-the-art methods, indicative TRL and OWASP linkage. *Source:* Cited literature (GCG, AutoDAN, LiRA, RMIA); OWASP LLM Top-10 (2025); EOI §2.3. *Interpretation:* Every critical technology is grounded in peer-reviewed methods; research-forward items (CT6, CT10) are the focus of academic collaboration and risk-managed delivery.

### Deep notes on the research-forward technologies

**CT2 — Gradient attacks and the access-model distinction.** GCG greedily optimises an adversarial suffix via greedy-coordinate-gradient search; suffixes transfer across models but are illegible and perplexity-detectable. I-GCG raises success and converges in roughly 400 iterations; AutoDAN uses a hierarchical genetic algorithm to produce fluent, filter-evading prompts. These require **white-box / gradient access** — available for indigenous models but not for black-box procured models, which is why the query-only methods (PAIR, TAP) in CT7 are mandatory complements. The framework selects the attack family automatically from the declared access model.

**CT3 — Membership inference, scoped honestly.** LiRA trains shadow models and applies a Neyman-Pearson-optimal likelihood-ratio test (Gaussian IN/OUT), evaluated at true-positive-rate under low false-positive-rate; RMIA uses a reference-model population for greater efficiency. Published evidence shows MIA is far weaker on realistically single-epoch-trained LLMs than on canaries; the EOI correctly scopes the target to **standard canary datasets**, where >80% accuracy is attainable. The framework reports MIA strictly against canaries and does not over-generalise to production-trained models.

**CT4 — Beyond "re-implementing a scanner."** Leading open-source model-artifact scanners have **documented CVEs and bypasses** across 2025 (Sonatype, JFrog and Cisco disclosures). The framework therefore combines bytecode static analysis with **structure-aware fuzzing** and **sandboxed detonation** of untrusted artifacts in disposable VMs/containers, and actively steers ingested models toward safe-by-design formats (safetensors, ONNX) which cannot execute arbitrary code. This positions the framework to **exceed** the foreign baseline, not merely match it.

**CT10 — The Indian-language harm taxonomy (net-new IP).** No tool ships a curated Indic defence harm taxonomy. Building one — spanning violence, weapons development, cyber-attack planning and regional harm categories across Hindi, Tamil, Telugu and Bengali, validated by native speakers — is a genuine research contribution and a defensible, sovereign IP asset. It is the highest-value item that money cannot currently buy, delivered with academic linguistics support (§4.iii).

### 4.iii Additional technology items required to complete the solution

Beyond the eleven core technologies, the following items complete a deployable, defence-grade solution. None is a dependency on foreign runtime infrastructure; each is sovereign-built, hardware procured for the enclave, or sourced through Indian academic / industry collaboration.

| Additional item | Why it is required | Source / approach |
|---|---|---|
| **Indian-language defence harm taxonomy & corpus** | Mandated by EOI §2.4(h)/2.3(j); unavailable in any existing tool; defines what "harmful" means in the Indian defence context across Hindi/Tamil/Telugu/Bengali | Net-new sovereign build with academic computational-linguistics partner; native-speaker validation |
| **Defence-specific alignment / refusal test sets** | Score safety-bypass across 10+ harm categories using the Indian taxonomy rather than Western defaults | Curated in-house from the taxonomy; reviewed with End-User domain input |
| **Offline backdoor / malware signature & threat-intel DB** | Sovereign detection of known malicious model patterns without external feeds | Built in-house; refreshed via controlled media; no live external calls |
| **Hardware-attested confidential-computing GPU(s)** | Protect target weights & intermediate state during testing inside the enclave (CT11) | Procure CC-capable GPU(s) (NVIDIA Hopper/Blackwell-class) for the enclave node |
| **DRDO accreditation-integration adapter** | Export certification output into the defence accreditation workflow | Built to End-User specification at RFP stage |
| **GPU-class compute for development** | Run gradient (GCG-class) optimisation & shadow-model training at 7B scale | In-house / leased / Indian-cloud / academic-partner allocation |
| **Academic R&D collaboration** | Strengthen MIA theory (CT3), embedding analysis (CT6) and Indic-NLP corpus (CT10) | MoU with IIT Kanpur ecosystem / NLP-security group; contribution capped at 40% of project cost per TDF rules |

**Table 4.** Additional technology items required to complete a deployable, defence-grade solution. *Source:* Cyberultron solution architecture; EOI §2.3–2.4 and Undertaking 15. *Interpretation:* No item introduces a foreign runtime dependency; each is sovereign-built, procured for the enclave, or sourced through Indian academia.

### 4.iv Block diagram and process

This sub-section presents the block diagram, system architecture, data-flow diagrams, an end-to-end sequence, the operational workflow and the deployment view. Together they specify how the framework ingests a target model and produces a signed certification — with every artifact, prompt, response and finding confined to the air gap.

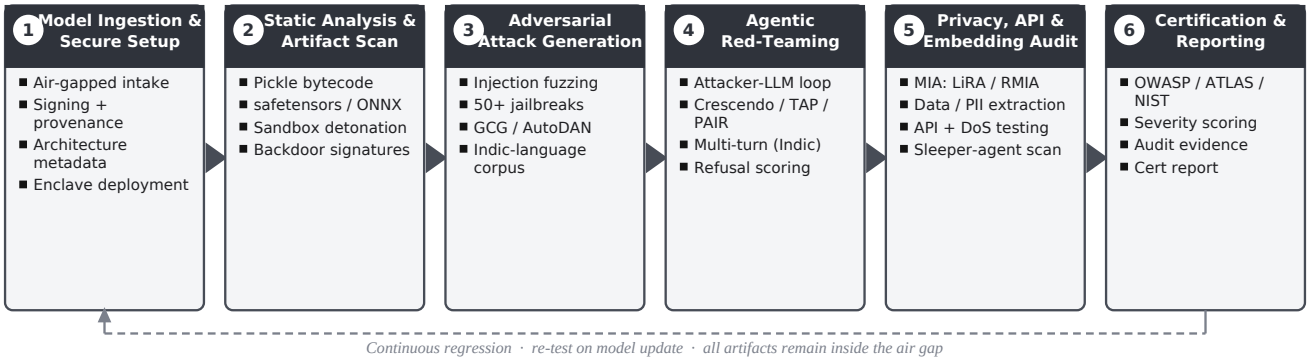



*Figure 1. Six-stage sovereign assessment pipeline (process flow). Stages execute in sequence; findings aggregate into the certification engine, with a continuous regression loop on any model update — entirely inside the air gap.*

**Process (block flow).** A target model and its declared scope enter Stage 1, where the artifact is signed, fingerprinted and deployed into the secure enclave. Stage 2 statically scans the serialized artifact and detonates it in a sandbox before any weight is loaded for inference. Stage 3 generates the adversarial battery (injection fuzzing, the 50+ jailbreak library, gradient attacks for white-box targets, and the Indic corpus). Stage 4 drives multi-turn agentic attacks using an air-gapped attacker model. Stage 5 audits privacy (membership inference on canaries, data/PII extraction), the inference API, and the embedding space for backdoors. Stage 6 maps every finding to OWASP / ATLAS / NIST, scores severity, and emits the signed report.

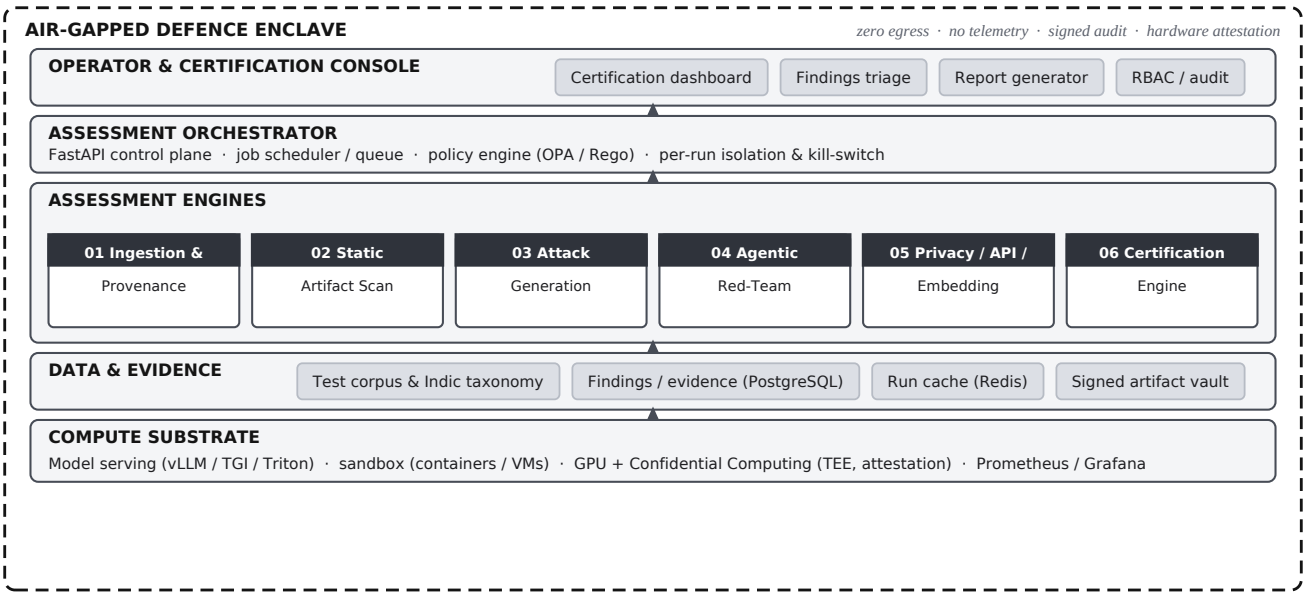



*Figure 2. Layered system architecture. A console and orchestrator drive six engines over a shared data tier and a GPU / sandbox compute substrate; the entire stack runs inside an air-gapped enclave with hardware attestation and deny-all egress.*

**Architecture rationale.** The control plane (FastAPI orchestrator plus an OPA / Rego policy engine) enforces per-run isolation, kill-switches and role-based access — patterns carried directly from Cyberultron's multi-model gateway work. The six engines are independently deployable and share a single enclave-resident data tier (corpus and Indic taxonomy, an evidence store in PostgreSQL, a Redis run-cache, and a signed artifact vault). The compute substrate hosts both the target and the attacker model on vLLM / TGI / Triton, provides disposable VM/container sandboxes for untrusted artifacts, and uses confidential-computing GPUs so target weights remain encrypted in use.

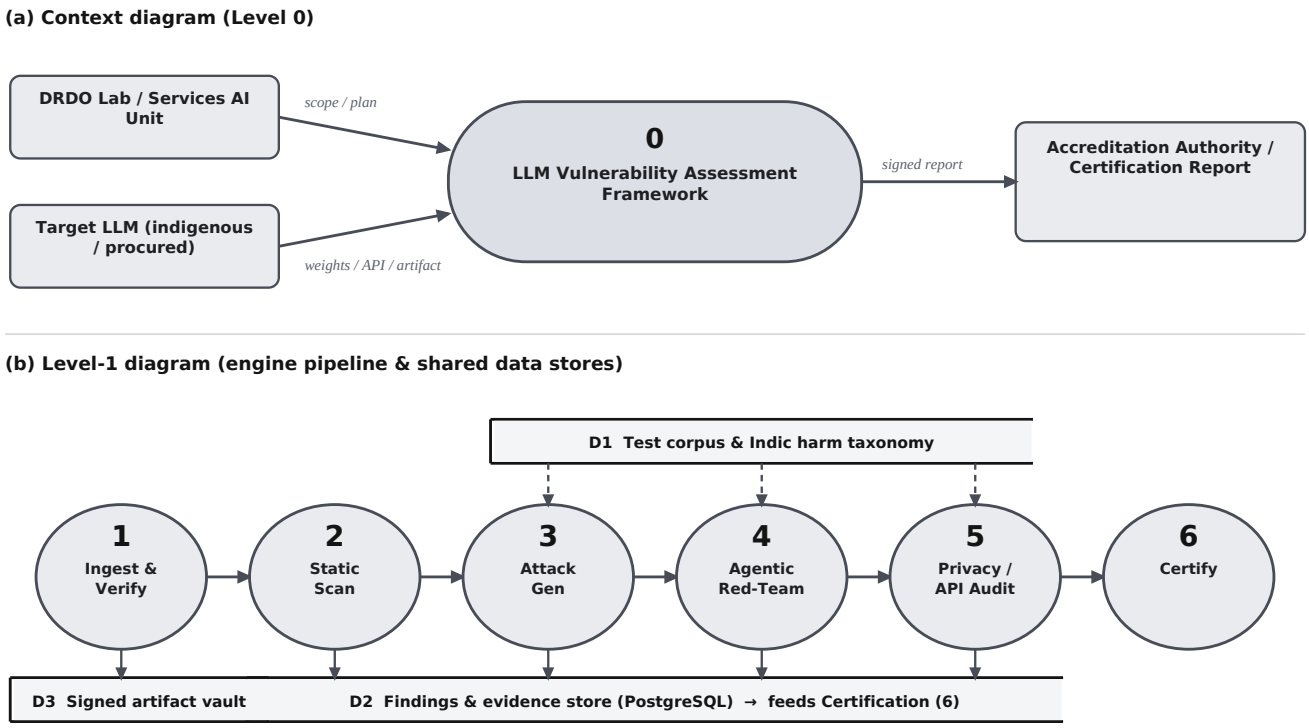



*Figure 3. Data-flow diagrams. (a) Context: the framework is a single process bounded by the air gap. (b) Level 1: engines pass control left-to-right; the corpus/taxonomy (D1) is read by attack engines, all engines write evidence to D2, ingestion/scan write to the signed vault (D3). Dashed = read, solid = write; every store is enclave-resident and access-logged.*

**Data flow.** At Level 0 the framework is a single trust-bounded process: the operator supplies scope and a test plan, the target supplies weights / API / artifact, and a signed report is the only output — nothing crosses the enclave boundary. At Level 1 the six engines pass control left-to-right; the shared corpus and Indic taxonomy (D1) are read by the attack engines, all engines append to the findings / evidence store (D2), and ingestion and scanning write to the signed artifact vault (D3). Every store is enclave-resident, access-logged and included in the signed audit trail.

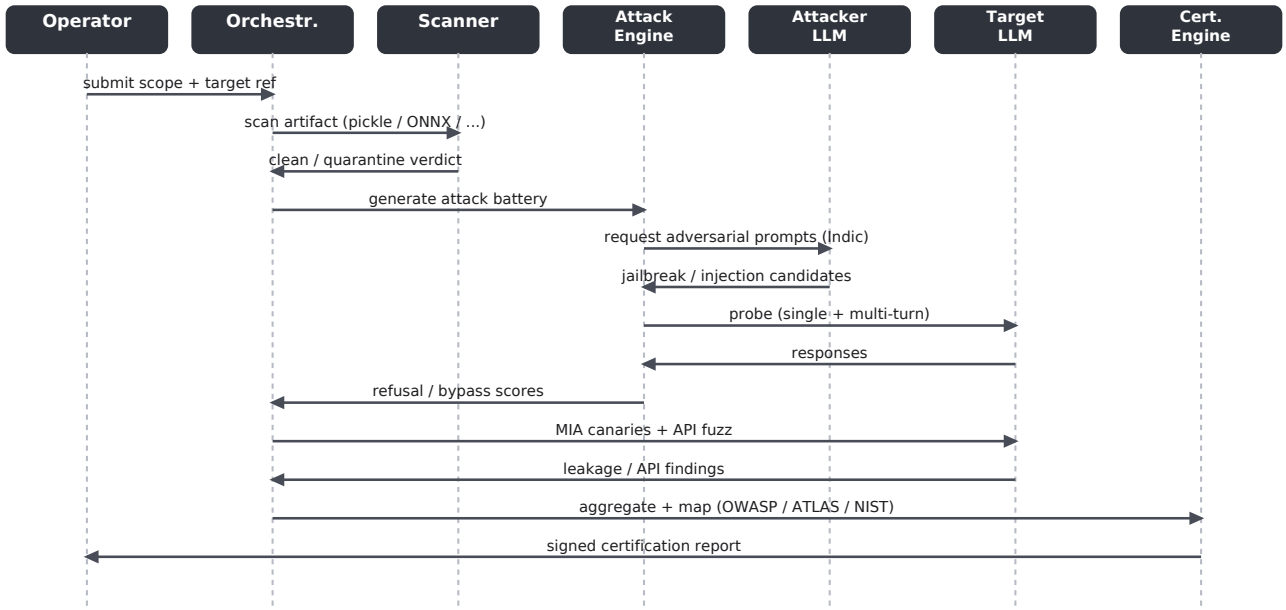



*Figure 4. UML sequence for a single assessment run, from scope submission to the signed certification report — showing the attacker-LLM / target-LLM interaction loop and the scan-before-load ordering.*

**Run sequence.** The sequence diagram shows control for a single assessment: scope submission, scan-before-load, attack-battery generation, the attacker-LLM / target-LLM probe loop (single- and multi-turn, including Indic prompts), the privacy and API audit, and finally compliance mapping and emission of the signed certification report. Ordering is a safety property: an artifact is never loaded for inference until static scanning and sandbox detonation return a clean or quarantined verdict.

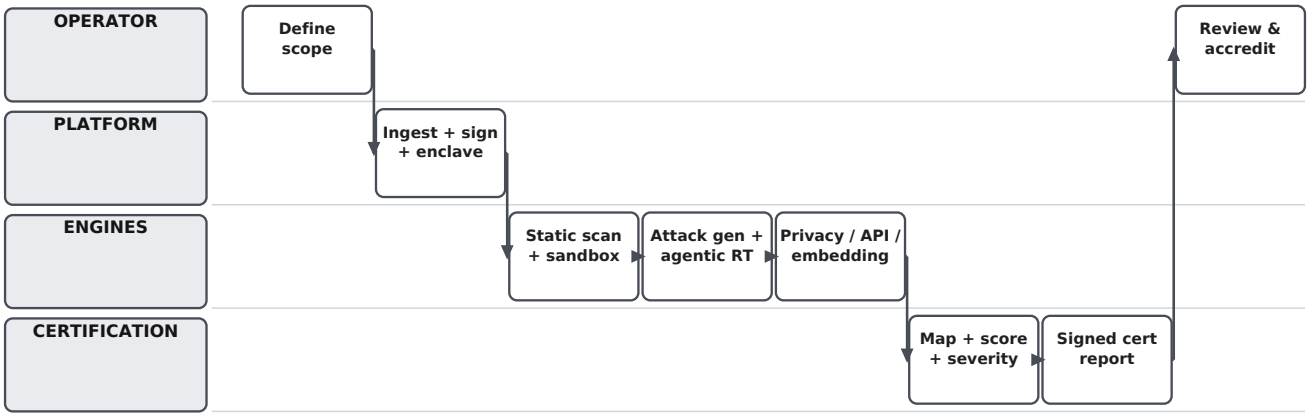



*Figure 5. Operational workflow (swimlanes) across Operator, Platform, Engines and Certification responsibilities — the human-and-system process from scoping to accreditation.*

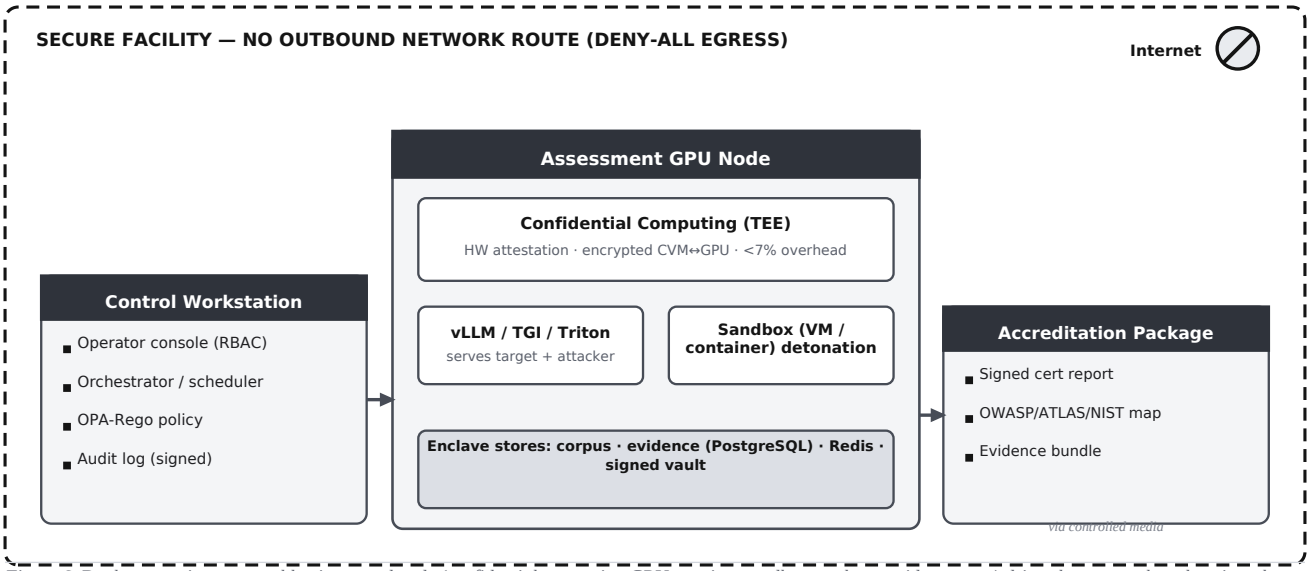



*Figure 6. Deployment view: a portable air-gapped node (confidential-computing GPU, serving, sandbox, enclave-resident stores) driven by a control workstation; the accreditation package is exported only via controlled media. Outbound network is denied.*

**Deployment.** The framework is delivered as a portable, air-gapped node: a confidential-computing GPU server (target + attacker serving, sandbox detonation, enclave-resident stores) driven by a control workstation that holds the operator console, orchestrator and signed audit log. There is no outbound network route; the accreditation package leaves only as a signed bundle on controlled media. The same node can be replicated per security domain, and the architecture is hardware-portable across NVIDIA confidential-computing GPUs, Intel TDX and AMD SEV-SNP.

### Performance parameters and figures of merit (responsive to EOI §2.4)

The framework is engineered to the EOI's indicative performance requirements. Each target is tied to a figure of merit and to the committed implementation approach.

| Parameter | Target (EOI) | Figure of merit | Committed approach |
|---|---|---|---|
| **Prompt-injection coverage** | >95% known; >70% zero-shot | Custom corpus of 10,000+ injection prompts | Signature/corpus matching for known; fuzzing + learned classifier on held-out novel patterns for zero-shot |
| **Jailbreak technique coverage** | 50+ methodologies | OWASP LLM / security benchmarks | GCG/I-GCG/AutoDAN/PAIR/TAP/DeepInception/ArtPrompt/PAP + DAN families |
| **Membership-inference accuracy** | >80% on canaries | LiRA / RMIA benchmark suites | Shadow-model LiRA + RMIA; reported strictly on standard canary datasets |
| **Model-artifact malware detection** | >90% detection | Custom malicious-model corpus | Bytecode static analysis + structure-aware fuzzing + sandbox detonation |
| **Safety-bypass coverage** | 10+ harm categories (defence) | Indian defence harm taxonomy | Indic taxonomy-driven refusal/alignment scoring |
| **Multilingual attack support** | 5+ Indian languages | Regional-language prompt corpus | Hindi, Tamil, Telugu, Bengali + 1; multi-turn Indic attacks |
| **Scan duration (7B model)** | <4 hours, full suite | Operational-efficiency metric | Parallelised probes; batched agentic runs; GPU acceleration |
| **Air-gapped security** | Zero external exfiltration | Security-audit certification | Deny-all egress; signed audit trail; hardware attestation |
| **OWASP LLM Top-10 compliance** | Full LLM01–LLM10 | Automated mapping & reporting | Every probe mapped to a category; ATLAS + NIST cross-mapping |

**Table 5.** Performance parameters and figures of merit against EOI §2.4 targets. *Source:* EOI §2.4; benchmark suites (AdvBench / HarmBench / XSTest, LiRA / RMIA). *Interpretation:* Each EOI target is matched to a measurable figure of merit and a committed, benchmarked implementation approach.

**INDIGENOUS CONTENT (≈100%) AND SOVEREIGNTY POSTURE**

The delivered system carries **no runtime foreign dependency and no telemetry.** Published methods and permissively-licensed open-source references (Apache-2.0 / MIT) are used at development time as starting points; in delivery every component is **forked, fully self-hosted, source-controlled within the Indian perimeter, and air-gapped.** All model weights, prompt corpora, vulnerability findings and reports remain inside the secure Indian perimeter throughout development, testing and deployment, consistent with EOI Undertaking 15(a). The Indian-language harm taxonomy (CT10) and the offline backdoor-signature database are net-new sovereign IP. This makes the framework not merely "Make-in-India" compliant but the only viable option for sovereign and classified models, which cannot be exposed to foreign-controlled tooling.

### 4.v Technical Approach and Capability Evidence

This section sets out the core technical approach of the proposed framework — the transformer-based model strategy and its supervised fine-tuning evidence, the cybersecurity corpus, the retrieval-augmented generation (RAG) design, the agentic analysis framework and the air-gapped deployment strategy — followed by the plans for vulnerability detection and evaluation, malware analysis and reverse engineering, and secure code patching. The system architecture, work breakdown structure and consolidated technology stack that support this approach are presented in §4 and §5.

#### 4.v.1 Transformer-based LLM Approach

The solution employs transformer-based LLMs in two roles — as the in-enclave attacker / assistant models that drive agentic red-teaming and analysis, and (where required) as a fine-tuned cybersecurity-specialised model for vulnerability reasoning and correlation. The approach favours open-weight base models adapted by parameter-efficient fine-tuning (LoRA / QLoRA / PEFT) over training from scratch — the evidence-based, resource-efficient practice for domain specialisation — with all training and inference performed inside the

air-gapped perimeter. The pipeline is shown in Figure 9.

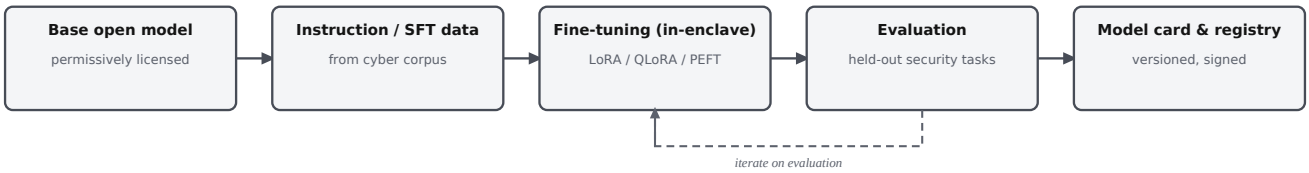



*Figure 9. Transformer model fine-tuning pipeline (in-enclave). A permissively-licensed base model is adapted with instruction / supervised data curated from the cybersecurity corpus using parameter-efficient fine-tuning, evaluated on held-out security tasks, and registered with a signed model card — all within the air-gapped perimeter.*

| Aspect | Approach |
|---|---|
| **Base model** | Permissively-licensed open-weight transformer (decoder-only), selected for size / capability fit and offline operability |
| **Adaptation** | Parameter-efficient fine-tuning (LoRA / QLoRA / PEFT); full fine-tuning only where justified |
| **Specialisation** | Cybersecurity instruction / supervised data from the curated corpus (§4.v.3) |
| **Inference & serving** | Quantised, high-throughput serving (vLLM / llama.cpp) within the enclave |
| **Evaluation** | Held-out security tasks; benchmarked, with a signed model card (§4.v.2) |
| **Sovereignty** | All weights, data and training in-perimeter; no external API or telemetry |

**Table 6.** Transformer-based LLM approach. *Source:* Programme model strategy (§5.5, §5.6); PEFT literature. *Interpretation:* The approach is mainstream and defensible — open-weight bases adapted by parameter-efficient fine-tuning and served offline — demonstrating model design / adaptation capability without external dependence; supporting experiment evidence is furnished separately.

### 4.v.2 Supervised Fine-Tuning and Instruction-Tuning Evidence

The firm's supervised fine-tuning (SFT) / instruction-tuning methodology adapts an open-weight base to cybersecurity tasks using curated instruction–response data, with a held-out evaluation protocol and a documented model card for every produced model. The model-card structure below is the firm's standard evidence artefact; completed experiment reports and model cards for representative runs are furnished as supporting documents.

| Model-card attribute | Content |
|---|---|
| **Base model** | Open-weight decoder-only transformer (size selected for task / hardware) |
| **Method** | Supervised fine-tuning / instruction tuning via LoRA / QLoRA (PEFT) |
| **Training data** | Curated cybersecurity instruction–response pairs from the corpus (§4.v.3); de-duplicated, licence-clean, PII-screened |
| **Evaluation** | Held-out task suite; task accuracy and security-relevant metrics; comparison to base |
| **Intended use** | In-enclave cyber reasoning, correlation and analysis support (decision-support, human-in-the-loop) |
| **Limitations / safeguards** | Documented failure modes; not autonomous; defensive-use-only; reviewed outputs |
| **Provenance** | Versioned (DVC); signed; reproducible; data and weights in-perimeter |

**Table 7.** Supervised fine-tuning / instruction-tuning — model-card structure (evidence artefact). *Source:* Firm fine-tuning methodology; model-card best practice. *Interpretation:* A documented, evaluated, reproducible SFT methodology with a signed model card per model evidences hands-on fine-tuning capability with evaluation.

### 4.v.3 Cybersecurity Corpus Curation

A defensible cybersecurity LLM depends on a well-curated corpus. The firm ingests heterogeneous authoritative sources — CVE / NVD, SARD and the Juliet Test Suite, OWASP material, code repositories with patch history, and threat reports — and processes them through a controlled pipeline (Figure 10) into a versioned vector store (for retrieval) and supervised fine-tuning sets, with licence, de-duplication and PII controls throughout.

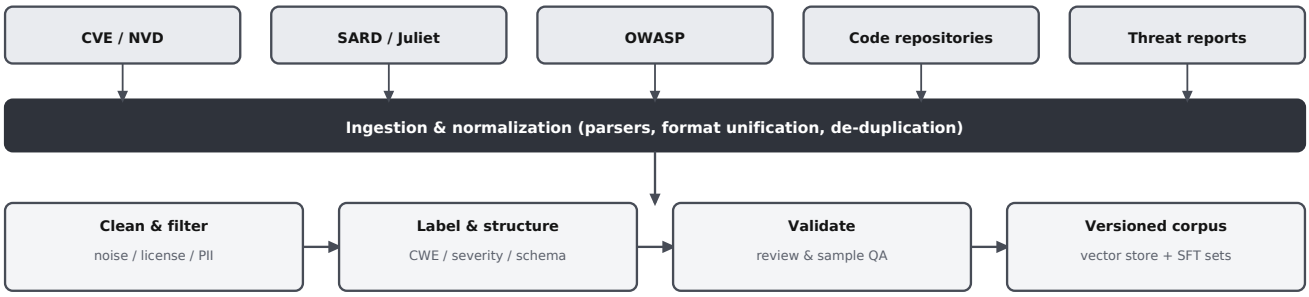



*Figure 10. Cybersecurity corpus curation pipeline. Heterogeneous sources (CVE / NVD, SARD / Juliet, OWASP, code repositories and threat reports) are ingested, normalised, cleaned, labelled (CWE / severity), validated and versioned into both a vector store (for retrieval) and supervised fine-tuning sets — with provenance and licence controls.*

| Source | Content | Use | Cleaning / controls |
|---|---|---|---|
| **CVE / NVD** | Vulnerability records, CVSS, CWE references | Labels; retrieval; SFT | Parse; de-dup; normalise IDs |
| **SARD / Juliet** | Labelled vulnerable / fixed code samples | Detection eval; SFT | Filter; balance; licence check |
| **OWASP** | Top-10, Benchmark and guidance | Evaluation; taxonomy | Structure; map to CWE |
| **Code repositories** | Source with commits / security patches | Patch pairs; SFT | Licence filter; secret / PII scrub; de-dup |
| **Threat reports** | TTPs, IOCs, advisories | Context; retrieval | De-noise; extract; redact |

**Table 8.** Cybersecurity corpus — dataset plan. *Source:* Firm corpus plan (Figure 10); public security data sources. *Interpretation:* Authoritative sources are mapped to their use and to specific cleaning controls, evidencing a rigorous, licence-aware dataset plan rather than indiscriminate scraping.

A representative record schema (for both retrieval metadata and SFT examples) is given below.

| Field | Description |
|---|---|
| **id** | Stable unique identifier |
| **source / type** | Origin (cve / code / report) and record type |
| **cwe / severity** | CWE class and severity (CVSS where available) |
| **language** | Programming or natural language |
| **vulnerable_snippet / fixed_snippet** | Code before / after fix (for patch-pair records) |
| **description / references** | Human description and source links |
| **licence** | Licence of the source (permissive-only retained) |
| **split** | train / validation / test assignment |

**Table 9.** Representative corpus record schema (sample). *Source:* Firm corpus schema. *Interpretation:* A structured schema with provenance, CWE / severity, patch pairs and licence fields supports both retrieval and supervised fine-tuning while preserving traceability and licence compliance.

### 4.v.4 Retrieval-Augmented Generation (RAG) Design

Retrieval-augmented generation grounds the model's analysis in the curated corpus, improving accuracy and auditability and reducing hallucination. An offline pipeline chunks and embeds the corpus into a vector database; at query time the system retrieves and re-ranks the most relevant passages and the LLM correlates and reasons over them to produce cited findings (Figure 11).

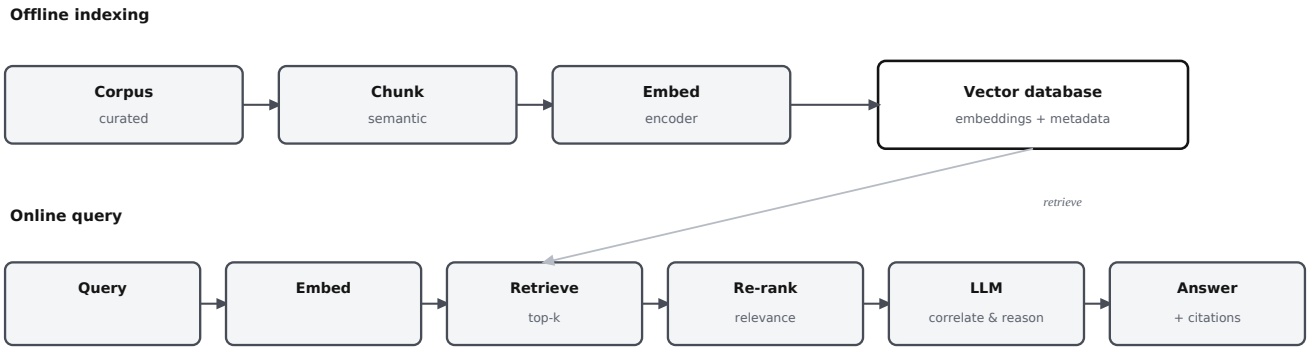



*Figure 11. Retrieval-augmented generation (RAG) architecture. An offline pipeline chunks and embeds the curated corpus into a vector database; at query time the system embeds the query, retrieves the top-k passages, re-ranks them, and the LLM correlates and reasons over the retrieved context to produce a cited answer — grounding outputs in evidence.*

| Component | Technology / choice | Role |
|---|---|---|
| **Embeddings** | Open sentence + code encoders (in-enclave) | Vectorise corpus and queries |
| **Chunking** | Semantic / structure-aware splitting | Preserve meaning of docs / code |
| **Vector database** | Open-source (FAISS / pgvector / Milvus-class) | Store embeddings; ANN search |
| **Retriever** | Top-k ANN with metadata filtering | Select candidate passages |
| **Re-ranker** | Cross-encoder | Precision ordering of candidates |
| **Correlation / LLM** | Fine-tuned cyber LLM (§4.v.1) | Reason over context; correlate findings |
| **Citations** | Source-linked provenance | Grounded, auditable answers |

**Table 10.** RAG design — components, technologies and roles. *Source:* Firm RAG design (Figure 11); RAG literature. *Interpretation:* Each RAG component is specified with an open-source, in-enclave choice and a clear role; the design grounds analysis in evidence and produces citations — essential for defensible, auditable security findings.

### 4.v.5 Agentic AI Framework Design

Agentic, multi-step reasoning enables deep vulnerability analysis and proof-of-concept chaining beyond single-shot prompting. The framework's agentic engine (§5.6, milestone M4; Annexure T) drives multi-turn red-teaming; the same agentic pattern, specialised for analysis, plans a task, retrieves context via RAG, analyses code / binaries, hypothesises a vulnerability, generates and validates a PoC chain in a sandbox, and reports correlated findings — iterating until validated (Figure 12). Orchestration uses open-source agentic / multi-step libraries (LangChain / AutoGen-class), entirely in-enclave.

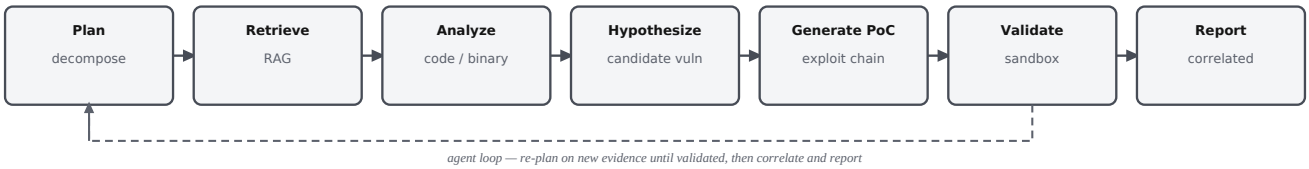



*Figure 12. Agentic vulnerability-analysis and PoC-chain workflow. A planning agent decomposes the task, retrieves context via RAG, analyses code / binaries, hypothesises a vulnerability, generates a proof-of-concept chain, validates it in a sandbox and reports correlated findings — iterating until validated, all within the enclave.*

### 4.v.6 Air-Gapped Deployment Strategy

The solution operates fully air-gapped, with no dependence on external cloud services — the precondition for handling sovereign / classified models. The strategy comprises an isolated network with deny-all egress, in-enclave package / image mirrors and reproducible builds, controlled-media-only transfer, offline model and signature updates, and confidential computing for weights in use. The air-gapped architecture is detailed in §5.4 with the network and development / test topologies in Figures 19 and 37, and the funded enclave specification in Annexure Q.

### 4.v.7 Vulnerability Detection and Evaluation Plan

Detection quality is measured, not asserted. Static, dynamic and LLM-assisted detectors produce ranked findings that an evaluation harness scores against labelled benchmark datasets, reporting precision, recall and F1 (Figure 13). The plan below maps each dataset to what it tests, the metric and the target.




*Figure 13. Vulnerability detection and evaluation pipeline. Inputs are processed by static, dynamic and LLM-assisted detectors; ranked findings are scored by an evaluation harness against labelled benchmark datasets (OWASP Benchmark, SARD, Juliet, CVE patch sets) reporting precision, recall and F1 — making detection quality measurable, not asserted.*

| Dataset | What it tests | Metric | Target |
|---|---|---|---|
| **OWASP Benchmark** | Web-vulnerability detection with true / false positives | Precision / recall / F1; FPR | High recall, low FPR |
| **SARD** | Labelled vulnerability patterns across many CWEs | Detection rate / F1 | Broad CWE coverage |
| **Juliet Test Suite** | C / C++ / Java flaw ↔ fixed pairs | Detection / discrimination | Flaw vs fixed |
| **CVE patch datasets** | Real vulnerability → patch pairs | Detection + patch relevance | Match known fixes |
| **Held-out internal** | LLM-specific findings (this framework) | Coverage / precision | Reproducible |

**Table 11.** Vulnerability detection and evaluation plan. *Source:* Firm evaluation plan (Figure 13); OWASP Benchmark, SARD, Juliet, CVE datasets. *Interpretation:* Detection is evaluated against recognised labelled datasets with precision / recall / F1 targets, making capability objectively measurable and comparable — the standard expected under technical scrutiny.

### 4.v.8 Malware Analysis and Reverse-Engineering Capability

For binary and serialised-artefact threats, the firm applies established reverse-engineering tooling and a structured analysis plan (Figure 14). Static reverse engineering uses industry-standard disassembly and decompilation tooling; dynamic analysis detonates samples in an isolated sandbox; features (strings, imports, control-flow, behaviour) are extracted and the sample is classified, producing a verdict and indicators of compromise. All analysis is performed inside the air-gapped enclave.

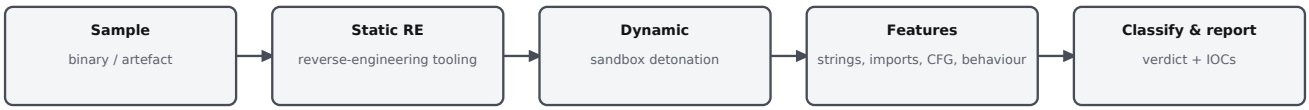



*Figure 14. Malware analysis and reverse-engineering workflow. A sample undergoes static reverse engineering (reverse-engineering tooling — disassembly, strings, imports, control-flow), dynamic detonation in an isolated sandbox, feature extraction and classification, producing a verdict and indicators of compromise — executed only inside the air-gapped enclave.*

| Tool / capability | Use |
|---|---|
| **Disassembly & decompilation** | Static reverse engineering, control-flow recovery, headless scripting for batch analysis |
| **Binary analysis framework** | Disassembly, binary analysis and scripting |
| **Interactive RE interface** | GUI-driven reverse engineering over the analysis engine |
| **Sandbox (containers / VMs)** | Dynamic detonation and behavioural observation |
| **Strings / imports / signatures** | Indicators, signatures and triage |

**Table 12.** Malware analysis / reverse-engineering tooling and plan. *Source:* Firm RE tooling note (Figure 14). *Interpretation:* Industry-standard reverse-engineering tools plus sandboxed dynamic analysis give static and behavioural coverage of binary and serialised-artefact threats; sample analysis reports are furnished separately.

### 4.v.9 Secure Code Patching Approach

As a recommended capability, the firm generates and validates secure code patches with documented fix rationale (Figure 15). From a localised vulnerability, root-cause analysis informs LLM-assisted generation of a minimal, idiomatic patch, which is validated by unit and regression tests and re-scanning before the patch and its rationale are documented and approved through human-in-the-loop sign-off; failed validation triggers regeneration.

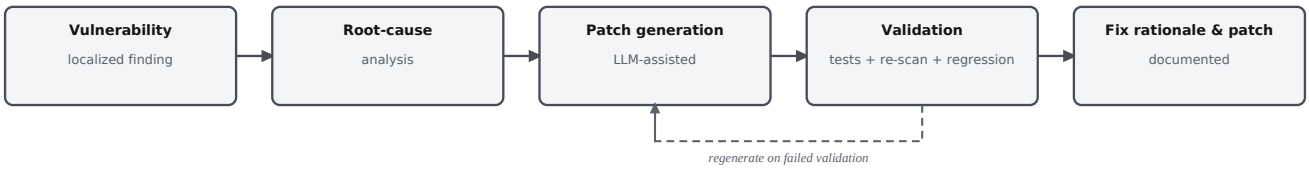



*Figure 15. Secure code patching workflow (recommended capability). From a localised vulnerability, root-cause analysis informs LLM-assisted patch generation, which is validated by tests, re-scanning and regression before the patch and its fix rationale are documented — regenerating on any failed validation, with a human-in-the-loop sign-off.*

| Step | Activity | Output |
|---|---|---|
| **Localise** | Confirm vulnerability location and type | Precise locus |
| **Root-cause** | Analyse cause and impact | Cause statement |
| **Generate** | LLM-assisted minimal, idiomatic patch | Candidate patch |
| **Validate** | Unit / regression tests; re-scan; build | Pass / fail + evidence |
| **Rationale** | Document fix and residual risk | Fix rationale |
| **Sign-off** | Human-in-the-loop review and approval | Approved patch + report |

**Table 13.** Secure code patching workflow. *Source:* Firm patching approach (Figure 15). *Interpretation:* Patch generation is bounded by root-cause analysis, multi-stage validation and human sign-off with documented rationale — a controlled, auditable approach rather than unconstrained automated rewriting.

# 5 DEVELOPMENT ESTIMATES (WITH RESPECT TO TIME)

This section responds to EOI Item 5. Sub-section 5.1 answers Item 5(i) — the estimated development time and its break-up — through a fully resourced 24-month plan organised into eight stage-gated milestones, supported by the methodology, organisation, infrastructure, technology-stack, verification, risk, compliance and effort analyses in 5.2–5.19. Sub-section 5.20 answers Item 5(ii) on prior suo-moto development, and 5.21–5.22 set out the proof-of-concept and the testing & qualification plans.

## 5.1 Estimated development time and schedule [Item 5(i)]

The proposed solution will be delivered in **24 months** — the EOI ceiling — decomposed into **eight milestones (M1–M8) of three months each**, executed as a single stage-gated critical chain. The sequence follows the system's natural build order: a secure air-gapped platform first (M1), then the engines in dependency order (M2–M6), then integration, confidential-computing hardening and performance optimisation (M7), and finally independent verification & validation, accreditation integration and a pilot assessment (M8). Four workstreams — programme governance, the Indian-language harm taxonomy, security/compliance/documentation, and academic R&D; — run continuously in parallel so that research-forward components mature ahead of the gates that consume them (Figure 16). The plan is deliberately effort-sequenced rather than compressed: selected sub-tasks parallelise within each milestone, preserving schedule contingency without extending the 24-month envelope.

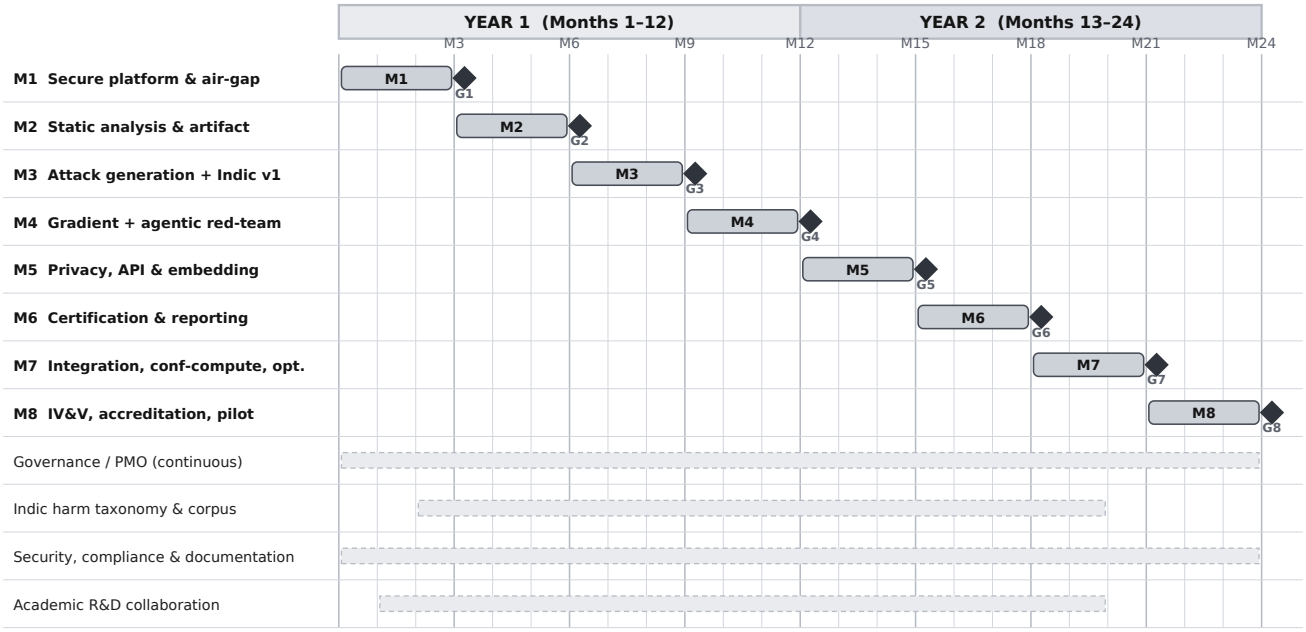



*Figure 16. Indicative 24-month master schedule (Gantt). Eight stage-gated milestones (M1–M8, solid bars) run sequentially in three-month increments to a hard 24-month ceiling, over four continuous workstreams (dashed). Each milestone closes at a formal gate (G1–G8). Note: schedule is effort-sequenced; selected sub-tasks parallelise within a milestone.*

| M | Months | TRL (start → target) | Primary theme | Headline deliverable at gate |
|---|---|---|---|---|
| **M1** | 1–3 | 2→4 | Secure platform & air-gap infrastructure | Hardened, air-gapped serving + ingestion platform; security baseline |
| **M2** | 4–6 | 3→5 | Static analysis & model-artifact security | Artifact scanner (multi-format) + sandbox detonation; >90% on test corpus |
| **M3** | 7–9 | 3→5 | Adversarial attack generation + Indic v1 | Injection/jailbreak battery (50+) + Indic corpus v1; coverage targets met |
| **M4** | 10–12 | 3→5 | Gradient attacks + agentic red-teaming | GCG/AutoDAN + multi-turn agentic engine (PAIR/TAP/Crescendo) |
| **M5** | 13–15 | 3→5 | Privacy, API & embedding audit | LiRA/RMIA MIA (>80% canaries) + API fuzzing + embedding analysis |
| **M6** | 16–18 | 4→6 | Certification, mapping & reporting | OWASP/ATLAS/NIST mapping engine + signed report generator |
| **M7** | 19–21 | 5→6 | Integration, conf-compute, optimisation | Integrated suite; TEE; <4 h full suite on 7B; Indic taxonomy v2 |
| **M8** | 22–24 | 6→7 | Independent V&V;, accreditation, pilot | IV&V; report; accreditation-export adapter; pilot certification & handover |

**Table 14.** Milestone summary — timeframe, Technology Readiness Level progression, theme and gate deliverable. *Source:* Cyberultron programme plan; TRL per ISO 16290 / DRDO usage; EOI §2.4 targets. *Interpretation:* The system advances from TRL 2–3 (proof-of-concept) to TRL 6–7 (validated in a relevant/operational environment) across eight equal gates, each with a measurable headline deliverable.

### 5.2 Development methodology and governance

**Approach.** Development follows a **milestone-based, stage-gated lifecycle with an iterative inner loop** (a Spiral/Agile hybrid) — the model recommended for technically novel, security-critical systems where requirements are stable (fixed by the EOI) but solution risk is concentrated in a few research-forward components. Each engine is developed in short design–build–unit-test–**adversarial self-test** iterations; the system red-teams itself continuously, so security quality is built in rather than inspected in at the end (Figure 17).

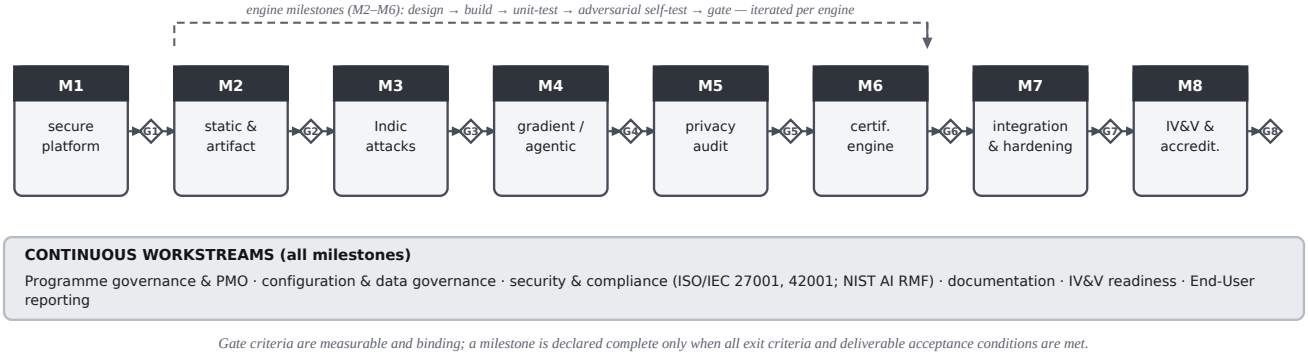



*Figure 17. Development methodology — a milestone-based, stage-gated lifecycle with an iterative inner loop for the engine milestones (Spiral/Agile hybrid) and continuous governance workstreams. Gates G1–G8 close milestones M1–M8 and are the formal acceptance checkpoints.*

**Governance and stage-gates.** Each milestone closes at a **binding gate (G1–G8)** with measurable exit criteria and formal deliverable acceptance; work on the next milestone's gated scope does not begin until the predecessor gate is cleared. A Programme Management Office maintains the schedule, risk register, configuration baseline and a fortnightly progress cadence with the End-User. The lifecycle and its controls are aligned to **ISO/IEC 27001** (information security management), **ISO/IEC 42001** (AI management system) and the **NIST AI RMF** Govern/Map/Measure/Manage functions, providing auditable governance throughout. This mirrors

the assurance posture expected of a defence-grade programme and withstands procurement and security review.

### 5.3 Programme organisation and manpower

Delivery is led by a single accountable Programme Director / Principal Investigator (the Founder & CEO), supported by a PMO and five delivery workstreams, an independent technical advisory board, a dedicated DRDO liaison, and a capped academic R&D; partner for the research-forward components (Figure 18). The structure gives clear single-point accountability while isolating the highest-risk research into a workstream with external scientific support.

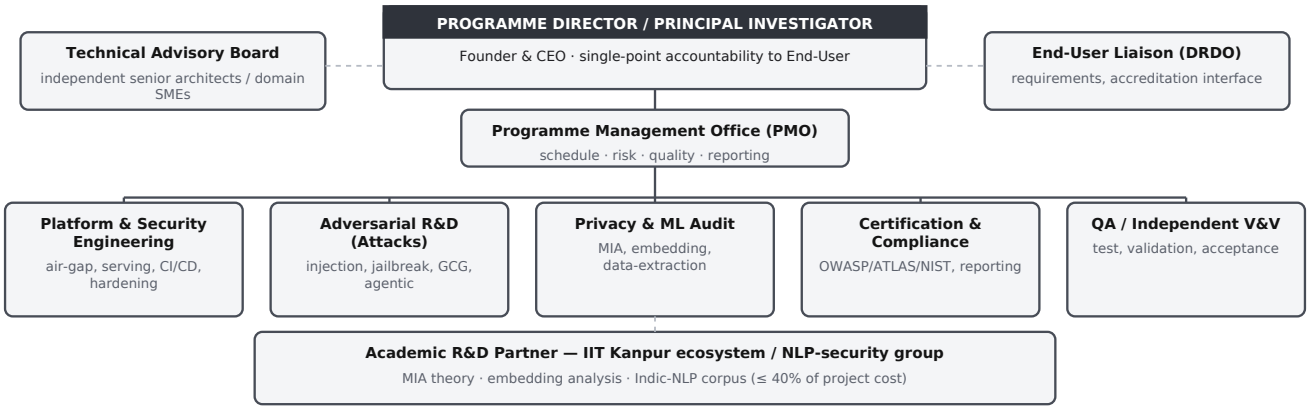



*Figure 18. Programme organisation. A single accountable Programme Director / Principal Investigator, a PMO, five delivery workstream leads, an independent advisory board, a dedicated End-User (DRDO) liaison, and a capped academic R&D partner for the research-forward components.*

Indicative effort is expressed in **person-months (PM)** as a schedule/resourcing measure; no commercial or cost information is included, consistent with EOI requirements. The allocation below is sized for the 24-month envelope and front-loads platform and attack-engineering capacity, with verification capacity rising toward M8.

| Role / workstream | Heads | Primary focus | Indicative effort (PM) |
|---|---|---|---|
| **Programme Director / PI** | 1 | Accountability, architecture authority, End-User interface, technical sign-off | 12 |
| **Platform & Security Engineering** | 3 | Air-gap platform, serving substrate, CI/CD, hardening, confidential computing | 60 |
| **Adversarial R&D; (Attacks)** | 3 | Injection/jailbreak, gradient attacks, agentic red-teaming, attack corpora | 54 |
| **Privacy & ML Audit** | 2 | Membership inference, embedding analysis, data-extraction, API audit | 30 |
| **Certification & Compliance** | 2 | OWASP/ATLAS/NIST mapping, scoring, reporting, standards alignment | 26 |
| **QA / Independent V&V;** | 2 | Test automation, validation against FoM, acceptance, IV&V; (independent at M8) | 26 |
| **Academic R&D; partner (capped)** | — | MIA theory, embedding/poisoning detection, Indic-NLP corpus (≤ 40% of project cost) | 18 |
| **Programme indicative total** | 13 | Core delivery team plus capped academic contribution across 24 months | ≈ 226 |

**Table 15.** Indicative manpower and effort allocation (person-months) across the 24-month programme. *Source:* Cyberultron resourcing plan; TDF academic-contribution rule (≤ 40%). *Interpretation:* Effort is weighted toward platform and adversarial engineering (the build-heavy core); verification effort is independent at M8. Figures are effort, not cost.

| Key activity | PD/PI | Platform | Attacks | Privacy | Cert. | QA/V&V; | Academic | DRDO |
|---|---|---|---|---|---|---|---|---|
| **Architecture & security design** | A | R | C | C | C | C | I | C |
| **Air-gap platform & infra** | A | R | I | I | I | C | – | I |
| **Attack engines & corpora** | A | C | R | C | I | C | C | I |
| **Privacy / embedding audit** | A | I | C | R | I | C | C | I |
| **Indic harm taxonomy** | A | I | C | C | C | I | R | C |
| **Certification & reporting** | A | I | I | I | R | C | I | C |
| **V&V; & acceptance** | A | C | C | C | C | R | I | C |
| **Accreditation integration** | A | C | I | I | R | C | – | R |

**Table 16.** Responsibility assignment (RACI) for principal activities. R = responsible, A = accountable, C = consulted, I = informed. *Source:* Cyberultron delivery model. *Interpretation:* Single-point accountability rests with the PD/PI for every activity; the DRDO End-User is consulted on design and responsible jointly for accreditation integration.

### 5.4 Infrastructure, network and security architecture

The development and target environments are stood up in M1 and hardened through M7. The network is fully air-gapped with no routable external path; the only ingress/egress is a unidirectional, signed-and-scanned controlled-media transfer (Figure 19). Security follows a defence-in-depth model of eight independent control layers (Figure 20), and the runtime is a single offline container-orchestrated cluster across four node roles (Figure 21). This posture is mandatory because the system, by design, loads and executes **untrusted model artifacts** — the threat model assumes the input is hostile and contains it through isolation, least privilege and a tamper-evident signed audit trail.

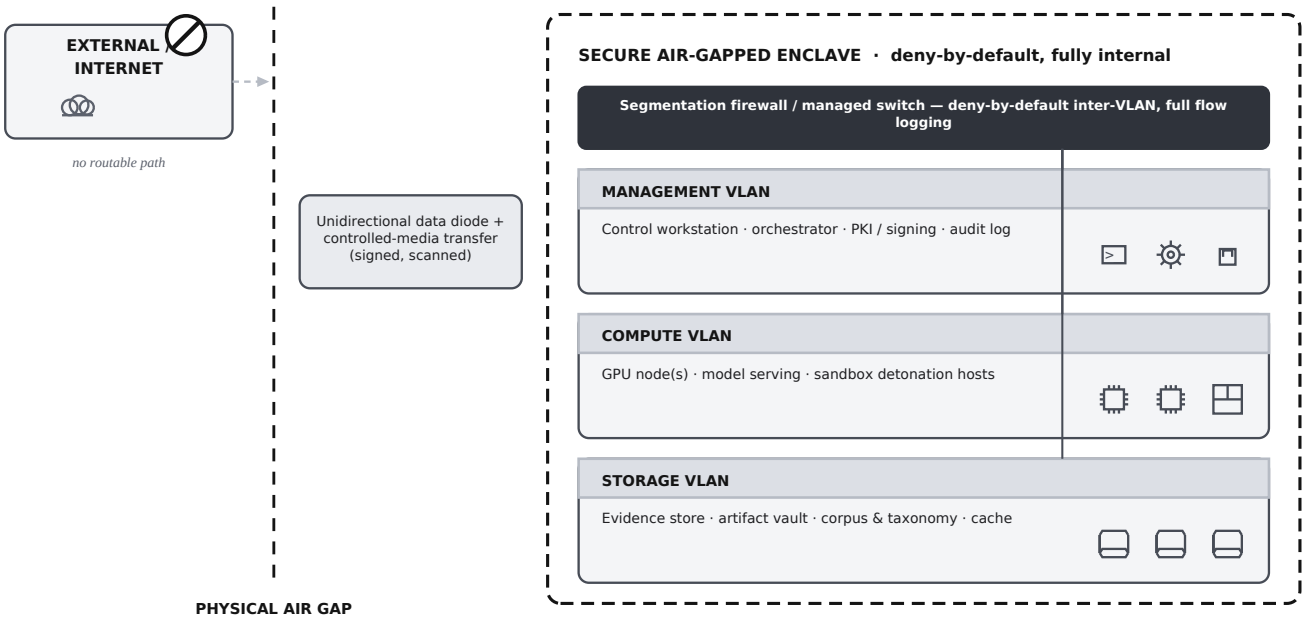



*Figure 19. Network topology. The enclave has no routable path to any external network; the only ingress/egress is a unidirectional, signed-and-scanned controlled-media transfer across a physical air gap. Internally, three deny-by-default VLAN segments (management, compute, storage) are isolated by a logging segmentation firewall.*

| | |
|---|---|
| **PHYSICAL / FACILITY** | Access-controlled secure room; tamper-evident hardware; controlled-media custody |
| **NETWORK** | Air-gap; deny-all egress; VLAN micro-segmentation; full flow logging |
| **HOST / OPERATING SYSTEM** | Hardened Linux (CIS benchmarks); minimal services; integrity monitoring |
| **CONTAINER / RUNTIME** | Rootless containers; seccomp/AppArmor; disposable sandbox detonation of artifacts |
| **APPLICATION / ORCHESTRATION** | OPA/Rego policy; RBAC; per-run isolation; circuit-breakers & kill-switch |
| **DATA / CRYPTOGRAPHY** | Encryption at rest & in use (TEE); signed artifacts & SBOM; key management |
| **IDENTITY & ACCESS** | Least-privilege; separation of duties; strong auth for operators |
| **AUDIT & ASSURANCE** | Tamper-evident signed audit trail; reproducible builds; IV&V evidence |

*Defence-in-depth: independent, layered controls so that compromise of any single layer does not breach the model, its data, or the findings.*

*Figure 20. Security architecture (defence-in-depth). Eight independent control layers, from facility to signed audit, map to ISO/IEC 27001 controls and the NIST AI RMF. The design assumes hostile inputs (untrusted model artifacts) and contains them through isolation and least privilege.*

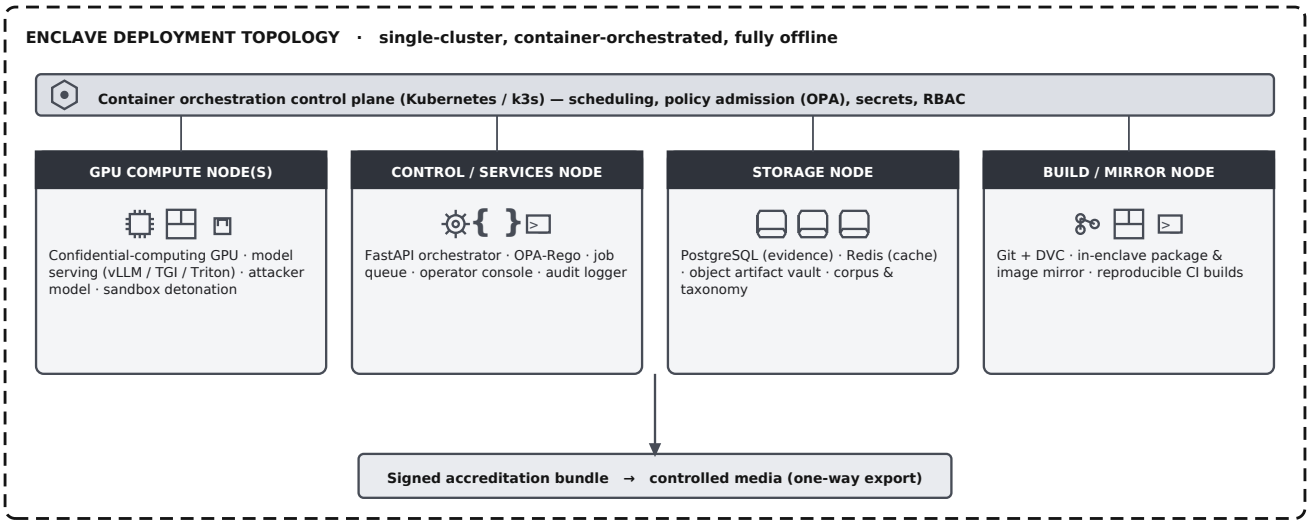



*Figure 21. Deployment topology. A single offline container-orchestrated cluster across four node roles (GPU compute, control/services, storage, build/mirror). All images and packages are mirrored in-enclave for reproducible builds; the only output is a signed bundle on controlled media.*

### 5.5 Technology stack

The solution is built on a wholly **Python-native, container-orchestrated, self-hostable** stack of permissively-licensed components (Apache-2.0 / MIT / BSD), organised in seven layers (Figure 22). The choice is deliberate: every layer can be forked, mirrored in-enclave and operated with zero external dependency or telemetry, which is the precondition for sovereign, air-gapped operation and the indigenous-content position in §4.iv. The stack reuses the production-proven foundations of Cyberultron's existing AI-security capabilities (serving, policy enforcement, observability), reducing platform risk in M1.

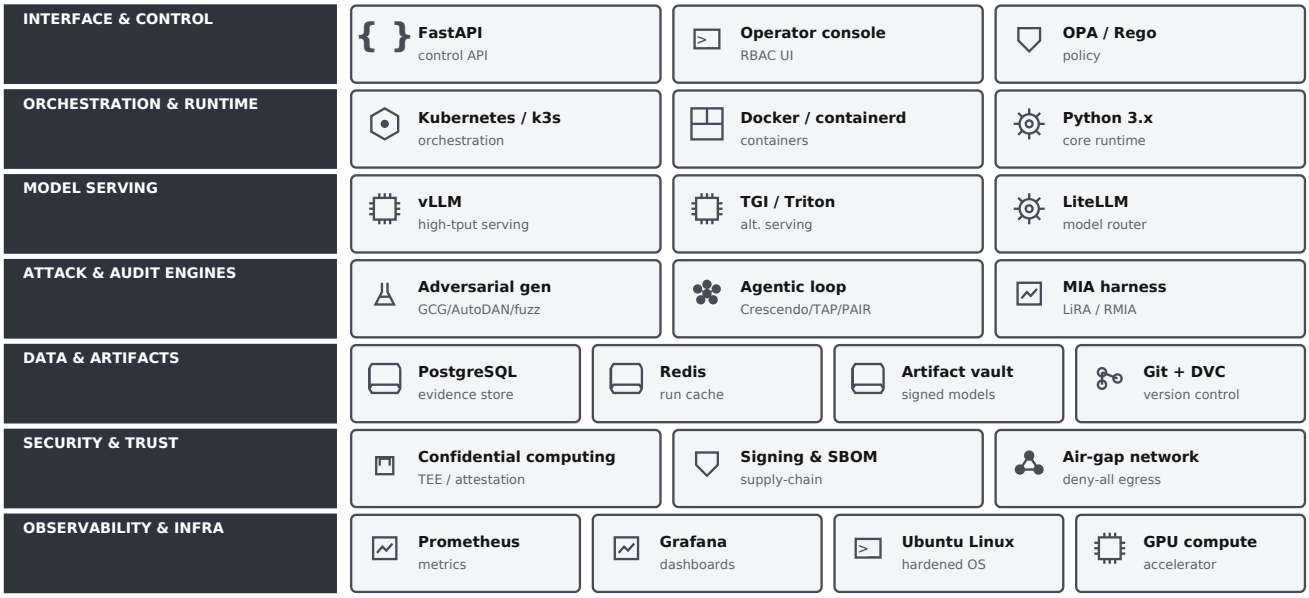



*Figure 22. Technology stack. A wholly Python-native, container-orchestrated, self-hostable stack organised in seven layers. Every component is permissively licensed (Apache-2.0 / MIT / BSD), forked and mirrored in-enclave at delivery, with no runtime foreign dependency or telemetry (icons are schematic component indicators, not vendor marks).*

### 5.6 Milestone-wise development plan (M1–M8)

Each milestone below specifies its objectives, work packages (with indicative effort), technical approach and rationale (with the prior-art weakness it addresses), deliverables and acceptance basis, binding gate exit criteria, and key risks with mitigations. Together they constitute the detailed break-up requested in Item 5(i). All thresholds are the EOI §2.4 figures of merit; all effort is in person-months (PM).

| M 1 | **Secure Platform & Air-Gap Infrastructure**<br>**Foundational enclave, serving substrate, orchestration and security baseline** | TIMEFRAME<br>**Months 1–3** | TRL<br>**2 → 4** |
|---|---|---|---|

**Objectives.** Stand up the air-gapped enclave and the foundation on which every engine runs: secure model ingestion with provenance, the model-serving substrate, the orchestration / policy control plane, the disposable-sandbox execution environment, an in-enclave CI/CD and package/image mirror, observability, and a documented defence-in-depth security baseline. The milestone establishes a sovereign, zero-egress operating base from day one.

| WP | Work package | Key tasks | PM |
|---|---|---|---|
| **1.1** | **Enclave network & segmentation** | Air-gapped segment; deny-all egress; VLAN micro-segmentation; controlled-media transfer; flow logging | 10 |
| **1.2** | **Compute & serving substrate** | GPU node bring-up; vLLM / TGI / Triton serving; LiteLLM routing; reference 7B model served in-enclave | 12 |
| **1.3** | **Orchestration & policy plane** | FastAPI control plane; job queue; OPA / Rego policy; RBAC; per-run isolation; circuit-breaker & kill-switch | 12 |
| **1.4** | **Secure ingestion & provenance** | Signed intake; checksums / fingerprints; architecture-metadata capture; signed artifact vault | 8 |
| **1.5** | **Sandbox & isolation** | Disposable VM / rootless-container detonation host; seccomp / AppArmor; no host side-effects | 6 |
| **1.6** | **CI/CD, mirror, observability & baseline** | In-enclave Git + image/package mirror; reproducible builds; Prometheus / Grafana; security-baseline document | 8 |

**Table 17.** M1 work packages and indicative effort. *Source:* Cyberultron programme plan; EOI §2.3(i). *Interpretation:* Platform effort (≈ 56 PM) is front-loaded so that all subsequent engines build on a stable, hardened, sovereign base.

**Technical approach & rationale.** The air-gap is non-negotiable for sovereign models: 2026 independent vendor analyses confirm that **no foreign LLM-security platform offers an air-gapped deployment**, so routing classified weights through them is precluded; the platform is therefore built zero-egress from the outset (addresses OWASP LLM03 supply-chain exposure and EOI Undertaking 15(a)). Security follows ISO/IEC 27001 controls in a defence-in-depth arrangement (Figure 20). The serving and policy foundations reuse the production-proven components of Cyberultron's existing AI-security capabilities, materially reducing platform risk. Reproducible builds from an in-enclave mirror give supply-chain integrity and auditability; confidential-computing enablement is scaffolded here and completed in M7.

| ID | Deliverable | Type | Acceptance basis |
|---|---|---|---|
| **D1.1** | Air-gapped enclave (network + segmentation) operational | Environment | Egress-denial test passes; segmentation enforced and logged |
| **D1.2** | Model-serving substrate serving a reference 7B model | Software / env. | Reference model served in-enclave at target throughput |
| **D1.3** | Orchestrator + OPA-Rego policy plane | Software | RBAC, per-run isolation, kill-switch demonstrated |
| **D1.4** | Secure ingestion & provenance pipeline + signed vault | Software | Artifact signed, fingerprinted, vaulted with audit entry |
| **D1.5** | Disposable sandbox execution environment | Environment | Test artifact detonated with zero host side-effects |
| **D1.6** | Security baseline document + CI/CD + observability | Document / infra | Baseline review passed; reproducible build from mirror |

**Table 18.** M1 deliverables and acceptance basis. *Source:* Cyberultron programme plan. *Interpretation:* Acceptance is evidence-based (tests and a security review), not self-declared; D1.1–D1.6 collectively constitute the sovereign operating base.

| Gate exit criterion | Measure / threshold | Verification method |
|---|---|---|
| **Zero external network route** | No successful egress on any port/protocol | Independent network egress test + log review |
| **In-enclave serving** | Reference 7B model served; latency/throughput within plan | Functional + performance test |
| **Policy enforcement** | RBAC, per-run isolation, kill-switch all enforced | Policy test cases; attempted privilege escalation blocked |
| **Artifact provenance** | 100% of ingested artifacts signed & fingerprinted | Vault audit; tamper test detected |
| **Reproducible build** | Byte-identical rebuild from in-enclave mirror | Reproducible-build verification |

**Table 19.** M1 gate (G1) exit criteria. *Source:* Cyberultron programme plan; EOI §2.4 (air-gapped security). *Interpretation:* Every criterion is measurable and independently verifiable; G1 must clear before any engine development on the gated path begins.

| Risk | L / I | Mitigation |
|---|---|---|
| **GPU / confidential-computing hardware lead time** | M / H | Early procurement; Indian-cloud or interim GPU for development; CC completed in M7, not M1-critical |
| **Integration complexity of control plane** | M / M | Reuse production-proven serving & policy components; thin vertical slice first |
| **Hardening introduces regressions** | L / M | Baseline-as-code; automated CI security checks; staged rollout |

**Table 20.** M1 key risks and mitigations. *Source:* Cyberultron risk register (extract). *Interpretation:* The dominant risk is hardware lead time; it is mitigated by decoupling confidential computing from the M1 critical path and using interim compute for development.

| M 2 | **Static Analysis & Model-Artifact Security**<br>**Scan-before-load: detect malicious objects, telemetry and backdoors in model files** | TIMEFRAME<br>**Months 4–6** | TRL<br>**3 → 5** |
|---|---|---|---|

**Objectives.** Build the static-analysis engine that inspects every model artifact **before any weight is loaded for inference**: pickle/bytecode analysis, multi-format parsing (safetensors, ONNX, H5, framework checkpoints), structure-aware fuzzing, sandboxed detonation of untrusted artifacts, and an offline backdoor-signature database with SBOM generation. Enforce a scan-before-load gate in the orchestrator.

| WP | Work package | Key tasks | PM |
|---|---|---|---|
| **2.1** | **Bytecode / pickle analyzer** | Opcode-level analysis; dangerous-callable detection; deserialization-graph reconstruction | 10 |
| **2.2** | **Multi-format scanner + safe-format steering** | safetensors / ONNX / H5 / checkpoint readers; steer ingestion to non-executable formats | 10 |
| **2.3** | **Structure-aware fuzzer** | Grammar/structure-aware mutation of artifact containers; crash & anomaly triage | 8 |
| **2.4** | **Sandbox detonation harness** | Detonate untrusted artifacts in disposable VM/container; behaviour capture; egress attempt detection | 8 |
| **2.5** | **Backdoor-signature DB + SBOM** | Offline signature corpus; SBOM generation; provenance cross-check; controlled-media refresh | 6 |
| **2.6** | **Scanner integration + scan-before-load gate** | Verdict service (clean/quarantine); orchestrator enforcement; evidence to store | 6 |

**Table 21.** M2 work packages and indicative effort. *Source:* Cyberultron programme plan; EOI §2.3(d). *Interpretation:* Coverage is built from three independent techniques (static, fuzzing, detonation) so that evasion of any one does not defeat detection.

**Technical approach & rationale.** Leading open-source scanners are **insufficient on their own**: leading open-source model-artifact scanners had documented CVEs and bypasses disclosed across 2025 (Sonatype, JFrog and Cisco), so a signature-only approach is brittle. The engine therefore layers bytecode static analysis with **structure-aware fuzzing** and **sandboxed detonation**, and actively steers ingested models toward safe-by-design formats (safetensors, ONNX) that cannot execute arbitrary code on load — directly mitigating OWASP LLM03 (supply chain) and LLM04 (data/model poisoning) and exceeding, rather than re-implementing, the foreign baseline. Detection is benchmarked against a curated malicious-model corpus to the EOI §2.4 target of >90%.

| ID | Deliverable | Type | Acceptance basis |
|---|---|---|---|
| **D2.1** | Pickle / bytecode analyzer | Software | Detects dangerous callables on labelled set; no false-clean on known-malicious |
| **D2.2** | Multi-format scanner + safe-format steering | Software | Parses target formats; flags executable-on-load artifacts |
| **D2.3** | Structure-aware artifact fuzzer | Software | Surfaces malformed/abusive container anomalies |
| **D2.4** | Sandbox detonation harness | Software / env. | Isolates a live exploit artifact; captures behaviour; blocks egress |
| **D2.5** | Backdoor-signature DB + SBOM generator | Data / software | SBOM produced; provenance cross-checked offline |
| **D2.6** | Integrated scanner with scan-before-load gate | Software | Orchestrator refuses load on quarantine verdict |

**Table 22.** M2 deliverables and acceptance basis. *Source:* Cyberultron programme plan. *Interpretation:* The scan-before-load gate (D2.6) makes safe ingestion a system invariant rather than a procedure.

| Gate exit criterion | Measure / threshold | Verification method |
|---|---|---|
| **Malicious-artifact detection rate** | ≥ 90% on the curated malicious-model corpus | Benchmark against labelled corpus |
| **No false-clean on known-malicious** | Zero known-malicious artifacts passed as clean | Regression on known-malicious set |
| **Detonation isolation** | Live exploit contained; zero host effect / egress | Red-team detonation test in sandbox |
| **Scan-before-load enforced** | 100% of loads preceded by a clean verdict | Orchestrator log audit |

**Table 23.** M2 gate (G2) exit criteria. *Source:* Cyberultron programme plan; EOI §2.4 (model-artifact malware detection). *Interpretation:* Thresholds are quantitative and benchmarked; the gate proves the engine exceeds the brittle signature-only baseline.

| Risk | L / I | Mitigation |
|---|---|---|
| **Novel obfuscation evades signatures** | M / M | Defence in depth: fuzzing + detonation catch behaviours signatures miss |
| **Format-coverage gaps for rare artifacts** | L / M | Prioritise common formats; extensible parser plug-ins; steer to safe formats |
| **Detonation performance overhead** | L / L | Tiered scanning: cheap static first, detonation only on suspicion |

**Table 24.** M2 key risks and mitigations. *Source:* Cyberultron risk register (extract). *Interpretation:* Layered detection makes the engine resilient to the very bypasses that defeated single-method foreign scanners in 2025.

| M 3 | **Adversarial Attack Generation + Indic Corpus v1**<br>**Black-box injection & jailbreak battery, plus the first sovereign Indian-language harm corpus** | TIMEFRAME<br>**Months 7–9** | TRL<br>**3 → 5** |
|---|---|---|---|

**Objectives.** Build the attack-generation engine — prompt-injection fuzzing, a library of 50+ jailbreak methodologies, and a benchmark harness — together with version 1 of the **Indian-language harm taxonomy**

**and corpus** (Hindi, Tamil, Telugu, Bengali and one further language). All attacks here are query-based and therefore usable against any model, indigenous or procured.

| WP | Work package | Key tasks | PM |
|---|---|---|---|
| **3.1** | **Prompt-injection fuzzing engine** | Direct/indirect injection patterns; mutation; corpus of 10,000+ injection prompts; learned novelty classifier | 12 |
| **3.2** | **Jailbreak library (50+)** | DAN families, DeepInception, ArtPrompt, PAP, role-play, encoding/obfuscation techniques | 10 |
| **3.3** | **Benchmark harness** | AdvBench / HarmBench / XSTest integration; scoring; reproducible runs | 6 |
| **3.4** | **Indic harm taxonomy v1 + corpus** | Defence harm categories; native-language prompt corpus across 5 languages; native-speaker validation | 14 |
| **3.5** | **Attack orchestration & scoring** | Campaign runner; refusal/bypass scoring; evidence capture to store | 6 |
| **3.6** | **Coverage measurement** | Known vs zero-shot coverage instrumentation against EOI targets | 4 |

**Table 25.** M3 work packages and indicative effort. *Source:* Cyberultron programme plan; EOI §2.3(a),(j). *Interpretation:* The Indic corpus (WP3.4) is the single largest research item and is resourced accordingly, with academic linguistics support.

**Technical approach & rationale.** The decisive gap in every foreign tool is the absence of an **Indian-language harm corpus**. Safety alignment is English-centric; peer-reviewed work (Yong et al., Brown; Deng et al., DAMO) shows low-resource languages are ~3× more likely to elicit harmful output, with combined attacks reaching ~79% success. The engine therefore curates a sovereign Indic taxonomy and corpus, validated by native speakers, addressing OWASP LLM01 and the EOI §2.4 multilingual requirement. Injection coverage targets >95% on known patterns (signature/corpus matching) and >70% zero-shot (structure-aware fuzzing plus a learned novelty classifier on held-out patterns); the jailbreak library exceeds the 50-methodology target drawn from OWASP LLM and current security benchmarks. The harm corpus is enclave-resident and access-controlled, used solely for defensive assessment.

| ID | Deliverable | Type | Acceptance basis |
|---|---|---|---|
| **D3.1** | Prompt-injection fuzzer + 10,000+ prompt corpus | Software / data | Coverage targets met on known & held-out sets |
| **D3.2** | Jailbreak library (50+ methodologies) | Software | ≥ 50 techniques integrated and runnable |
| **D3.3** | Benchmark harness (AdvBench/HarmBench/XSTest) | Software | Reproducible benchmark runs with scoring |
| **D3.4** | Indian-language harm taxonomy v1 + corpus | Data / IP | ≥ 5 languages; native-speaker validation sign-off |
| **D3.5** | Attack orchestration & scoring service | Software | Campaigns run end-to-end; evidence captured |
| **D3.6** | Coverage measurement report | Document | Known/zero-shot coverage quantified vs EOI |

**Table 26.** M3 deliverables and acceptance basis. *Source:* Cyberultron programme plan. *Interpretation:* D3.4 is net-new sovereign IP and the principal differentiator of the framework.

| Gate exit criterion | Measure / threshold | Verification method |
|---|---|---|
| **Known-injection coverage** | ≥ 95% of known injection patterns | Benchmark vs known-pattern corpus |
| **Zero-shot injection coverage** | ≥ 70% on held-out novel patterns | Held-out evaluation |
| **Jailbreak coverage** | ≥ 50 methodologies integrated | Library audit + execution test |
| **Indic corpus validated** | ≥ 5 languages, native-speaker validated | Linguistic validation record |

**Table 27.** M3 gate (G3) exit criteria. *Source:* Cyberultron programme plan; EOI §2.4 (injection coverage, jailbreak count, multilingual). *Interpretation:* Coverage is split into known and zero-shot to match the EOI's two-part target honestly.

| Risk | L / I | Mitigation |
|---|---|---|
| **Zero-shot coverage target is demanding** | M / M | Combine fuzzing with a learned novelty classifier; iterate against held-out sets |
| **Indic corpus quality & validation effort** | M / H | Academic computational-linguistics partner; native-speaker review; staged language rollout |
| **Sensitive-content governance** | L / H | Enclave-only, access-controlled, audit-logged; defensive-use-only policy |

**Table 28.** M3 key risks and mitigations. *Source:* Cyberultron risk register (extract). *Interpretation:* Corpus maturity (R6) is the highest-impact item and is de-risked through academic partnership and staged language coverage.

## M 4 — Gradient Attacks + Agentic Red-Teaming

**White-box optimisation for indigenous models and multi-turn agentic attacks for any model**

TIMEFRAME **Months 10-12** | TRL **3 → 5**

**Objectives.** Add white-box gradient attacks (GCG, I-GCG, AutoDAN) for indigenous models with weight access, and an **agentic multi-turn red-teaming** engine (PAIR, TAP, Crescendo) driven by an air-gapped attacker model, including multi-turn attacks in Indian languages and a refusal/alignment scoring module. The engine auto-selects the attack family from the target's declared access model.

| WP | Work package | Key tasks | PM |
|---|---|---|---|
| **4.1** | **Gradient attack module (GCG / I-GCG)** | Greedy-coordinate-gradient suffix search; improved I-GCG convergence; transfer testing | 12 |
| **4.2** | **AutoDAN (genetic, fluent prompts)** | Hierarchical genetic optimisation; low-perplexity, filter-evading prompts | 8 |
| **4.3** | **Agentic orchestrator (attacker-LLM loop)** | Air-gapped attacker model; conversation state; budgeted multi-turn campaigns | 12 |
| **4.4** | **Multi-turn strategies (PAIR / TAP / Crescendo)** | Iterative refinement (PAIR), tree-of-attacks (TAP), gradual escalation (Crescendo) | 10 |
| **4.5** | **Multi-turn Indic attacks** | Conversational low-resource-language attacks; code-switching; Indic corpus integration | 8 |
| **4.6** | **Scoring + access-model auto-selection** | Refusal/alignment scoring; white-box vs black-box routing logic | 4 |

**Table 29.** M4 work packages and indicative effort. *Source:* Cyberultron programme plan; EOI §2.3(b),(g). *Interpretation:* Gradient and agentic tracks proceed in parallel; the access-model router (WP4.6) unifies them behind one interface.

**Technical approach & rationale.** Gradient methods are powerful but require white-box access: GCG performs greedy-coordinate-gradient suffix search (transferable but perplexity-detectable), I-GCG improves success and convergence (~400 iterations), and AutoDAN produces fluent, filter-evading prompts via genetic optimisation. These apply to **indigenous** models; for **procured black-box** models the engine relies on query-only methods —

PAIR (iterative refinement), TAP (tree-of-attacks with pruning) and Crescendo (gradual escalation). 2026 studies show that even where single-turn translation attacks are patched, **multi-turn low-resource-language attacks remain effective**, motivating WP4.5. The attacker model is served in-enclave (no foreign API), preserving the air gap. This addresses OWASP LLM01 and LLM07 and the EOI's white-box + agentic requirements; the auto-selection logic ensures correct method choice per target.

| ID | Deliverable | Type | Acceptance basis |
|---|---|---|---|
| **D4.1** | Gradient attack module (GCG / I-GCG) | Software | Adversarial suffix found on reference indigenous model |
| **D4.2** | AutoDAN genetic-attack module | Software | Produces fluent, low-perplexity, filter-evading prompts |
| **D4.3** | Agentic red-teaming orchestrator | Software | Runs budgeted multi-turn campaigns with in-enclave attacker |
| **D4.4** | Multi-turn strategy library (PAIR/TAP/Crescendo) | Software | All three strategies execute end-to-end |
| **D4.5** | Multi-turn Indian-language attack set | Software / data | Conversational Indic attacks demonstrated |
| **D4.6** | Scoring + access-model auto-selection | Software | Correct white-box/black-box routing verified |

**Table 30.** M4 deliverables and acceptance basis. *Source:* Cyberultron programme plan. *Interpretation:* The engine covers both access models, so it remains effective on procured models where gradients are unavailable.

| Gate exit criterion | Measure / threshold | Verification method |
|---|---|---|
| **Gradient attack effective (white-box)** | Suffix found on reference indigenous model | Attack run + success log |
| **Agentic loop operational** | PAIR/TAP/Crescendo run end-to-end in-enclave | Campaign execution test |
| **Multi-turn Indic attacks** | Demonstrated on ≥ 2 Indian languages | Conversational attack transcript review |
| **Access-model routing** | Correct family auto-selected per declared access | Routing test cases |

**Table 31.** M4 gate (G4) exit criteria. *Source:* Cyberultron programme plan; EOI §2.4 (jailbreak coverage, multilingual). *Interpretation:* Criteria validate both white-box and black-box pathways, ensuring no dependence on weight access for procured models.

| Risk | L / I | Mitigation |
|---|---|---|
| **Gradient optimisation compute cost** | M / M | 7B-scale focus; batched optimisation; GPU scheduling; cache transferable suffixes |
| **Agentic campaign instability / runaway** | M / M | Hard run budgets; circuit-breakers; deterministic seeds; in-enclave attacker model |
| **White-box unavailable for procured models** | L / L | By design: query-only PAIR/TAP/Crescendo cover the black-box case |

**Table 32.** M4 key risks and mitigations. *Source:* Cyberultron risk register (extract). *Interpretation:* Compute cost is the principal risk; it is bounded by 7B-scale targeting, batching and suffix caching.

| M 5 | **Privacy, API & Embedding Audit**<br>**Membership inference, data-extraction, inference-API security and representation analysis** | TIMEFRAME<br>**Months 13–15** | TRL<br>**3 → 5** |
|---|---|---|---|

**Objectives.** Build the privacy and audit engine: membership-inference attacks (LiRA, RMIA) against standard canaries, training-data / PII extraction tests, inference-API security testing (authorisation bypass, rate-limit flaws, function-calling abuse, denial-of-service), and embedding-space / representation analysis to detect sleeper agents, backdoor triggers and poisoning.

| WP | Work package | Key tasks | PM |
|---|---|---|---|
| **5.1** | **Membership-inference harness** | LiRA shadow-model training; RMIA reference population; TPR@low-FPR evaluation on canaries | 10 |
| **5.2** | **Data / PII extraction tests** | Canary insertion; extraction prompting; memorisation quantification | 6 |
| **5.3** | **Inference-API security testing** | API fuzzing; authz bypass; rate-limit & quota flaws; function-calling abuse; DoS probing | 8 |
| **5.4** | **Embedding / representation analysis** | Anomalous-cluster detection; backdoor-trigger probing; representation drift | 8 |
| **5.5** | **Sleeper-agent / poisoning detection** | Trigger-search heuristics; behaviour-divergence tests on suspected backdoors | 6 |
| **5.6** | **Integration & privacy scoring** | Unified privacy report; severity contribution; evidence capture | 4 |

**Table 33.** M5 work packages and indicative effort. *Source:* Cyberultron programme plan; EOI §2.3(c),(e),(f). *Interpretation:* Membership inference and embedding analysis are the research-heavy items and receive academic support.

**Technical approach & rationale.** Membership inference must be **scoped honestly**: published evidence shows MIA is far weaker on realistically single-epoch-trained LLMs than on canaries, so the EOI correctly targets **standard canary datasets**, where >80% accuracy is attainable. LiRA applies a Neyman–Pearson-optimal likelihood-ratio test using shadow models, evaluated at true-positive-rate under low false-positive-rate; RMIA uses a reference-model population for efficiency. API security adapts classical application-security testing to model-serving endpoints (OWASP LLM06 sensitive-information disclosure, LLM10 unbounded consumption). Embedding/representation analysis (sleeper-agent and backdoor detection) is deliberately research-forward (TRL 3 at entry) and is the strongest candidate for academic collaboration. The engine reports MIA strictly against canaries and does not over-generalise to production-trained models — a credibility-critical design choice for a government audience.

| ID | Deliverable | Type | Acceptance basis |
|---|---|---|---|
| **D5.1** | Membership-inference harness (LiRA + RMIA) | Software | ≥ 80% accuracy on standard canary datasets |
| **D5.2** | Data / PII extraction test suite | Software | Canary extraction & memorisation quantified |
| **D5.3** | Inference-API security tester | Software | Detects seeded authz / rate-limit / DoS flaws |
| **D5.4** | Embedding / representation analysis toolkit | Software | Flags injected backdoor trigger in a test model |
| **D5.5** | Sleeper-agent / poisoning detection | Software | Identifies behaviour-divergence on a planted backdoor |
| **D5.6** | Integrated privacy & audit report module | Software | Unified findings with severity contribution |

**Table 34.** M5 deliverables and acceptance basis. *Source:* Cyberultron programme plan. *Interpretation:* Honest, canary-scoped MIA reporting is itself an acceptance condition, distinguishing the framework from over-claiming tools.

| Gate exit criterion | Measure / threshold | Verification method |
|---|---|---|
| **Membership-inference accuracy** | ≥ 80% on standard canary datasets | LiRA/RMIA benchmark on canaries |
| **Data-extraction testing** | Canary extraction & memorisation reported | Extraction test run |
| **API security findings** | Seeded authz/rate-limit/DoS flaws detected | Red-team API test with planted flaws |
| **Embedding backdoor detection** | Injected trigger flagged in test model | Controlled backdoor experiment |

**Table 35.** M5 gate (G5) exit criteria. *Source:* Cyberultron programme plan; EOI §2.4 (membership-inference accuracy). *Interpretation:* Thresholds are benchmarked and, for MIA, explicitly bounded to canaries to avoid scientific over-statement.

| Risk | L / I | Mitigation |
|---|---|---|
| **Embedding analysis is research-forward (TRL 3)** | M / H | Academic collaboration; TRL-honest scoping; staged capability with fallback heuristics |
| **Risk of MIA over-claim** | L / M | Canary-only reporting; explicit scope statement in every report |
| **API-test false positives** | L / L | Validated findings only; reproducible proof-of-concept per finding |

**Table 36.** M5 key risks and mitigations. *Source:* Cyberultron risk register (extract). *Interpretation:* Embedding analysis (R2) carries the highest residual risk and is the focus of the academic partnership and milestone gating.

## M6 — Certification, Mapping & Reporting

**Automated mapping to OWASP / ATLAS / NIST, severity scoring and signed certification reports**

TIMEFRAME **Months 16–18** | TRL **4 → 6**

**Objectives.** Build the certification engine: a compliance-mapping component that links every probe to OWASP LLM Top-10 (2025), MITRE ATLAS and NIST AI RMF controls; a vulnerability severity-scoring model; a findings-triage dashboard; a signed, reproducible report generator; and an audit-evidence bundle suitable for accreditation review.

| WP | Work package | Key tasks | PM |
|---|---|---|---|
| **6.1** | **Compliance-mapping engine** | Rules linking each probe/finding to OWASP LLM01–10, ATLAS techniques, NIST AI RMF functions | 10 |
| **6.2** | **Severity-scoring model** | Calibrated severity model (impact × exploitability); documented rubric | 6 |
| **6.3** | **Certification dashboard** | Findings triage; coverage view; per-category status; export | 8 |
| **6.4** | **Signed report generator** | ReportLab / WeasyPrint pipeline; cryptographically signed PDF/HTML; templated sections | 8 |
| **6.5** | **Audit-evidence bundle & reproducibility** | Evidence packaging; run manifests; reproducible re-scoring | 6 |
| **6.6** | **Cross-mapping (ATLAS, NIST, ISO 42001)** | Framework cross-walk; traceability matrix; coverage assertions | 4 |

**Table 37.** M6 work packages and indicative effort. *Source:* Cyberultron programme plan; EOI §2.3(h). *Interpretation:* Mapping and reporting reuse Cyberultron's document-generation pipelines, reducing build risk on WP6.4.

**Technical approach & rationale.** Foreign tools' reporting is cloud-tied and oriented to commercial dashboards, **not defence accreditation**. The engine instead produces a sovereign, signed, reproducible certification mapped to three authoritative frameworks: the OWASP Top-10 for LLM Applications (2025), MITRE ATLAS (adversarial ML tactics/techniques), and the NIST AI RMF (incl. the Generative AI Profile 600-1). Each probe is rule-mapped to the controls it exercises, giving a defensible coverage assertion; severity uses a documented,

calibrated rubric to avoid subjectivity; and every report is signed and reproducible from its evidence bundle, satisfying audit and accreditation scrutiny. ISO/IEC 42001 cross-mapping aligns the output with AI-management-system expectations.

| ID | Deliverable | Type | Acceptance basis |
|---|---|---|---|
| **D6.1** | Compliance-mapping engine | Software | Every probe maps to ≥ 1 framework control |
| **D6.2** | Severity-scoring model + rubric | Software / doc | Calibrated, documented, reproducible scores |
| **D6.3** | Certification dashboard | Software | Full OWASP LLM01–10 coverage view |
| **D6.4** | Signed certification report generator | Software | Signed report reproducible from evidence |
| **D6.5** | Audit-evidence bundle | Software / data | Re-scoring reproduces the report |
| **D6.6** | Framework cross-mapping & traceability matrix | Document | ATLAS + NIST + ISO 42001 cross-walk present |

**Table 38.** M6 deliverables and acceptance basis. *Source:* Cyberultron programme plan. *Interpretation:* Signed, reproducible reporting (D6.4/D6.5) is the artifact an accreditation authority can rely upon.

| Gate exit criterion | Measure / threshold | Verification method |
|---|---|---|
| **Framework coverage** | Every probe mapped to ≥ 1 OWASP/ATLAS/NIST control | Mapping audit |
| **OWASP LLM Top-10 completeness** | All LLM01–LLM10 represented in report | Coverage review |
| **Report reproducibility** | Signed report regenerated byte-for-byte from evidence | Reproducibility test |
| **Cross-mapping present** | ATLAS + NIST AI RMF cross-walk complete | Traceability-matrix review |

**Table 39.** M6 gate (G6) exit criteria. *Source:* Cyberultron programme plan; EOI §2.4 (OWASP compliance, automated mapping). *Interpretation:* Reproducibility of a signed report is a hard criterion — the basis of accreditation trust.

| Risk | L / I | Mitigation |
|---|---|---|
| **Framework updates / drift** | L / M | Versioned mapping rules; periodic controlled-media framework refresh |
| **Severity-scoring subjectivity** | L / M | Documented rubric; calibration set; peer review of scores |
| **Report-completeness gaps** | L / L | Template-driven generation with automated completeness checks |

**Table 40.** M6 key risks and mitigations. *Source:* Cyberultron risk register (extract). *Interpretation:* Mapping risks are low and procedural; versioned rules keep the certification current against evolving standards.

## M 7 — Integration, Confidential Computing & Optimisation

**Unified suite, weights protected in use, full suite in under four hours on a 7B model**

TIMEFRAME **Months 19–21** | TRL **5 → 6**

**Objectives.** Integrate the six engines into a single orchestrated suite (per the run sequence, Figure 4); complete confidential-computing protection of target weights during testing; optimise performance to the EOI target of a **full security suite on a 7B model in under four hours**; deliver version 2 of the Indian-language taxonomy and corpus; and harden the system for resilient operation.

| WP | Work package | Key tasks | PM |
|---|---|---|---|
| **7.1** | **End-to-end integration** | Six engines into one pipeline; orchestrated run; unified evidence & reporting; regression suite | 12 |
| **7.2** | **Confidential computing completion** | GPU CC mode; hardware attestation; encrypted CVM↔GPU; Intel TDX / AMD SEV-SNP portability | 10 |
| **7.3** | **Performance optimisation** | Parallelised probes; batched agentic runs; GPU acceleration; profiling to < 4 h on 7B | 10 |
| **7.4** | **Indic taxonomy & corpus v2** | Expanded categories/languages; refinement from M3–M6 findings; re-validation | 8 |
| **7.5** | **System hardening & resilience** | Kill-switch & circuit-breakers under load; fault injection; recovery | 6 |
| **7.6** | **Operator documentation & runbooks** | Admin/operator guides; runbooks; configuration & data-governance docs | 4 |

**Table 41.** M7 work packages and indicative effort. *Source:* Cyberultron programme plan; EOI §2.3(i), §2.4 (scan duration). *Interpretation:* Integration, confidential computing and optimisation proceed together so the optimised suite runs on the attested, hardened platform.

**Technical approach & rationale.** Testing a model requires loading its weights — which for a sovereign or classified model must themselves be protected in use. The framework uses **confidential computing**: NVIDIA GPU CC mode with hardware attestation and an encrypted CPU-TEE↔GPU channel (published overhead under ~7%), with portability across Intel TDX and AMD SEV-SNP and CNCF Confidential Containers — so weights remain encrypted in memory throughout assessment (mitigating OWASP LLM03 exposure during testing). Performance is engineered to the EOI's operational metric (< 4 h full suite on a 7B model) through probe parallelisation, batched agentic campaigns and GPU acceleration, validated by profiling. Taxonomy v2 deepens the sovereign differentiator using lessons from M3–M6.

| ID | Deliverable | Type | Acceptance basis |
|---|---|---|---|
| **D7.1** | Integrated six-engine assessment suite | Software | End-to-end run produces unified signed report |
| **D7.2** | Confidential-computing-enabled node | Software / env. | Attestation verified; weights encrypted in use |
| **D7.3** | Performance optimisation + report | Software / doc | Full suite < 4 h on a 7B model, measured |
| **D7.4** | Indian-language taxonomy & corpus v2 | Data / IP | Expanded, re-validated coverage |
| **D7.5** | Hardened, resilient system | Software | Resilience & fault-injection tests pass |
| **D7.6** | Operator documentation & runbooks | Document | Complete admin/operator guidance |

**Table 42.** M7 deliverables and acceptance basis. *Source:* Cyberultron programme plan. *Interpretation:* The <4 h measured run (D7.3) and verified attestation (D7.2) are the milestone's defining, testable outcomes.

| Gate exit criterion | Measure / threshold | Verification method |
|---|---|---|
| **Full-suite scan duration (7B)** | < 4 hours, full suite, measured | Timed end-to-end benchmark run |
| **Confidential-computing attestation** | Attestation verified; weights encrypted in use | Attestation check + memory-protection test |
| **End-to-end integration** | Single run drives all six engines to one report | Integration regression suite |
| **Taxonomy v2 delivered** | Expanded categories/languages, re-validated | Validation record review |
| **Resilience** | Kill-switch & recovery hold under fault injection | Fault-injection test |

**Table 43.** M7 gate (G7) exit criteria. *Source:* Cyberultron programme plan; EOI §2.4 (scan duration, air-gapped security). *Interpretation:* The performance and attestation criteria are the hardest technical bars in the programme and are validated by measurement.

| Risk | L / I | Mitigation |
|---|---|---|
| **< 4 h target under full suite** | M / M | Parallelise probes; batch agentic runs; profile & optimise heaviest stages; tiered depth |
| **CC overhead / hardware compatibility** | M / M | Benchmark to ~7% overhead; portability across NVIDIA CC / Intel TDX / AMD SEV-SNP |
| **Integration regressions** | L / M | Staged integration; CI regression gates; feature flags |

**Table 44.** M7 key risks and mitigations. *Source:* Cyberultron risk register (extract). *Interpretation:* Both leading risks are performance-related and are addressed by parallelism, batching and profiling against a measured target.

## M 8 — Independent V&V;, Accreditation, Pilot & Handover

**Independent validation against every EOI metric, pilot in a relevant environment, and transfer**

TIMEFRAME **Months 22–24** | TRL **6 → 7**

**Objectives.** Conduct independent verification & validation (by a separate team) against every EOI figure of merit; build and integrate the defence accreditation-export adapter to End-User specification; run a pilot assessment on representative models with End-User participation; security-audit the framework itself; and complete documentation, training and knowledge transfer, culminating in final acceptance and TRL 7 (validated in a relevant / operational environment).

| WP | Work package | Key tasks | PM |
|---|---|---|---|
| **8.1** | **Independent V&V; (IV&V;)** | Separate team validates all FoM; traceability to EOI §2.4; defect resolution | 10 |
| **8.2** | **Accreditation-export adapter** | Map certification output into End-User accreditation workflow (to RFP/End-User spec) | 8 |
| **8.3** | **Pilot assessment** | Assess ≥ 1 indigenous + ≥ 1 procured model with End-User; capture operational feedback | 10 |
| **8.4** | **Framework security audit** | Penetration test & code audit of the framework itself; remediation | 6 |
| **8.5** | **Documentation, training & transfer** | Final docs; operator & maintainer training; knowledge transfer to End-User | 6 |
| **8.6** | **Final certification & closure** | Final report; acceptance; programme closure & lessons learned | 4 |

**Table 45.** M8 work packages and indicative effort. *Source:* Cyberultron programme plan; EOI §2.3(h), §2.4. *Interpretation:* Verification capacity peaks here, and the work is performed independently of the build team to ensure objectivity.

**Technical approach & rationale.** Credibility for a government audience requires **independent** validation, not self-assessment: a separate IV&V; team validates the system against each EOI §2.4 figure of merit with full traceability, consistent with NIST AI RMF Measure/Manage. The pilot assessment exercises the framework on representative indigenous and procured models with End-User participation, advancing the system to TRL 7

(validated in a relevant/operational environment). The accreditation-export adapter is built to the End-User's specification so the certification slots directly into the defence accreditation workflow. The framework is itself penetration-tested and code-audited (the assessor must be at least as secure as what it assesses). Engagement from M1 through the DRDO liaison ensures the accreditation specification and pilot models are available on time.

| ID | Deliverable | Type | Acceptance basis |
|---|---|---|---|
| **D8.1** | Independent V&V; report (all FoM) | Document | IV&V; confirms every EOI §2.4 metric met |
| **D8.2** | Accreditation-export adapter | Software | Integrated & accepted by End-User |
| **D8.3** | Pilot assessment report | Document | ≥ 1 indigenous + ≥ 1 procured model assessed |
| **D8.4** | Framework security-audit report | Document | Framework passes pen-test & code audit |
| **D8.5** | Documentation, training & knowledge transfer | Document / service | Operators & maintainers trained; docs complete |
| **D8.6** | Final certification report & closure | Document | Final acceptance; programme closed |

**Table 46.** M8 deliverables and acceptance basis. *Source:* Cyberultron programme plan. *Interpretation:* Independent V&V; (D8.1) and the pilot (D8.3) are the evidence that the system works in a relevant environment, not only on the bench.

| Gate exit criterion | Measure / threshold | Verification method |
|---|---|---|
| **Independent V&V; passed** | All EOI §2.4 FoM independently confirmed | IV&V; report sign-off |
| **Pilot assessment completed** | ≥ 1 indigenous + ≥ 1 procured model | Pilot report + End-User acceptance |
| **Accreditation integration** | Adapter integrated & accepted by End-User | Integration acceptance test |
| **Framework self-security** | Framework passes its own pen-test & audit | Security-audit report |
| **Handover & training** | Operators/maintainers trained; docs delivered | Training completion & doc review |

**Table 47.** M8 gate (G8) exit criteria — final acceptance. *Source:* Cyberultron programme plan; EOI §2.4 (all parameters). *Interpretation:* G8 is the programme's terminal acceptance: independent confirmation of every metric plus a successful pilot and clean self-audit.

| Risk | L / I | Mitigation |
|---|---|---|
| **IV&V; uncovers residual gaps** | M / M | Continuous self-test through M1–M7; schedule contingency in M8 for remediation |
| **Pilot-model availability** | M / M | Early End-User coordination via liaison; reference models as fallback |
| **Late accreditation specification** | M / H | Engage End-User from M1; adapter designed to a stable interface contract |

**Table 48.** M8 key risks and mitigations. *Source:* Cyberultron risk register (extract). *Interpretation:* The principal risk is external (timely accreditation spec and pilot models), mitigated by early and sustained End-User engagement.

### 5.7 Consolidated deliverables register

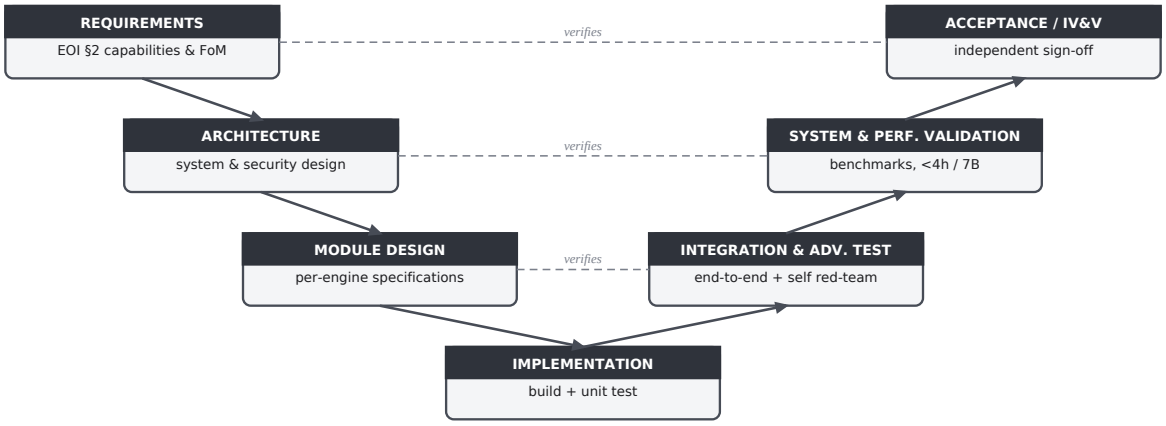
The register consolidates the milestone deliverables (§5.6) against their gate and Technology Readiness Level. It is the single traceable list against which acceptance is managed.

| M | Gate | Key deliverables (see §5.6 for IDs & acceptance) | Acceptance basis | TRL |
|---|---|---|---|---|
| **M1** | G1 | Air-gapped enclave, serving substrate, orchestrator+OPA, ingestion/provenance, sandbox, security baseline & CI/CD | Egress-deny, in-enclave serving, policy & reproducible-build tests | 4 |
| **M2** | G2 | Bytecode analyzer, multi-format scanner, fuzzer, detonation sandbox, signature DB/SBOM, scan-before-load gate | ≥90% detection on corpus; detonation isolation | 5 |
| **M3** | G3 | Injection fuzzer (10k+), 50+ jailbreak library, benchmark harness, Indic taxonomy v1, scoring, coverage report | ≥95% known / ≥70% zero-shot; ≥5 validated languages | 5 |
| **M4** | G4 | GCG/I-GCG, AutoDAN, agentic orchestrator, PAIR/TAP/Crescendo, multi-turn Indic, access-model routing | White-box & black-box pathways demonstrated | 5 |
| **M5** | G5 | LiRA/RMIA MIA harness, PII-extraction, API security tester, embedding analysis, sleeper/poisoning, privacy report | ≥80% MIA on canaries; seeded API flaws & backdoor detected | 5 |
| **M6** | G6 | Mapping engine, severity model, dashboard, signed report generator, evidence bundle, cross-mapping matrix | Full OWASP LLM01–10; signed report reproducible | 6 |
| **M7** | G7 | Integrated suite, confidential computing, performance optimisation, Indic taxonomy v2, hardening, runbooks | <4 h/7B measured; attestation verified | 6 |
| **M8** | G8 | IV&V; report, accreditation adapter, pilot report, framework security audit, documentation/training, final certification | Independent FoM sign-off; pilot + clean self-audit | 7 |

**Table 49.** Consolidated deliverables register with gates and TRL progression. *Source:* Cyberultron programme plan (§5.6). *Interpretation:* Forty-eight numbered deliverables roll up to eight gated acceptance points; TRL rises monotonically from 4 to 7.

### 5.8 Verification, validation and acceptance

Verification (“built right”) and validation (“right thing, against the EOI”) follow a V-model with full requirements-to-acceptance traceability (Figure 23). Continuous adversarial self-testing runs at every level; final validation at M8 is performed by an independent team against each figure of merit.




*Continuous adversarial self-testing runs at every level (the system red-teams itself); independent V&V (M8) is performed by a separate team against the EOI figures of merit before acceptance.*

*Figure 23. Verification & Validation (V-model). Left arm: requirements traced down to implementation; right arm: test levels traced up to independent acceptance. Horizontal links bind each design tier to its validation tier, giving full requirements-to-acceptance traceability.*

| Validation item (EOI §2.4) | Validation method | Acceptance threshold | MS |
|---|---|---|---|
| **Prompt-injection coverage** | Benchmark vs known + held-out novel corpora | ≥95% known; ≥70% zero-shot | M3 |
| **Jailbreak coverage** | Library audit + execution | ≥50 methodologies | M3/M4 |
| **Membership-inference accuracy** | LiRA/RMIA on standard canaries | ≥80% on canaries | M5 |
| **Model-artifact malware detection** | Labelled malicious-model corpus | ≥90% detection | M2 |
| **Multilingual attack support** | Native-validated Indic attack runs | ≥5 Indian languages | M3/M7 |
| **Scan duration (7B model)** | Timed end-to-end benchmark | <4 hours, full suite | M7 |
| **Air-gapped security** | Egress test + signed-audit review | Zero exfiltration | M1/M8 |
| **OWASP LLM Top-10 compliance** | Mapping & coverage audit | Full LLM01–LLM10 | M6 |

**Table 50.** Validation matrix — EOI figures of merit mapped to method, threshold and milestone. *Source:* EOI §2.4; Cyberultron V&V; plan. *Interpretation:* Every EOI performance parameter has a defined, independently-checkable validation method and milestone, ensuring complete traceability at acceptance.

### 5.9 Risk management

Risks are tracked in a live register with owner, likelihood, impact and mitigation, and reviewed at every gate. Figure 24 shows residual positions after planned mitigations; the register below is the authoritative source.




*Figure 24. Programme risk matrix (5×5, impact × likelihood). Residual risk positions after planned mitigations (see Table for the risk register). Research-forward items (R2 embedding analysis, R6 Indic-corpus maturity) carry the highest residual exposure and are actively de-risked through academic collaboration and milestone gating.*

| ID | Risk | L / I | Mitigation | Owner |
|---|---|---|---|---|
| **R1** | GPU / confidential-computing hardware lead time | Possible / Major | Early procurement; interim/Indian-cloud compute for dev; CC off the M1 critical path | Platform |
| **R2** | Embedding/representation analysis maturity (research-forward) | Unlikely / Severe | Academic collaboration; TRL-honest scope; fallback heuristics; gated delivery | Privacy / Academic |
| **R3** | Novel obfuscation evades static scanning | Possible / Moderate | Defence in depth: structure-aware fuzzing + sandbox detonation | Platform / Attacks |
| **R4** | <4 h performance under the full suite | Likely / Major | Probe parallelisation; batched agentic runs; profiling; tiered scan depth | Platform |
| **R5** | Inference-API test false positives | Unlikely / Moderate | Validated findings only; reproducible proof-of-concept per finding | Privacy |
| **R6** | Indian-language corpus maturity & validation effort | Possible / Severe | Academic linguistics partner; native-speaker validation; staged language rollout | Attacks / Academic |
| **R7** | Severity-scoring subjectivity | Likely / Minor | Documented rubric; calibration set; peer review of scores | Certification |
| **R8** | Late accreditation specification from End-User | Unlikely / Major | Engage End-User from M1 via liaison; design to a stable interface contract | PD / DRDO |
| **R9** | Key-person dependency | Rare / Major | Cross-training; documentation; PMO continuity planning | PD / PMO |
| **R10** | Standards / framework drift | Possible / Minor | Versioned mapping rules; periodic controlled-media refresh | Certification |

**Table 51.** Programme risk register (top 10) with likelihood, impact, mitigation and owner. *Source:* Cyberultron risk management plan. *Interpretation:* The two highest-impact risks (R2 embedding analysis, R6 Indic corpus) are research items mitigated by academic partnership; the most likely (R4 performance) is mitigated by engineering measures and validated at G7.

### 5.10 Standards and compliance mapping

The programme and its output align to the authoritative AI-security and information-security standards relevant to a defence audience. The mapping below states, for each, the scope and how it is addressed.

| Standard / framework | Scope | How addressed in this programme | MS |
|---|---|---|---|
| **OWASP Top-10 for LLM Apps (2025)** | LLM application risk taxonomy | Every probe mapped to LLM01–LLM10; full coverage asserted in the certification report | M6 |
| **MITRE ATLAS** | Adversarial ML tactics & techniques | Findings cross-mapped to ATLAS techniques for threat-informed reporting | M6 |
| **NIST AI RMF (incl. GenAI Profile 600-1)** | AI risk Govern/Map/Measure/Manage | Lifecycle governance and V&V; structured to the four functions; report cross-mapped | M6/M8 |
| **ISO/IEC 27001** | Information-security management | Defence-in-depth controls (Figure 20); enclave operated to ISMS controls | M1–M8 |
| **ISO/IEC 42001** | AI management system | Stage-gated lifecycle and documentation aligned to AIMS expectations | M1–M8 |
| **DPDP Act 2023 / data governance** | Personal-data protection | Enclave-only data; privacy testing scoped to canaries; access-controlled corpora | M5 |
| **CERT-In posture** | Incident/audit readiness | Signed, tamper-evident audit trail; reproducible evidence bundles | M1/M6 |
| **EOI Undertaking 15 (sovereignty)** | In-perimeter data & IP | Zero egress; ≈100% indigenous content; net-new sovereign IP (taxonomy, signature DB) | All |

**Table 52.** Standards and compliance mapping. *Source:* OWASP (2025); MITRE ATLAS; NIST AI RMF 100-1 / 600-1; ISO/IEC 27001 & 42001; DPDP Act 2023; CERT-In; EOI Undertaking 15. *Interpretation:* Compliance is designed in from M1, not retrofitted, and is evidenced in the signed certification output at M6 and the independent validation at M8.

### 5.11 Effort and value analysis

Consistent with EOI requirements, this analysis contains **no commercial or cost information**. "Investment" is expressed only as development effort in person-months; "value" and "risk-if-not-delivered" are stated qualitatively from a national-capability standpoint. The pattern shows effort concentrated where sovereign value and risk-reduction are highest.

| Capability / workstream | Effort (PM) | Strategic value (qualitative) | Risk if not delivered |
|---|---|---|---|
| **Secure air-gapped platform (M1)** | ≈56 | Sovereign operating base; precondition for testing classified models | No trustworthy environment exists; foreign tools remain the only option |
| **Static artifact security (M2)** | ≈48 | Blocks supply-chain / backdoor compromise before load | Malicious models load undetected (OWASP LLM03/04) |
| **Attack generation + Indic v1 (M3)** | ≈52 | Core offensive coverage + sovereign Indic differentiator | English-only testing misses ~3× Indic attack surface |
| **Gradient + agentic (M4)** | ≈54 | State-of-the-art coverage for indigenous & procured models | Sophisticated jailbreaks remain undetected |
| **Privacy / API / embedding (M5)** | ≈42 | Leakage, API and backdoor assurance | Data-leakage and sleeper-agent risks unquantified |
| **Certification & reporting (M6)** | ≈42 | Accreditation-grade, signed, reproducible evidence | Findings not actionable for accreditation |
| **Integration, CC, optimisation (M7)** | ≈50 | Operational viability (<4 h) + weights protected in use | Tool too slow / exposes weights during testing |
| **IV&V;, accreditation, pilot (M8)** | ≈44 | Independent credibility; validated in a relevant environment | Unvalidated tool cannot be trusted for national security |

**Table 53.** Effort-and-value analysis (effort in person-months; no monetary information). *Source:* Cyberultron programme plan; EOI §2.4 and national-capability context (§4.i). *Interpretation:* Effort tracks sovereign value and risk-reduction; the platform, attack and integration workstreams carry both the highest effort and the highest strategic consequence.

### 5.12 Schedule assumptions, dependencies and critical path

The eight milestones form a single critical chain with zero schedule float to the 24-month ceiling; two parallel workstreams feed multiple milestones and complete ahead of the gates they support (Figure 25). The schedule rests on a small set of explicit assumptions, each with an owner and a fallback.

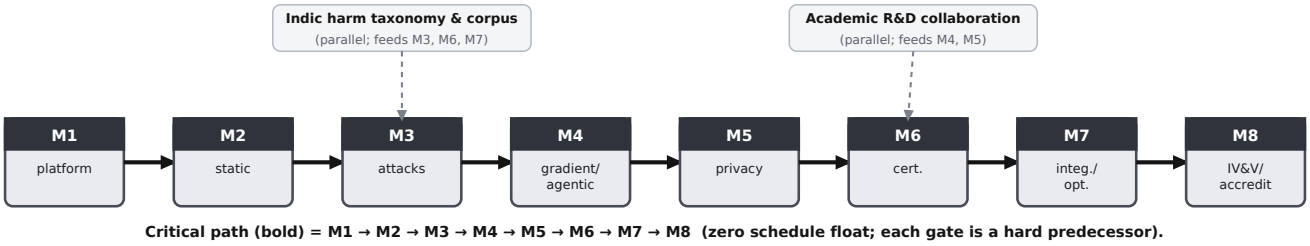



*Figure 25. Milestone dependency network and critical path. The eight milestones form a single critical chain with zero float to the 24-month ceiling; two parallel workstreams (Indic taxonomy, academic R&D) feed multiple milestones and are scheduled to complete ahead of the gates they support.*

| Assumption / dependency | Impact if invalid | Owner / fallback |
|---|---|---|
| **GPU & confidential-computing hardware available by M1** | M1 platform & M7 CC slip | Platform / interim Indian-cloud or leased GPU; CC deferred within M7 |
| **End-User (DRDO) liaison engaged from M1** | Accreditation spec & pilot models late (R8) | PD / stable interface contract; reference models as fallback |
| **Academic R&D; MoU executed early** | R2/R6 research items slow | PD / in-house fallback heuristics; staged corpus |
| **Pilot models (indigenous + procured) by M8** | Pilot scope reduced | DRDO liaison / open-weight reference models for pilot |
| **Controlled-media transfer cadence agreed** | Framework/signature refresh delayed | Security / scheduled offline refresh windows |
| **Core team availability across 24 months** | Critical-path delay (R9) | PMO / cross-training & documented continuity |

**Table 54.** Schedule assumptions, dependencies and fallbacks. *Source:* Cyberultron programme plan; risk register (§5.9). *Interpretation:* Because the critical path has zero float, each assumption is paired with a concrete fallback so that a single dependency cannot breach the 24-month ceiling.

### 5.13 Data governance and Indian-language corpus management

All data handled by the programme — model weights, attack corpora, the Indian-language harm corpus, findings and audit logs — is governed under a strict, enclave-only regime aligned to the DPDP Act 2023 and ISO/IEC 27001. No data class leaves the secure perimeter; access is least-privilege and audit-logged. The assessment lifecycle of a model is governed as a state machine in which scanning must clear before any weight is loaded (Figure 26).

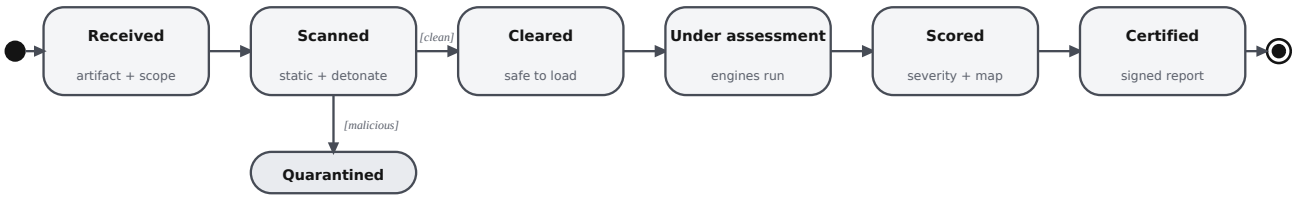



*Figure 26. UML state machine for an assessed model. The artifact transitions Received → Scanned → Cleared → Under assessment → Scored → Certified (→ archived/closed); a [malicious] verdict diverts it to Quarantined with no load. The [clean] guard makes scan-before-load a state invariant of the system.*

| Data class | Examples | Handling & controls | Access / retention |
|---|---|---|---|
| **Target model artifacts** | Weights, configs, tokenizer, checkpoints | Signed, fingerprinted, vaulted; encrypted in use (TEE); never copied out | Need-to-know; purged on End-User instruction |
| **Attack corpora** | Injection / jailbreak prompts, suffixes | Enclave-only; defensive-use-only policy; versioned | Engineering team; retained for regression |
| **Indic harm corpus** | Native-language harm prompts & taxonomy | Highest sensitivity; access-controlled; validation records kept | Restricted; retained as sovereign IP in-enclave |
| **Findings & evidence** | Vulnerabilities, transcripts, scores | Tamper-evident store; signed; reproducible | Auditor & End-User; retained for accreditation |
| **Audit logs** | Access, runs, transfers | Append-only, signed; controlled-media export only | Audit role; long-term retention |

**Table 55.** Data governance regime by data class. *Source:* Cyberultron data governance plan; DPDP Act 2023; ISO/IEC 27001. *Interpretation:* Sensitivity rises from attack corpora to the Indic harm corpus and target weights; controls scale accordingly, and nothing is exfiltrable by design.

The Indian-language harm corpus — the framework's principal sovereign asset — is built through a defined, auditable lifecycle with academic computational-linguistics support and native-speaker validation, delivered in two versions (v1 at G3, v2 at G7).

| Stage | Activity | Validation | MS |
|---|---|---|---|
| **Taxonomy design** | Define defence harm categories (violence, weapons, cyber-attack planning, regional harms) | Domain review with End-User input | M3 |
| **Corpus construction** | Curate native-language prompts across ≥5 languages; code-switching variants | Linguist review; de-duplication | M3 |
| **Native-speaker validation** | Independent native speakers verify intent, fluency and category fit | Inter-rater agreement record | M3 |
| **Versioning & refinement** | Refine from M3–M6 findings; expand categories/languages; re-validate (v2) | v2 validation record | M7 |
| **Governance** | Access control, defensive-use-only, enclave-only retention as sovereign IP | Access-log audit | All |

**Table 56.** Indian-language harm-corpus build lifecycle. *Source:* Cyberultron corpus management plan. *Interpretation:* The corpus is produced under a research-grade, validated, auditable process — the basis of its credibility and its status as net-new sovereign IP.

### 5.14 Benchmarking methodology and baseline comparison

Every figure of merit is measured against recognised, reproducible benchmarks rather than asserted. Standard suites (AdvBench, HarmBench, XSTest) and methods (LiRA, RMIA) are complemented by curated malicious-model and injection corpora. The table contrasts the framework's committed target with the qualitative capability of the

foreign baseline tools on the same axis.

| Metric | Benchmark / method | Foreign-tool baseline (qualitative) | Framework target | Measurement |
|---|---|---|---|---|
| **Injection coverage** | Known + held-out injection corpus | Partial; no Indic; cloud-tied | ≥95% / ≥70% 0-shot | Corpus pass-rate |
| **Jailbreak coverage** | OWASP LLM / security suites | Varies across existing suites | ≥50 methods | Library audit |
| **Membership inference** | LiRA / RMIA on canaries | Rare in commercial tools | ≥80% canaries | TPR @ low-FPR |
| **Artifact malware detection** | Curated malicious-model corpus | Signature-only; CVE-prone (2025) | ≥90% detection | Labelled-corpus rate |
| **Multilingual support** | Native-validated Indic attack runs | Absent in all foreign tools | ≥5 languages | Validated attack set |
| **Scan duration (7B)** | Timed full-suite run | Not air-gapped; not comparable | < 4 hours | Wall-clock benchmark |
| **Air-gapped operation** | Egress + audit review | None offer air-gap (2026) | Zero exfiltration | Egress test |
| **Certification output** | Mapping coverage audit | Cloud dashboards; not accreditation | OWASP/ATLAS/NIST | Coverage audit |

**Table 57.** Benchmarking matrix — metric, method, foreign baseline, framework target and measurement. *Source:* EOI §2.4; AdvBench / HarmBench / XSTest; LiRA / RMIA; 2026 vendor analyses. *Interpretation:* On every axis the framework either meets a quantified target on a recognised benchmark or occupies space the foreign baseline cannot (air-gap, Indic) — a defensible comparison under technical scrutiny.

### 5.15 Quality, configuration and change management

Engineering discipline follows recognised quality, configuration and change-control practice, embedded in the stage-gated lifecycle and the continuous-integration pipeline so that quality is built in and every artifact is versioned, reproducible and traceable.

| Practice | Mechanism | Cadence / gate |
|---|---|---|
| **Code quality** | Mandatory peer review; static analysis; style & security linting in CI | Every merge |
| **Test coverage** | Unit + integration + adversarial self-test; coverage thresholds enforced in CI | Every build; gate |
| **Configuration management** | Versioned source (Git) + data/model versioning (DVC); reproducible, signed builds | Continuous; baseline per gate |
| **Baselines** | Frozen, signed configuration baseline captured at each milestone gate | G1–G8 |
| **Change control** | Change-control board for scope/interface changes; impact assessment; End-User notice | On change |
| **Defect management** | Tracked defects with severity; closure verification; regression added to suite | Continuous |
| **Documentation control** | Versioned documents; review & approval; controlled distribution | Per deliverable |

**Table 58.** Quality, configuration and change-management practices. *Source:* Cyberultron quality plan; ISO/IEC 27001 & 42001; ISO 9001-style discipline. *Interpretation:* Each practice is tied to a cadence or gate, making quality auditable rather than aspirational, and ensuring every gate baseline is reproducible.

### 5.16 Scalability and performance engineering

The framework is engineered to meet the EOI's operational target (a full suite on a 7B model in under four hours) and to scale predictably to larger models and higher throughput. Scaling is achieved by adding worker nodes and parallelising independent probes rather than by re-architecture; the design degrades gracefully (longer but bounded runtimes) on larger models and replicates per security domain.

| Dimension | Mechanism | Effect / evidence |
|---|---|---|
| **Throughput** | High-throughput serving (vLLM continuous batching); batched agentic campaigns | More probes/hour on fixed hardware |
| **Horizontal scale** | Add GPU worker nodes to the orchestrated cluster; queue-based scheduling | Near-linear added capacity for parallel probes |
| **Parallelism** | Independent probes & engines run concurrently; only gated stages serialise | Wall-clock reduction toward < 4 h target |
| **Larger models** | Tiered scan depth; tensor/pipeline-parallel serving for >7B | Bounded, predictable runtime growth |
| **Multi-domain** | Replicate the self-contained node per security domain | Independent capacity without shared state |
| **Efficiency** | Confidential computing with published overhead under ~7% | Security with minimal performance cost |

**Table 59.** Scalability and performance engineering levers. *Source:* Cyberultron performance plan; vLLM throughput literature; NVIDIA Confidential Computing overhead data. *Interpretation:* Scaling is additive (more nodes, more parallelism), so the validated < 4 h/7B result extends to larger workloads with predictable, bounded cost.

### 5.17 Knowledge transfer, training and sustainment

The programme delivers not only the system but the capability to operate and sustain it independently within the secure perimeter, with no external dependency. Training, documentation and a sovereign sustainment model are delivered in M8.

| Item | Audience | Deliverable | MS |
|---|---|---|---|
| **Operator training** | End-User operators | Hands-on training; operator guide & runbooks | M8 |
| **Maintainer training** | End-User technical staff | Architecture, build & extension training; maintainer manual | M8 |
| **Documentation set** | All | Admin, operator, design, V&V; and accreditation documents | M7–M8 |
| **Sustainment model** | End-User | Offline refresh procedure (signatures, frameworks, corpus) via controlled media | M8 |
| **Knowledge transfer** | End-User | Source, build pipeline and reproducibility handover within perimeter | M8 |

**Table 60.** Knowledge transfer, training and sustainment deliverables. *Source:* Cyberultron transition plan. *Interpretation:* Sustainment is fully sovereign — the End-User can refresh and operate the system offline indefinitely, consistent with the air-gapped, zero-dependency design.

### 5.18 Detailed activity schedule (month-by-month)

To make the break-up requested in Item 5(i) fully explicit, the table below decomposes the 24-month programme to the month, mapped to its milestone, with principal activities and the key output expected in that month. Gate months are marked.

| Mo. | MS | Principal activities | Key monthly output |
|---|---|---|---|
| **1** | M1 | Mobilise team; enclave network design; GPU procurement / allocation; security baseline drafting | Design baseline; procurement initiated |
| **2** | M1 | Build air-gapped segment & segmentation; stand up serving substrate; orchestrator skeleton | Zero-egress segment; reference model served |
| **3** | M1 | Ingestion + provenance; sandbox; CI/CD + in-enclave mirror; baseline review — Gate G1 | G1: sovereign platform operational |
| **4** | M2 | Pickle/bytecode analyzer; deserialization-graph reconstruction | Analyzer alpha |
| **5** | M2 | Multi-format readers + safe-format steering; structure-aware fuzzer; detonation harness | Detonation sandbox working |
| **6** | M2 | Signature DB + SBOM; integrate; scan-before-load gate — Gate G2 | G2: scanner ≥ 90% on corpus |
| **7** | M3 | Injection fuzzing engine (10k+ corpus); jailbreak library (50+); benchmark harness | Attack engine alpha |
| **8** | M3 | Indic taxonomy v1; corpus construction across ≥ 5 languages | Indic corpus draft |
| **9** | M3 | Native-speaker validation; scoring; coverage measurement — Gate G3 | G3: coverage + Indic corpus v1 |
| **10** | M4 | GCG / I-GCG gradient module; transfer testing | Gradient attack working |
| **11** | M4 | AutoDAN genetic attack; agentic orchestrator with in-enclave attacker model | Agentic loop alpha |
| **12** | M4 | PAIR / TAP / Crescendo; multi-turn Indic; access-model routing — Gate G4 | G4: gradient + agentic engine |
| **13** | M5 | LiRA shadow-model harness; RMIA reference-population MIA | MIA harness alpha |
| **14** | M5 | Data / PII extraction tests; inference-API security tester | API security tester working |
| **15** | M5 | Embedding / representation & sleeper-agent analysis; integrate — Gate G5 | G5: privacy / API / embedding suite |
| **16** | M6 | Compliance-mapping engine (OWASP/ATLAS/NIST); severity-scoring model | Mapping engine alpha |
| **17** | M6 | Certification dashboard; signed report generator | Signed certification report |
| **18** | M6 | Audit-evidence bundle; cross-mapping & traceability — Gate G6 | G6: certification engine complete |
| **19** | M7 | End-to-end integration of six engines; regression suite | Integrated assessment suite |
| **20** | M7 | Confidential computing; hardware attestation; TEE portability | CC attestation verified |
| **21** | M7 | Performance optimisation (< 4 h/7B); Indic taxonomy v2; hardening — Gate G7 | G7: < 4 h suite + protected weights |
| **22** | M8 | Independent V&V; begins (separate team); framework penetration test | IV&V; in progress |
| **23** | M8 | Accreditation-export adapter; pilot assessment (indigenous + procured) | Pilot assessment results |
| **24** | M8 | Remediation; documentation & training; final certification — Gate G8 | G8: final acceptance & handover |

**Table 61.** Detailed month-by-month activity schedule with gate months. *Source:* Cyberultron programme plan (§5.6, Figure 16). *Interpretation:* Each of the 24 months has a defined activity set and a tangible output; the eight gate months (3, 6, 9, 12, 15, 18, 21, 24) are the binding acceptance points, confirming the plan fits the 24-month ceiling exactly.

### 5.19 Assumptions, constraints and exclusions

For completeness and to eliminate ambiguity in evaluation, the programme's principal assumptions, constraints and explicit exclusions are stated below; schedule-level dependencies are detailed in §5.12.

| Type | Statement |
|---|---|
| **Assumption** | GPU and confidential-computing hardware are available at M1; the DRDO End-User liaison and accreditation specification are engaged from M1; the academic R&D; MoU is executed early; pilot models are available by M8. |
| **Constraint** | Hard 24-month ceiling; fully air-gapped operation with zero external dependency or telemetry; ≈100% indigenous content; no commercial / cost information in this response (per EOI); all data remains within the Indian perimeter (Undertaking 15). |
| **Exclusion** | Commercial productisation, pricing and sales packaging are out of scope of this technical response; assessment of non-LLM model classes is out of scope unless specified by the End-User at RFP; hardware procurement and the accreditation decision itself rest with the End-User; the framework does not modify or remediate the model under test (it assesses and certifies). |
| **Dependency** | Timely End-User inputs (accreditation interface, pilot models) and controlled-media transfer windows; each has a defined fallback in §5.12 so the critical path is protected. |

**Table 62.** Assumptions, constraints and exclusions. *Source:* Cyberultron programme plan; EOI terms and Undertaking 15. *Interpretation:* Stating scope boundaries explicitly removes ambiguity for the evaluation committee and bounds the 24-month commitment precisely.

### 5.20 Suo-moto design and development of a similar product / technology [Item 5(ii)]

**ANSWER: NO.**

Cyberultron Consulting Private Limited has **not** carried out suo-moto (self-initiated) design and development of a product or technology equivalent to the proposed framework, and — as established by the competitive analysis in §4.i — **no indigenous, air-gapped, defence-grade equivalent exists anywhere in India**; the global market is foreign-controlled, cloud-oriented and offers no air-gapped deployment. The framework is therefore to be purpose-built under the TDF Scheme. However, Cyberultron possesses substantial, directly relevant **foundational capabilities** that materially de-risk and accelerate delivery, summarised below.

These foundational capabilities are pre-existing and self-funded; they are reused as starting points (chiefly to shorten M1 and de-risk the platform and reporting layers) but do not by themselves constitute the proposed framework, which is net-new.

| Pre-existing foundational capability | Relevance to the proposed framework | De-risking effect |
|---|---|---|
| **AI-security capabilities — runtime guardrails** | Production experience with LLM threat surfaces (injection, jailbreak, policy) | Informs attack engines (M3/M4) and policy plane (M1) |
| **Multi-model security gateway** | Multi-model serving, routing, per-tenant isolation, kill-switch/circuit-breaker patterns | Directly reused in orchestration & isolation (M1/M7) |
| **Python-native, self-hostable stack** | vLLM, LiteLLM, OPA/Rego, FastAPI, PostgreSQL, Redis, Prometheus/Grafana in production | Lowers platform & integration risk (M1, M6, M7) |
| **Air-gapped, on-premise deployment experience** | Delivery into restricted Indian-compliance environments | Validates the zero-egress operating model (M1) |
| **Compliance & GRC depth** | ISO/IEC 27001 & 42001, NIST AI RMF, DPDP, RBI/SEBI/CERT-In practice | Underpins certification mapping & governance (M6, §5.10) |
| **Document-generation pipelines** | Signed, reproducible PDF/HTML reporting at scale | Reused for the certification report generator (M6) |

**Table 63.** Pre-existing foundational capabilities relevant to delivery (Item 5(ii) details). *Source:* Cyberultron capability baseline. *Interpretation:* No equivalent product has been suo-moto developed; however, mature adjacent capabilities reduce platform, integration and reporting risk and shorten the critical path — strengthening confidence in the 24-month estimate.

### 5.21 Proof-of-Concept Plan [Type-I source code and Type-II binary / malware]

The framework's capability is demonstrated through the two proof-of-concept (PoC) classes contemplated by the EOI — Type-I (source-code) and Type-II (binary / malware) demonstrations. Each PoC has defined inputs, the engines it exercises, a reproducible demonstration procedure and the evidence it produces; all PoCs run inside

the air-gapped sandbox and feed the test catalogue (Annexure J). The agentic analysis and PoC-chaining method is set out in §4.v.5 and the reverse-engineering method in §4.v.8.

| Proof-of-concept | Class | Input | Method / engines | Demonstrated outcome |
|---|---|---|---|---|
| **PoC-1 Source-code vulnerability detection** | Type-I | Labelled vulnerable source (SARD / Juliet / CVE) | Static + LLM-assisted detectors; RAG correlation | Detected vulnerabilities with CWE and measured precision / recall |
| **PoC-2 LLM red-team campaign** | Type-I (model) | Open-weight target LLM | Injection / jailbreak / gradient / agentic engines | Successful attack campaigns; attack-success rate; findings report |
| **PoC-3 Malware / binary analysis** | Type-II | Malicious / suspicious binary | Static RE (reverse-engineering tooling) + sandbox detonation | Verdict, indicators of compromise and behaviour report |
| **PoC-4 Malicious serialised-model artefact** | Type-II | Crafted unsafe pickle / artefact | Static artefact scanner + sandbox | Detection of unsafe deserialisation / embedded payload |
| **PoC-5 Agentic PoC-chain** | Type-I / II | Code or binary target | Agentic vulnerability analysis + PoC chaining | Validated proof-of-concept chain with correlated evidence |

**Table 64.** Proof-of-concept execution plan (Type-I source code and Type-II binary / malware). *Source:* Cyberultron PoC plan; EOI demonstration classes; Annexure J. *Interpretation:* Five reproducible PoCs span both mandated classes — Type-I source-code and LLM red-team demonstrations and Type-II binary, malware and malicious-artefact demonstrations — each producing logged, repeatable evidence at the relevant gate (chiefly M2–M6).

Each PoC is executed only within the isolated sandbox, is fully reproducible from versioned inputs and scripts, and produces signed, access-logged evidence retained in the enclave. The PoCs are sequenced against the milestone plan (§5.6) so that capability is demonstrated incrementally and de-risks the integrated demonstration at M7.

### 5.22 Testing and Qualification Plan

Testing and qualification establish that the framework meets its functional, security and performance requirements and is ready for qualification. The plan combines benchmark-based evaluation, independent analyst validation and a staged qualification-readiness review, building on the verification and validation approach (§5.8), the benchmarking methodology (§5.14), the indicative acceptance test plan (Annexure AA) and the indicative test catalogue (Annexure J).

| Test type | Scope / method | Basis / datasets | Pass criterion | Stage |
|---|---|---|---|---|
| **Functional testing** | Module and integration tests across the six engines | Unit / integration suites | All planned functions operational | M1–M7 |
| **Detection-quality benchmarking** | Precision / recall / F1 on labelled sets | OWASP Benchmark, SARD, Juliet, CVE patch (§4.v.7) | Meet target precision / recall | M5–M6 |
| **Red-team efficacy** | Attack-success rate and technique coverage | OWASP LLM Top-10; MITRE ATLAS | Coverage of mapped techniques | M3–M4 |
| **Performance & scalability** | Throughput and latency under load | Load profiles (§5.16) | Meet performance targets | M7 |
| **Analyst validation** | Expert review of findings; false-positive control | Sampled findings | Validated, reproducible findings | M5–M7 |
| **Qualification readiness** | Execution of the acceptance test plan | Annexure AA (17 ATP tests) | All ATP tests pass at their gates | M8 |
| **Independent V&V;** | Separate-team verification and validation | §5.8 validation matrix | Independent sign-off | M8 |

**Table 65.** Testing and qualification plan. *Source:* Cyberultron test & qualification plan; §5.8, §5.14; Annexures AA, J. *Interpretation:* Testing spans functional, detection-quality, red-team, performance and analyst-validation dimensions and culminates in a formal qualification-readiness review against the acceptance test plan and independent V&V; — covering benchmarks, analyst validation and qualification readiness as required.

Qualification readiness is evidenced by the acceptance test plan (Annexure AA), the verification and validation matrix (§5.8) and the standards and compliance mapping (§5.10, Annexure E); together these convert testing outcomes into an auditable qualification decision at M8.

# 6 ACADEMIC PARTNERS AND R&D; SUPPORT REQUIRED

This section responds to EOI Item 6: the academic / R&D; institutions whose support the proposed solution would benefit from, and the specific technologies where such support is needed. The need is concentrated in the research-forward components identified in §4.ii and resourced in §5.3 — chiefly the Indian-language harm taxonomy, embedding / representation analysis, membership-inference theory and advanced attack methods. The remainder of the system is engineering-led and within the industry's existing capability. The collaboration model and its data/IP boundary are shown in Figure 30.

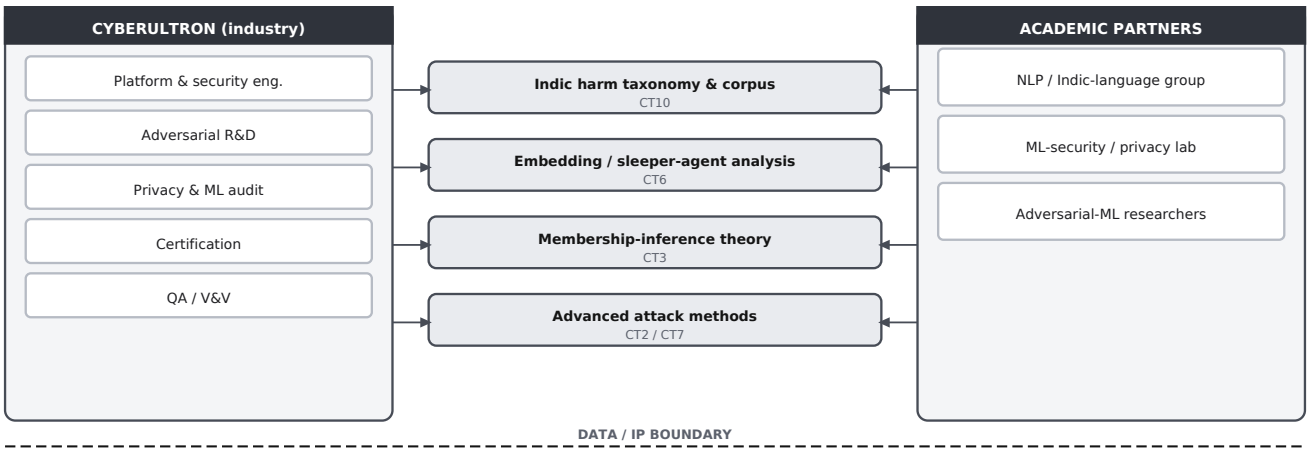



*Figure 30. Academic collaboration model. The industry team owns delivery; academic partners contribute to four research-forward areas through defined interfaces, under a strict data/IP boundary (synthetic / de-identified data only; no classified weights or findings leave the enclave) and the TDF ≤ 40% academic-cost rule.*

## 6.1 Technologies where academic support is needed

Four technology areas are research-forward (lower entry TRL, active in the literature) and are where academic collaboration adds the most value; the table maps each to the reason, the type of support and the category of institution best placed to provide it.

| Technology area (CT) | Why academic support is valuable | Type of support | Institution category |
|---|---|---|---|
| **Indian-language harm taxonomy & corpus (CT10)** | Native linguistic depth and validation across ≥5 languages; the principal sovereign differentiator | Corpus design, native-speaker validation, code-switching expertise | Computational-linguistics / NLP group |
| **Embedding & representation analysis (CT6)** | Sleeper-agent / backdoor detection is research-forward (TRL 3); strongest open scientific question | Joint research; detection methods; evaluation design | ML-security / representation-learning lab |
| **Membership-inference theory (CT3)** | Rigorous, honestly-scoped MIA (LiRA / RMIA) and canary methodology | Statistical methodology; benchmark design; review | Privacy-in-ML / statistics group |
| **Advanced attack methods (CT2 / CT7)** | State-of-the-art gradient and agentic attacks evolve rapidly in academia | Method advisory; literature tracking; red-team review | Adversarial-ML researchers |

**Table 66.** Technologies where academic support is needed, with support type and institution category. *Source:* Cyberultron solution architecture (§4.ii, §5.3); cited literature. *Interpretation:* Academic support is deliberately scoped to four research-forward areas; the engineering-heavy majority of the system needs no external support, bounding academic cost well within the TDF ≤ 40% rule.

### 6.2 Candidate academic / R&D; institutions

The following are representative candidate institutions whose published expertise aligns with the areas above; the company is incubated within the IIT Kanpur ecosystem (§7), which is the anchor relationship. Final partner selection and formal MoUs will be concluded at project award. Academic engagement is bounded by a strict data/IP boundary: partners work only on synthetic or de-identified data, and no classified model weights or vulnerability findings ever leave the secure enclave.

| Candidate institution (representative) | Relevant published expertise | Proposed role | Engagement |
|---|---|---|---|
| **IIT Kanpur (incubation anchor)** | Security, systems, ML; incubation & mentorship ecosystem | Research anchor; advisory; talent | Existing linkage; MoU at award |
| **AI4Bharat / IIT Madras** | Indian-language NLP, corpora and benchmarks (Indic-NLP) | Indic taxonomy & corpus validation | Project MoU (research) |
| **IIIT Hyderabad (LTRC)** | Language technologies; Indian-language resources | Native-language validation; code-switching | Project MoU (research) |
| **IIT Bombay (BharatGen ecosystem)** | Sovereign foundation models; multilingual NLP | Model-side insight; evaluation alignment | Project MoU (research) |
| **IISc Bengaluru** | Machine learning, security and privacy theory | MIA / embedding-analysis research | Project MoU (research) |
| **C-DAC / DRDO labs (as directed)** | HPC, secure systems, defence-domain context | Domain alignment; environment guidance | As directed by End-User |

**Table 67.** Candidate academic / R&D; institutions and proposed roles (representative). *Source:* Public institutional expertise; Cyberultron incubation linkage. *Interpretation:* Candidates are mapped to the four research-forward areas; naming is indicative, with the IIT Kanpur incubation as the concrete existing anchor and other MoUs to be formalised at award.

# 7 EXISTING ACADEMIC / RESEARCH-INSTITUTE SUPPORT

This section responds to EOI Item 7 on academic / research support that already exists with the industry in relation to this technology development.

**EXISTING LINKAGE: YES — INCUBATION WITHIN THE IIT KANPUR ECOSYSTEM.**
Cyberultron Consulting Private Limited is incubated within the **IIT Kanpur innovation / incubation ecosystem**, with associated startup backing. This provides an existing, concrete academic anchor — access to research mentorship, the institute's systems / security / ML expertise and talent pipeline — directly relevant to the research-forward components of this project. Project-specific research MoUs (for the Indic-corpus and embedding-analysis work in §6) will be formally executed at award; they are scoped under the same strict data/IP boundary described in §6.

The distinction between existing support and support to be established is summarised below, so the evaluation committee can clearly separate what is already in place from what is contingent on award.

| Linkage | Nature | Relevance to this technology | Status |
|---|---|---|---|
| **IIT Kanpur incubation ecosystem** | Incubation / startup association; mentorship; ecosystem access | Anchor for research-forward components; systems / security / ML depth; talent | Existing |
| **Technical advisory (senior architects / SMEs)** | Independent advisory board (§5.3) | Architecture & method review across the programme | Existing |
| **Indic-NLP corpus collaboration** | Research MoU (computational linguistics) | Native-language taxonomy & corpus validation (CT10) | To be executed at award |
| **Embedding / privacy research collaboration** | Research MoU (ML-security / privacy) | Sleeper-agent & MIA methodology (CT6 / CT3) | To be executed at award |

**Table 68.** Existing versus to-be-established academic / research support. *Source:* Cyberultron incubation and advisory arrangements; §6 collaboration plan. *Interpretation:* A concrete academic anchor (IIT Kanpur incubation) already exists; project-specific research MoUs are appropriately deferred to award and scoped within the data/IP boundary — a credible, honest position for a TDF response.

# 8 INDIGENOUS CONTENT IN THE PROPOSED SOLUTION

This section responds to EOI Item 8 on the likely indigenous content of the proposed solution. Indigenous content is assessed across six dimensions — company ownership, development personnel, net-new intellectual property, data and corpora, system integration, and the software/hardware substrate — and is summarised in Figure 31.

**INDIGENOUS CONTENT: ≈100% (AND 100% SOVEREIGN-OPERATED).**
The proposed solution is developed by an Indian-owned MSME using resident Indian personnel; all net-new intellectual property (the six assessment engines, the Indian-language harm taxonomy and the backdoor-signature database), all data and corpora, and all system integration and deployment are **100% indigenous**. The open-source foundational substrate is global-origin but permissively licensed (Apache-2.0 / MIT / BSD), forked, mirrored in-enclave and operated with zero external dependency or telemetry; the only non-indigenous element is commodity GPU/TEE **silicon**, for which no domestic substitute yet exists — a constraint common to every Indian AI programme. The system is therefore effectively sovereign in operation and overwhelmingly indigenous in content.

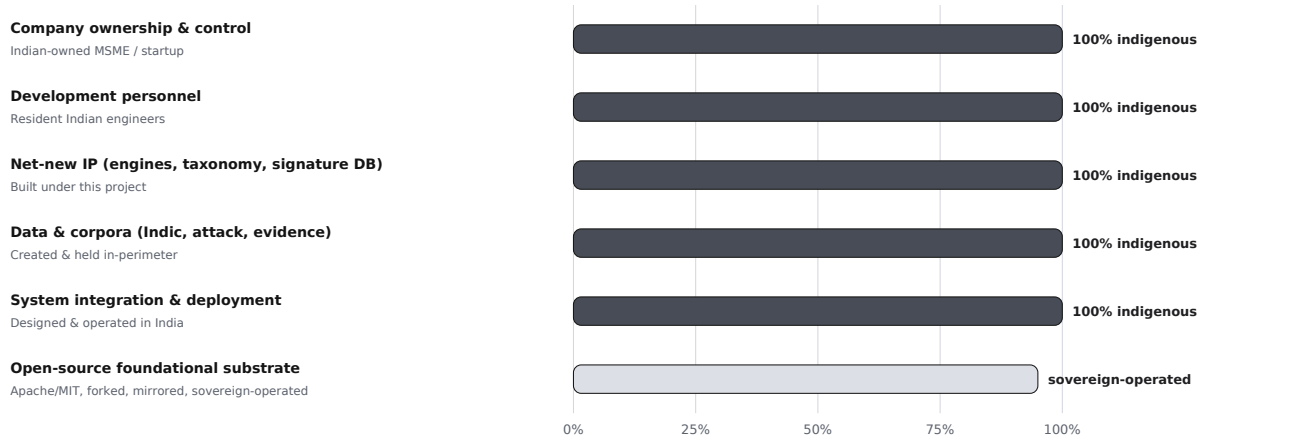



*Figure 31. Indigenous-content composition. Ownership, personnel, net-new IP, data and integration are 100% indigenous; the open-source substrate is global-origin but permissively licensed, forked and mirrored in-enclave and operated with zero external dependency or telemetry — making the deployed system effectively sovereign.*

## 8.1 Indigenous content by component

The table assesses each principal component by origin and ownership; “Yes” denotes indigenously developed, “sovereign-operated” denotes forked open-source operated with no external dependency, and hardware silicon is identified explicitly.

| Component | Origin / ownership | Indigenous | Notes |
|---|---|---|---|
| **Company, ownership & personnel** | Indian MSME; resident Indian engineers | Yes (100%) | Item 1; Undertaking 15 |
| **Six assessment engines (M2–M6)** | Designed & built under this project | Yes (100%) | Net-new sovereign software |
| **Indian-language harm taxonomy & corpus** | Built under this project (with academia) | Yes (100%) | Net-new sovereign IP |
| **Backdoor-signature database** | Built under this project | Yes (100%) | Net-new sovereign IP |
| **Certification & reporting engine** | Built under this project | Yes (100%) | Reuses our document pipelines |
| **Security architecture & air-gap design** | Designed by the industry team | Yes (100%) | Sovereign design |
| **Orchestration & policy plane** | OSS (FastAPI, OPA) integrated by us | Integration 100% | Forked & mirrored; sovereign-operated |
| **Model-serving substrate** | OSS (vLLM / TGI / Triton) | Sovereign-operated | Apache/MIT; forked & mirrored, zero egress |
| **Data stores (PostgreSQL, Redis, vault)** | Open-source | Sovereign-operated | Forked & mirrored in-enclave |
| **Confidential-computing integration** | Foreign silicon; integration by us | Mixed (logic indigenous) | TEE silicon imported; CC logic sovereign |
| **Documentation, V&V;, accreditation adapter** | Produced by the industry team | Yes (100%) | Sovereign |
| **GPU / TEE hardware (silicon)** | Foreign-origin commodity silicon | No (imported) | No domestic substitute; common to all |

**Table 69.** Indigenous content by component. *Source:* Cyberultron solution architecture (§4–§5); component licences. *Interpretation:* Every software and IP element is either indigenously developed or sovereign-operated open-source; the sole non-indigenous element is commodity silicon, isolating the dependency to hardware that no Indian programme can yet source domestically.

### 8.2 Indigenous content by category

| Category | Coverage | Indigenous content | Basis |
|---|---|---|---|
| **Ownership & control** | Company, governance, decision rights | 100% | Indian MSME / startup |
| **Personnel** | Engineering, research, delivery | 100% | Resident Indian team |
| **Net-new IP & engines** | Six engines, taxonomy, signature DB, certification | 100% | Developed under project |
| **Data & corpora** | Indic, attack, evidence, taxonomy | 100% | Created & held in-perimeter |
| **Integration & deployment** | Architecture, air-gap, operations | 100% | Designed & operated in India |
| **Software substrate (OSS)** | Serving, stores, policy, observability | Sovereign-operated | Apache/MIT, forked & mirrored |
| **Hardware (silicon)** | GPU / TEE accelerators | Imported | No domestic substitute available |

**Table 70.** Indigenous content by category. *Source:* Cyberultron solution architecture; TDF indigenous-content intent. *Interpretation:* Five of seven categories are 100% indigenous and a sixth is sovereign-operated; only commodity silicon is imported — versus foreign LLM-security tools, whose indigenous content is effectively nil and which are ineligible under the scheme.

# 9 RISK IDENTIFICATION AND MITIGATION PLAN

This section responds to EOI Item 9 with a comprehensive risk-identification and mitigation plan. It expands the milestone-level risks (§5.6) and the principal register (§5.9) into a full programme view across eight risk categories, managed through the lifecycle in Figure 32 and aligned to ISO 31000 and the NIST AI RMF (Map / Measure / Manage).

## 9.1 Risk-management methodology

Risks are identified from a structured taxonomy (technical, schedule, resource, hardware/supply, research, security, compliance and external), assessed on a five-point likelihood×impact scale (Figure 24), treated by the appropriate strategy (avoid / reduce / transfer / accept), and monitored continuously with formal review at every milestone gate. A live register is maintained with a named owner and a residual-risk position per item.




*Figure 32. Risk-management lifecycle. Risks are identified, assessed on a likelihood×impact scale, treated by the appropriate strategy, and monitored continuously, with formal review at every milestone gate — aligned to ISO 31000 and the NIST AI RMF.*

## 9.2 Risk distribution and register

Figure 33 shows the residual-risk distribution by category and severity after planned mitigations; the consolidated register follows. Likelihood (L) and Impact (I) use the five-point scale of Figure 24.

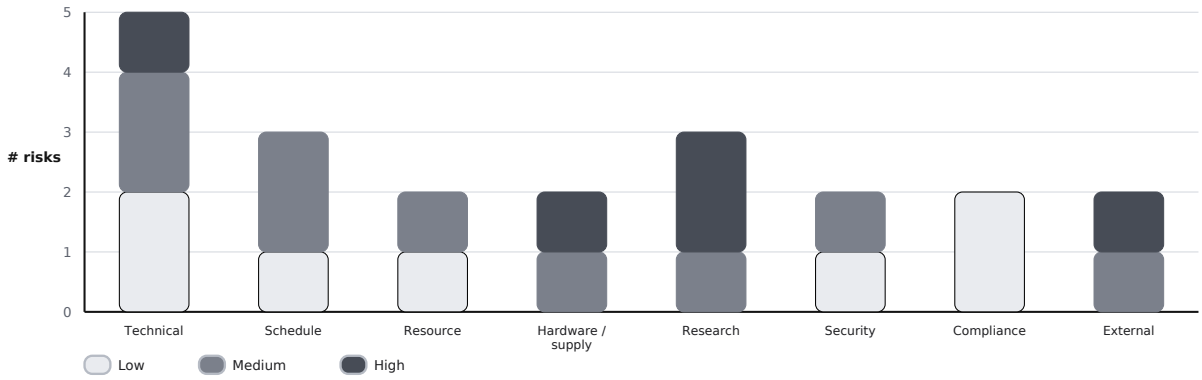



*Figure 33. Risk distribution by category and residual severity (post-mitigation). Research and hardware/supply categories carry the highest-severity residual risks; these are the focus of academic collaboration, early procurement and milestone gating (see the risk register, Table below).*

| ID | Category | Risk | L / I | Mitigation | Residual |
|---|---|---|---|---|---|
| **R1** | Hardware/supply | GPU / confidential-computing hardware lead time | Pos / Maj | Early procurement; interim Indian-cloud compute; CC off the M1 critical path | Medium |
| **R2** | Research | Embedding / sleeper-agent analysis maturity (TRL 3) | Unl / Sev | Academic collaboration; TRL-honest scope; fallback heuristics; gating | Medium |
| **R3** | Technical | Novel obfuscation evades static scanning | Pos / Mod | Defence in depth: fuzzing + sandbox detonation | Low |
| **R4** | Technical | < 4 h performance under the full suite | Lik / Maj | Probe parallelisation; batched agentic runs; profiling; tiered depth | Medium |
| **R5** | Technical | Inference-API test false positives | Unl / Mod | Validated findings only; reproducible PoC per finding | Low |
| **R6** | Research | Indian-language corpus maturity & validation | Pos / Sev | Academic linguistics partner; native validation; staged languages | Medium |
| **R7** | Compliance | Severity-scoring subjectivity | Lik / Min | Documented rubric; calibration set; peer review | Low |
| **R8** | External | Late accreditation specification from End-User | Unl / Maj | Engage End-User from M1; stable interface contract | Medium |
| **R9** | Resource | Key-person dependency | Rar / Maj | Cross-training; documentation; PMO continuity | Low |
| **R10** | Compliance | Standards / framework drift | Pos / Min | Versioned mapping rules; controlled-media refresh | Low |
| **R11** | Security | Sandbox escape from a malicious artifact | Unl / Maj | Rootless containers; seccomp / AppArmor; strong isolation | Low |
| **R12** | Schedule | Cross-engine integration slippage | Pos / Mod | Staged integration; CI gates; schedule buffers | Low |
| **R13** | Resource | Specialist-talent availability | Pos / Mod | Early hiring; academic pipeline; cross-training | Low |
| **R14** | Hardware/supply | GPU / CC firmware-driver compatibility | Pos / Mod | Qualification testing; vendor-agnostic TEE portability | Low |
| **R15** | Research | Gradient-attack convergence on some models | Pos / Min | Multiple methods (GCG/I-GCG/AutoDAN) + query-only fallback | Low |
| **R16** | Compliance | Data-handling / DPDP for sensitive corpora | Unl / Maj | Enclave-only; access control; defensive-use-only policy | Low |
| **R17** | Technical | Benchmark availability / representativeness | Pos / Min | Standard suites + custom corpora; documented method | Low |
| **R18** | External | Pilot-model availability at M8 | Pos / Mod | Early End-User coordination; reference models fallback | Low |
| **R19** | Security | Vulnerabilities in the framework itself | Unl / Maj | M8 penetration test & code audit; secure SDLC | Low |
| **R20** | Schedule | Scope creep | Pos / Mod | Change-control board; fixed EOI scope; gate discipline | Low |

**Table 71.** Consolidated risk register (R1–R20) with category, likelihood/impact, mitigation and residual rating. *Source:* Cyberultron risk-management plan (§5.6, §5.9). *Interpretation:* Twenty risks span eight categories; after mitigation the great majority are Low residual, with five Medium items (research, hardware and external dependencies) actively de-risked through academic collaboration, early procurement and sustained End-User engagement.

### 9.3 Principal residual risks — treatment detail

**R1 — Hardware / confidential-computing lead time.** The dominant supply risk is the lead time for TEE-capable GPU servers. Treatment: initiate procurement at award; use interim Indian-cloud or leased GPU capacity for development so the critical path is not gated on hardware; and keep confidential-computing enablement off the M1 critical path, completing it in M7. Residual: Medium, trending Low once hardware is on

site.

**R2 / R6 — Research-forward components (embedding analysis; Indic corpus).** The highest-impact technical risks are the two research items. Treatment: bind them to the academic partnership (§6) under the data/IP boundary; scope honestly to attainable TRLs; stage the corpus by language; and provide engineering fallbacks (heuristic detection; staged coverage) so a deliverable always lands at the gate even if the research target slips. Residual: Medium, contained by gating.

**R4 — Performance (< 4 h on a 7B model).** The most likely technical risk is the performance target under the full suite. Treatment: engineer for it from M1 (parallel probes, batched agentic runs, GPU acceleration), profile continuously, and use tiered scan depth so the headline target is met while deeper probes run as extended passes. Validated at G7. Residual: Medium.

**R8 / R18 — External dependencies (accreditation spec; pilot models).** The principal external risks concern timely End-User inputs. Treatment: engage the DRDO liaison from M1, design the accreditation adapter to a stable interface contract, and hold open-weight reference models as a pilot fallback. Residual: Medium, with concrete fallbacks (§5.12).

A zero-float critical path (Figure 25) means each Medium risk is paired with a concrete fallback so that no single risk can breach the 24-month ceiling; schedule contingency is held within each milestone and concentrated at M8 for remediation following independent V&V.;

# 10 ADDITIONAL INFRASTRUCTURE REQUIRING FUNDING SUPPORT

This section responds to EOI Item 10: infrastructure required beyond the essential items, not already available with the industry, for which funding support is sought. The position is summarised in Figure 34. The industry already holds the general development, cloud, software and expertise base; the infrastructure specific to **air-gapped, defence-grade operation** — which by its nature cannot be commodity cloud — is what requires funding. All entries are technical specifications only; no commercial figures are included, consistent with EOI requirements, and the final bill of materials is agreed with the End-User at the RFP stage (see also Annexure L).

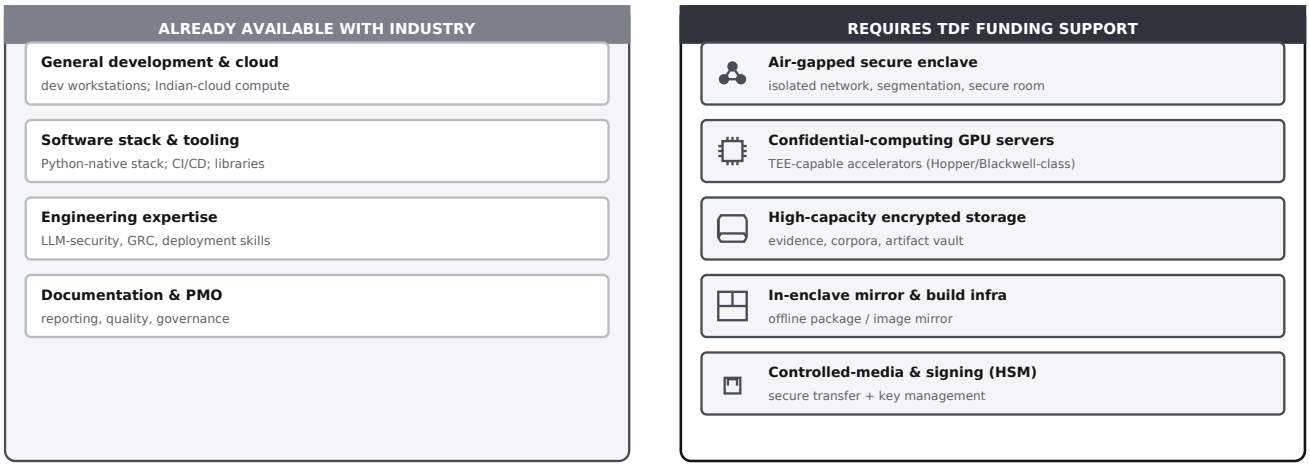



*Figure 34. Infrastructure — existing versus funded. The industry already holds general development, cloud, software and expertise; the air-gapped, confidential-computing and secure-handling infrastructure specific to defence-grade operation is what requires TDF funding support (technical need only; no commercial figures).*

## 10.1 Infrastructure inventory — essential, available and funded

The inventory classifies each item as essential or additional, states whether it is already available with the industry, and whether funding support is required, with justification.

| Infrastructure item | Category | With industry? | Funding? | Justification |
|---|---|---|---|---|
| **Development workstations** | Essential | Yes | No | In place |
| **Software stack & libraries (OSS)** | Essential | Yes | No | Python-native stack already operated |
| **Engineering manpower (core team)** | Essential | Yes | Partial | Core team in place; specialist hires at award |
| **General compute (Indian cloud)** | Essential | Yes | No | Used for interim development |
| **Air-gapped secure enclave (network, segmentation, secure room)** | Additional | No | Yes | Mandatory for sovereign / classified weights; not commodity cloud |
| **Confidential-computing GPU servers (TEE)** | Additional | No | Yes | Serving, attacks & weights-protected-in-use; not currently held |
| **High-capacity encrypted storage** | Additional | Partial | Yes | Evidence, corpora and artifact vault at scale |
| **In-enclave package / image mirror & build** | Additional | No | Yes | Reproducible, fully offline builds |
| **Controlled-media transfer apparatus** | Additional | No | Yes | Only sanctioned, signed ingress / egress |
| **Hardware security module (HSM) / signing** | Additional | No | Yes | Key management & signed artifacts / audit |
| **Sandbox detonation capacity** | Additional | Partial | Yes | Isolated hosts for untrusted-artifact detonation |
| **Independent V&V; / pilot environment** | Additional | No | Yes | Separate IV&V; (M8) and pilot assessment |

**Table 72.** Infrastructure inventory — essential vs additional, availability and funding need. *Source:* Cyberultron capability baseline; EOI essential-infrastructure list; solution architecture (§5.4). *Interpretation:* Essential items are already in place; the additional, defence-specific infrastructure (air-gap, confidential computing, secure handling) is what requires funding — none of it is substitutable by the commodity resources the industry already holds.

### 10.2 Funded infrastructure — technical justification

The items below are the additional infrastructure for which funding support is sought; each is essential to the air-gapped, defence-grade operating model and is not available within the industry's current resources.

| Funded infrastructure | Why essential to this project | Reference |
|---|---|---|
| **Air-gapped secure enclave** | Sovereign / classified weights cannot traverse external networks; the enclave is the precondition for all testing | §5.4; Fig 19; Annexure L |
| **Confidential-computing GPU servers** | High-throughput serving and attacks, with target weights encrypted in use (TEE / attestation) | §5.4; M7; Annexure L |
| **Encrypted storage at scale** | Tamper-evident evidence store, signed artifact vault and growing Indic corpora | §5.13; Annexure L |
| **In-enclave mirror & build** | Reproducible, signed builds with no external dependency | M1 / M2; Annexure L |
| **Controlled-media & HSM / signing** | The only sanctioned transfer path and the basis of signed, auditable output | §5.4; M6; Annexure L |
| **Independent V&V; / pilot environment** | Objective validation by a separate team and a relevant-environment pilot (TRL 7) | M8; §5.8 |

**Table 73.** Funded infrastructure and technical justification (non-commercial). *Source:* Cyberultron solution architecture (§5.4–5.5, §5.8, §5.13). *Interpretation:* Each funded item is mapped to where it is used and why it is indispensable; the list is deliberately minimal and defence-specific, with commodity needs met from existing industry resources.

In summary, the funding support sought is confined to the specialised, air-gapped and confidential-computing infrastructure that no commodity environment can provide and that the industry does not currently hold; the broad development, software and expertise base is contributed by the industry. Indicative technical specifications are given in Annexure L; quantities and the bill of materials are finalised with the End-User at the RFP stage, with no commercial information included at the EOI stage.

## 11 EXPERIENCE IN DESIGN & DEVELOPMENT, INCLUDING ASSOCIATED TOOLS

This section responds to EOI Item 11. The firm demonstrates working knowledge of, and the capability to develop, the technologies relevant to LLM security assessment. Evidence takes the forms recognised by the EOI — internal prototypes and production capability, open-source familiarity, research-grade methodology, and team credentials — and is further evidenced by the technical design set out across this response (§4–§5, Annexures T, U). The capability-to-evidence mapping is shown in Figure 36. Supporting documents (anonymised CVs, repositories, engagement and project records, certifications) are furnished separately with this submission.

| | | Internal prototypes / production | Open-source / research | Design in this response | Team credentials |
|---|---|---|---|---|---|
| **A1** | Transformer design, training & fine-tuning | ● | ○ | ● | ● |
| **A2** | Supervised fine-tuning / instruction-tuning | ● | ● | ● | ○ |
| **A3** | Cybersecurity-corpus curation | ● | ○ | ● | ○ |
| **A4** | Air-gapped / isolated-network operation | ● | ○ | ● | ● |
| **A5** | Python (mandatory) + system integration | ● | ○ | ● | ● |
| **A6** | Agentic / multi-step LLM frameworks | ○ | ● | ● | ○ |
| **A7** | RAG pipelines + open-source vector DB | ● | ○ | ● | ○ |
| **A8** | Benchmarked detection (precision / recall) | ● | ● | ● | ○ |
| **A9** | Malware-analysis tooling awareness | ○ | ● | ● | ○ |

● Strong evidence ○ Supporting evidence

*Figure 36. Capability and evidence map. Each essential design-and-development criterion (A1–A9) is evidenced across internal prototypes / production, open-source & research, the design set out in this response, and team credentials — every criterion is met with strong evidence on at least two axes.*

Compliance against each essential design-and-development criterion is recorded below.

| SN | Item / Criterion | Compliance | Supporting documents |
|---|---|---|---|
| **A1** | Working knowledge of transformer-based language-model design, training and fine-tuning — demonstrated through projects, prototypes, fine-tuned model releases, hackathons, open-source contributions or published work; experience with small / medium open-weight models is acceptable, scaling up progressively | **Yes** | Model strategy (§4.v.1, §4.v.2); anonymised CVs; open-source profiles |
| **A2** | Hands-on familiarity with supervised fine-tuning (SFT) and instruction-tuning of open-weight LLMs; a small-scale fine-tuning exercise with documented evaluation is acceptable evidence | **Yes** | SFT approach & model card (§4.v.2); fine-tuning records |
| **A3** | Familiarity with cybersecurity-domain corpora — source code (C / C++ / Python / Java / Go / Rust / JavaScript / assembly), CVE / NVD / SARD entries, OWASP Benchmark, security blogs and threat-intel reports — and capability to curate and clean such data | **Yes** | Corpus curation (§4.v.3, §5.13); data-pipeline records |
| **A4** | Capability to design and operate the solution in an air-gapped / isolated-network mode without dependence on external cloud services, for sovereign training and inference | **Yes** | Air-gapped architecture (§4.v.6, §5.4); deployment experience |
| **A5** | Software-development experience with Python (mandatory) and capability to integrate model-serving, retrieval, agentic and analyst-facing components | **Yes** | Python-native stack (§5.5); integration (§4.v, M7) |
| **A6** | Familiarity with agentic / multi-step LLM frameworks (LangChain, AutoGen, LlamaIndex or equivalent open-source libraries) | **Yes** | Agentic-engine design (§4.v.5); Annexure T |
| **A7** | Familiarity with Retrieval-Augmented Generation (RAG) pipelines using any open-source vector database (FAISS, Chroma, Milvus, Qdrant) for document retrieval and correlation | **Yes** | RAG design (§4.v.4); retrieval-pipeline records |
| **A8** | Capability to evaluate vulnerability detection on standard benchmarks (OWASP Benchmark, SARD, Juliet, CVE patch datasets) and report precision / recall | **Yes** | Detection & evaluation plan (§4.v.7); benchmark harness |
| **A9** | Awareness of malware-analysis assistance using open-source tooling (Ghidra, radare2 / Cutter or equivalent) | **Yes** | Malware analysis & RE (§4.v.8); Annexure T |

**Table 74.** Compliance against essential design-and-development criteria (Item 11). *Source:* EOI Item 11; this response; supporting documents furnished separately. *Interpretation:* All nine essential design-and-development criteria are met (Yes), each substantiated by the technical design in this response and by separately-furnished supporting documents.

### 11.1 Technology and tool familiarity

The specific technologies and techniques named in the EOI, the firm's level of familiarity, and where each is demonstrated in this response, are mapped below.

| Technology / technique | Familiarity | Demonstrated via / where in this response |
|---|---|---|
| **LLM security testing & red-teaming** | Working | Six-engine framework design (§4.iv, §5.6); Annexures T, U |
| **Prompt injection & jailbreak (GCG, AutoDAN, PAIR, DAN, token-smuggling)** | Working | Attack engines (M3 / M4); Annexures T, AB |
| **Gradient / agentic attack methods** | Working | Gradient & agentic engines (M4); Annexure T |
| **Serialised-artefact inspection (pickle / safetensors / ONNX / ckpt)** | Working | Static scanner (M2); Annexures T, AB |
| **Air-gapped / isolated-network design & operation** | Demonstrated | §5.4, §5.13; Figures 19, 37 |
| **Python (mandatory) + system integration** | Strong | Python-native stack (§5.5); integration (M7) |
| **Agentic / multi-step frameworks (LangChain / AutoGen / LlamaIndex)** | Working | Agentic orchestrator (M4); Annexure T |
| **Inference serving (vLLM / TGI / Ollama / llama.cpp / Triton)** | Working | Serving substrate (§5.5, M1); Figure 37 |

**Table 75.** Technology and tool familiarity mapping (Item 11). *Source:* EOI Item 11; programme design (§4–§5). *Interpretation:* Every technology and technique named in the EOI is matched to a stated familiarity level and to where it is demonstrated in this response, evidencing hands-on working capability across the full tool-chain.

### 11.2 Substantiation by criterion

**A1–A3 Model development, fine-tuning and cybersecurity-corpus curation.** The proposed framework fine-tunes open-weight transformer models for security tasks; the model strategy and the SFT / instruction-tuning approach are set out in §4.v.1–§4.v.2 with a benchmarked model card, and the cybersecurity-corpus curation pipeline — source code, CVE / NVD / SARD, OWASP Benchmark and threat-intel — in §4.v.3. Working with small / medium open-weight models is the stated baseline, scaling up progressively. Fine-tuning records and data-pipeline documentation are furnished as supporting documents.

**A4–A6 Air-gapped operation, Python integration and agentic frameworks.** The entire solution is architected for fully air-gapped operation (§4.v.6, §5.4); the stack is wholly Python-native (§5.5) with system integration across model-serving, retrieval, scanning and analyst-facing components (M7); and the agentic engine (§4.v.5) is built on agentic / multi-step orchestration patterns equivalent to LangChain / AutoGen / LlamaIndex.

**A7–A9 RAG, benchmarked detection and malware analysis.** Retrieval-augmented correlation over an open-source vector store is set out in the RAG design (§4.v.4); detection quality is evaluated against OWASP Benchmark, SARD, Juliet and CVE patch datasets with precision / recall reported (§4.v.7); and binary / serialised-artefact threats are handled with open-source reverse-engineering tooling and sandbox detonation (§4.v.8).

## 12 ESSENTIAL TEST INFRASTRUCTURE FOR THE SOLUTION

This section responds to EOI Item 12. The firm has the essential design, development, integration and testing infrastructure — in-house and through collaboration — required to develop the project. This is the essential development / test infrastructure; the additional, defence-grade air-gapped and confidential-computing infrastructure required for handling sovereign / classified models is the subject of Item 10. The essential development / test topology is shown in Figure 37.

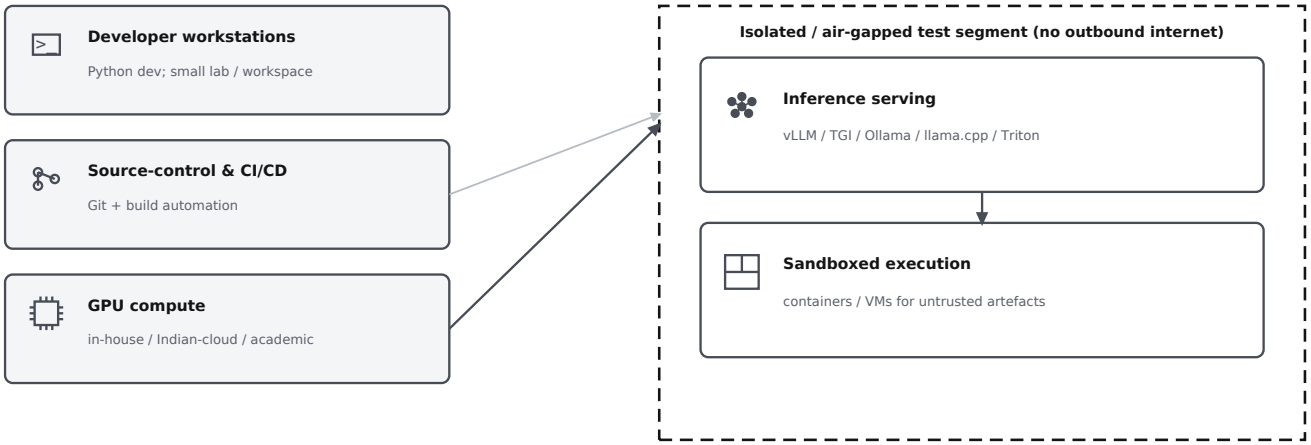



*Figure 37. Development and test infrastructure topology (essential; in-house / collaboration). Standard workstations, source-control / CI-CD and GPU-class compute support development; an isolated, no-outbound test segment hosts open-source inference serving and a sandbox for safely executing untrusted serialised artefacts.*

| SN | Type of Infrastructure | Compliance | Availability | Supporting documents |
|---|---|---|---|---|
| **A1** | GPU-class compute (in-house, leased, or via Indian cloud / academic / partner) sufficient for fine-tuning and serving open-weight models in the small-to-medium parameter range during development; larger compute arranged progressively | **Yes** | In-house + Collaboration | Compute records; partner / cloud arrangement |
| **A2** | Distributed-training capability using any open-source stack (DeepSpeed, FSDP, Accelerate, Megatron); large-scale runs may be undertaken on shared / partner / cloud infrastructure as required | **Yes** | In-house + Collaboration | Training-stack records; partner / cloud arrangement |
| **A3** | Isolated / air-gappable testing environment (dedicated machine or network segment with no outbound internet) for sensitive corpora and model weights | **Yes** | In-house | Network / segment configuration |
| **A4** | Inference-serving setup (open-source tools such as vLLM, TGI, Ollama, llama.cpp or equivalent) for hosting and evaluating fine-tuned models | **Yes** | In-house | Serving configuration |
| **A5** | Source-control and basic CI / CD infrastructure with secure dependency management | **Yes** | In-house | Repository / pipeline records |
| **A6** | Secure data-ingestion practice for importing CVE feeds, vendor patches, OSS code repositories and threat-intel into a controlled environment | **Yes** | In-house | Ingestion SOP; data-pipeline records |
| **A7** | Code-analysis sandbox: container / VM environments for safe parsing, AST / CFG extraction and PoC validation across multiple programming languages | **Yes** | In-house | Sandbox design; container / VM configuration |

**Table 76.** Compliance against essential test-infrastructure requirements (Item 12). *Source:* EOI Item 12; firm infrastructure baseline (§5.4–5.5). *Interpretation:* All seven essential infrastructure items are available (Yes), in-house or via collaboration; GPU compute is augmented through Indian-cloud / academic arrangements, and an isolated, no-outbound development segment already exists for sensitive-model testing.

# 13 AVAILABILITY OF EXPERIENCED MANPOWER

This section responds to EOI Item 13. The firm has experienced manpower across the technical roles enumerated by the EOI — in-house in the founding / engineering team and, where noted, through documented collaboration and advisory arrangements. Consistent with the EOI, a small founding team covering multiple roles is acceptable; the organisation is shown in Figure 18 (§5.3). Acceptable supporting documents (anonymised CVs, engagement records, certifications, publications, open-source profiles, collaboration agreements) are furnished separately.

| SN | Manpower / experience | Compliance | Availability | Supporting documents |
|---|---|---|---|---|
| **A1** | At least one founder / technical lead with hands-on background in machine learning, NLP / LLMs or applied AI research (projects, publications, certifications, open-source contributions or prior experience) | **Yes** | In-house | Anonymised CV; certifications; profiles |
| **A2** | Engineer(s) with practical Python / ML experience and exposure to transformer training and fine-tuning frameworks (Hugging Face Transformers, PyTorch, Accelerate, DeepSpeed, FSDP) | **Yes** | In-house | Anonymised CVs; repositories |
| **A3** | Engineer(s) with cybersecurity / secure-coding awareness (CEH, OSCP, CTF participation, vulnerability disclosures or relevant project work) for dataset curation, evaluation and red-teaming | **Yes** | In-house + Collaboration | Certifications; CTF / disclosure records |
| **A4** | Data engineer / curator for ingestion, deduplication, basic PII handling and dataset version control | **Yes** | In-house | Anonymised CV; data-pipeline records |
| **A5** | Project / engineering lead responsible for milestone delivery (may be the founder or a designated team member) | **Yes** | In-house | Engagement record |
| **A6** | Resource(s) with reverse-engineering / malware-analysis exposure for binary-analysis components | **Yes** | In-house + Collaboration | RE / malware-analysis records; Annexure T |
| **A7** | Software / DevOps engineer for inference serving, agentic-framework integration and analyst-facing APIs / UIs | **Yes** | In-house | Anonymised CV; project records |

**Table 77.** Compliance against manpower requirements (Item 13). *Source:* EOI Item 13; firm organisation (§5.3, Figure 18); supporting documents furnished separately. *Interpretation:* All enumerated technical roles are covered (Yes), primarily in-house with collaboration / advisory support where indicated; the founding team covers multiple roles, which the EOI expressly accepts.

## 13.1 Role-coverage matrix

| Role | Covered by | Availability | Key basis |
|---|---|---|---|
| **Technical lead** | Founder / CEO | In-house | Cybersecurity & applied-AI background |
| **ML / LLM engineer** | Engineering team | In-house | Python / PyTorch / Transformers |
| **Offensive-security engineer** | Engineering team / advisor | In-house + Collab. | Certifications; CTF / disclosures |
| **Software / DevOps engineer** | Engineering team | In-house | Scanner, dashboards, deployment |
| **Project / engineering lead** | Founder / designate | In-house | Milestone delivery & PMO |
| **Research / linguistics support** | Academic partners (§6) | Collaboration | Indic-NLP; ML-security research |
| **Data engineer / curator** | Engineering team | In-house | Ingestion, dedup, PII handling, versioning |
| **Reverse-engineering / malware analysis** | Engineering team / advisor | In-house + Collab. | Binary analysis; sandbox detonation |

**Table 78.** Role-coverage matrix. *Source:* Firm organisation (§5.3); academic collaboration (§6). *Interpretation:* Every required role is mapped to a responsible party; the lean founding team covers the core engineering roles in-house, with research-forward roles supported through academic collaboration.

## 14 MANAGEMENT CAPABILITIES

This section responds to EOI Item 14. Appropriate to the firm's size and stage, the management capabilities available are listed below, with the basis for each. The intent — quality and security discipline — is met through a combination of information-security alignment, AI-risk-management awareness, MLOps / DevSecOps practice, a secure SDLC and planned independent verification & validation. These are detailed in §5.10, §5.15 and Annexures E and Y.

| Management capability | Available | Basis / maturity |
|---|---|---|
| **Quality Management System / Quality Control** | Yes (in practice) | Quality plan; review, test & config discipline (§5.15) |
| **Information Security — ISO/IEC 27001** | Yes (aligned) | Control alignment & practice (§5.10, Annexure E) |
| **AI Risk Management — NIST AI RMF / ISO/IEC 42001** | Yes (awareness) | Lifecycle governance & risk approach (§5.9–§5.10) |
| **MLOps** | Yes | Model / data versioning; reproducible pipelines (§5.5) |
| **DevSecOps** | Yes | Security in CI/CD; secure build & deploy (§5.15) |
| **Secure SDLC** | Yes | Secure development practice (§5.15, Annexure Y) |
| **Independent Verification & Validation (IV&V;)** | Yes (planned) | Separate-team validation at M8 (§5.8) |
| **CMMI** | Awareness | Process discipline aligned; not formally certified |

**Table 79.** Management capabilities available (Item 14). *Source:* EOI Item 14; programme management approach (§5.8, §5.10, §5.15; Annexures E, Y). *Interpretation:* The firm meets the quality-and-security-discipline intent through several of the listed capabilities — information-security alignment, AI-risk awareness, MLOps, DevSecOps, secure SDLC and planned IV&V; — commensurate with its size and stage.

## 15 UNDERTAKING BY THE FIRM

a) Cyberultron Consulting Private Limited hereby undertakes that all model weights, prompt corpora, vulnerability findings, fine-tuning datasets, inference logs, and reports generated, derived or used under the proposed project shall remain within the secure Indian perimeter throughout development, testing and deployment. No such artefact shall be transmitted to, processed on, or stored upon any infrastructure, network or cloud service located outside India or under foreign ownership or control, at any stage of the work.

The Company further undertakes that the development, training, evaluation and inference environment shall be operable in an air-gapped / isolated-network mode, and that data handling, retention and disposal shall conform to the applicable directions of the Government of India for sensitive and classified information.

For and on behalf of **Cyberultron Consulting Private Limited**

**(Krishna Mohan Sharma)**
Head of Technology & Authorised Signatory · +91 94574 54866 · krishna@cyberultron.com

# 16 ORGANIZATION STRUCTURE, LEGAL STATUS AND COMMITMENTS

## 16.a Corporate

| | |
|---|---|
| **Registered name** | Cyberultron Consulting Private Limited |
| **Legal status** | Private Limited Company (limited by shares), incorporated under the Companies Act, 2013 on 9 February 2022 |
| **CIN / GSTIN / PAN** | CIN: U72900UR2022PTC013576 · GSTIN: 05AAKCC0894R1ZZ · PAN: AAKCC0894R |
| **Place of registration** | Registrar of Companies, Uttarakhand, India |
| **Registered office** | C3iHub, 2nd Floor, Technopark Phase I, IIT Kanpur, Kanpur – 208016, Uttar Pradesh, India |
| **Principal place of business** | C3iHub, 2nd Floor, Technopark Phase I, IIT Kanpur, Kanpur – 208016, Uttar Pradesh, India |
| **MSME / Startup status** | MSME-registered; DPIIT-recognised Startup — Certificate No. DIPP96348 |
| **Business activities** | AI-native cybersecurity, privacy and GRC — design and development of LLM security assessment, runtime AI guardrails and a multi-model security gateway; incubated at C3iHub, IIT Kanpur. |

## 16.b Corporate Structure

The Company is promoter-managed and operates with a lean founding and engineering team in which members cover multiple roles, consistent with the EOI's acceptance of small founding teams. The present Directors and the Authorised Signatory are set out below; the discipline-wise technical coverage and the responsible parties are detailed in the manpower and role-coverage matrices at §13 and §13.1, and the formal particulars are on record with the Registrar of Companies and in the incorporation documents furnished with this EOI.

| Name | Role / Designation | Particulars |
|---|---|---|
| Mukesh Goyal | Founder & Director | On record with the Registrar of Companies |
| Suman Goyal | Director | On record with the Registrar of Companies |
| Krishna Mohan Sharma | Head of Technology & Authorised Signatory | On record with the Registrar of Companies |

**Permanent manpower (discipline-wise).** The Company maintains a lean permanent technical team, augmented by documented collaboration and advisory arrangements, covering AI / ML / LLM engineering, cybersecurity / secure-coding, data engineering / curation, and DevOps / platform engineering, principally at the principal place of business (C3iHub, IIT Kanpur) with remote working. Role-wise coverage and the basis for each role are set out in §13.1; detailed permanent-strength particulars are available on record and will be furnished as required.

## 16.c Shareholding Pattern and Major Investors

**i. Shareholding pattern of the firm.** The Company is wholly owned and controlled by resident Indian citizens together with an Indian institutional shareholder. The full shareholding pattern is set out below.

| Shareholder / Investor | Category | Holding (%) |
|---|---|---|
| Mukesh Goyal | Promoter & Majority Shareholder | 55.00 |
| Suman Goyal | Promoter / Shareholder | 30.00 |
| Vinod Kumar K B HUF | Shareholder | 7.00 |
| Mrs. Radhaben B. Panchal | Shareholder | 5.00 |
| IIT Kanpur | Institutional Shareholder / Strategic Academic Partner | 3.00 |
| **Total** | | **100.00** |

**ii. Majority shareholder and top-five shareholders.** The majority shareholder is **Mukesh Goyal** (55.00%). The Company has five shareholders in all; the top-five shareholders are therefore Mukesh Goyal (55.00%), Suman Goyal (30.00%), Vinod Kumar K B HUF (7.00%), Mrs. Radhaben B. Panchal (5.00%) and IIT Kanpur (3.00%).

**iii. Foreign shareholders holding more than 5%.** Nil — there are no direct or indirect foreign shareholders, including foreign entities, holding more than a 5% stake. A foreign-shareholding declaration to this effect is furnished with this EOI.

**iv. Shareholders from a country sharing a land border with India.** Nil — there are no direct or indirect shareholders from any country sharing a land border with India. A declaration to this effect is furnished with this EOI.

## 17 FINANCIAL CAPABILITIES

The applicant has a **positive net worth**. Complete audited annual financial statements for the most recent financial year — the balance sheet, the profit & loss account statement and the audit report — are furnished with this EOI as a financial annexure, in which the audited net-worth figure and the corresponding financial year are stated. No commercial or cost information relating to this proposal is included in the body of this response.

The applicant self-certifies that it is **not** under liquidation, court receivership or any similar proceeding, and that the financial statements furnished are true and complete copies of its audited records.

## 18 LITIGATION / ARBITRATION HISTORY

The applicant has **no** history of court litigation or arbitration proceedings arising from contracts executed in the last five years or currently under execution. The same position applies to the applicant's significant sub-contractors, and is recorded in the prescribed format below.

| Year | Decree / Award for or against the Applicant, or Arbitration ongoing | Name of client, cause of litigation, and matter in dispute | Disputed amount (current value) |
|---|---|---|---|
| Nil | Nil | Nil | Nil |

## CAPABILITY AND INFRASTRUCTURE EVIDENCE (SUPPORTING DETAIL)

This section consolidates, in one place, the mandatory capability and infrastructure evidence required by the EOI, complementing the experience and tooling in §11, the essential test infrastructure in §12 and the technology and methodology in §5.5–§5.6. As this is an Expression-of-Interest response, each item is evidenced here through a representative design, network diagram, standard operating procedure, repository structure or capability record; the corresponding live artefacts — network diagrams and egress policy, deployment notes, repository access, the data-ingestion SOP, the sandbox design and project reports / demonstrations — are maintained by the firm and will be produced for inspection by the evaluation committee on request, with all sensitive material handled within the Indian perimeter.

| Mandatory evidence (EOI) | Form of evidence | Demonstrated in this response |
|---|---|---|
| **Isolated / air-gappable test environment** | Network diagram; egress policy; screenshots | the Capability and Infrastructure Evidence (Supporting Detail), Figure 38; §5.4, Figure 19 |
| **Inference serving setup** | Deployment note; configuration; screenshots | the Capability and Infrastructure Evidence (Supporting Detail), Figure 39; §5.5, Figure 22 |
| **Source control and CI/CD** | Repository access; pipeline / process screenshots | the Capability and Infrastructure Evidence (Supporting Detail), Figure 40; §5.15 |
| **Secure data-ingestion practice** | Data-ingestion SOP | the Capability and Infrastructure Evidence (Supporting Detail), Figure 41; §5.13 |
| **Code-analysis sandbox** | Sandbox design; screenshots | the Capability and Infrastructure Evidence (Supporting Detail), Figure 42; §4.v.8 |
| **AI / ML / LLM project evidence** | Project reports; demonstrations; links | the Capability and Infrastructure Evidence (Supporting Detail), Figure 43; §11, §5.6 |

**Table 80.** Mandatory capability and infrastructure evidence — compliance crosswalk. *Source:* EOI mandatory-evidence requirements; this response. *Interpretation:* Each of the six mandatory evidence items is addressed by a dedicated subsection and figure in this section and is further substantiated by the corresponding design content elsewhere in the response; the live artefacts are available for inspection on request.

### Isolated / Air-Gappable Test Environment

The test environment is a dedicated machine / network segment with no outbound route to any external network. Naive air-gaps often fail because a single mis-scoped firewall rule, a dual-homed host or an auto-update agent quietly re-establishes egress; the design therefore enforces a deny-all egress policy at the host and segment level, permits only intra-enclave traffic, and logs every flow, with the only ingress being a one-way, signed-and-scanned controlled-media transfer. The topology and a representative egress ruleset are shown in Figure 38.

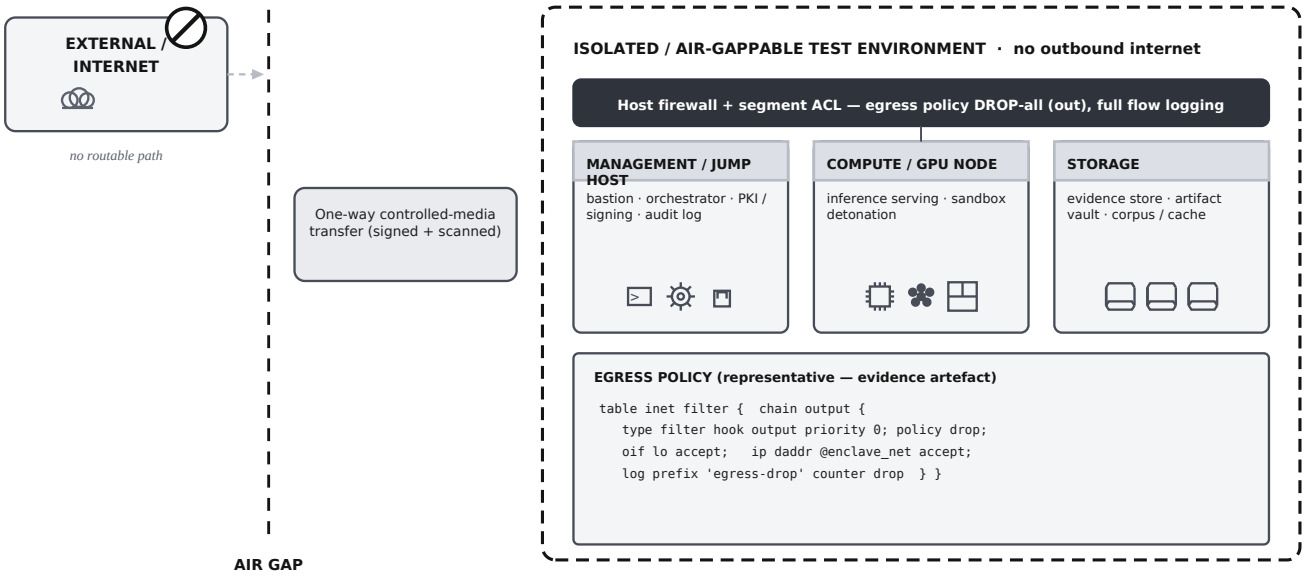



*Figure 38. Isolated / air-gappable test environment. The test segment has no outbound route to any external network; the only ingress is a one-way, signed-and-scanned controlled-media transfer. A host firewall and segment ACL enforce a deny-all egress policy (representative ruleset shown) with full flow logging across the management, compute / GPU and storage hosts.*

**Evidence furnished.** Network / topology diagram of the isolated segment; the host-firewall and segment-ACL egress policy (deny-all out, full flow logging); host inventory; and screenshots of the configured rules and routing tables, available for inspection.

### Inference Serving Setup

Models are served inside the enclave by self-hosted, OpenAI-compatible runtimes (vLLM, TGI, Triton, Ollama and llama.cpp), selected to match model size and available hardware and to avoid any dependency on a hosted inference API — the single largest sovereignty risk in commercial tooling. Signed open-weight models are version-pinned and quantised, served behind an internal router (LiteLLM) with RBAC, quota and audit, and consumed by the attacker / assistant models, the evaluation harness and the agentic loop, as shown in Figure 39.

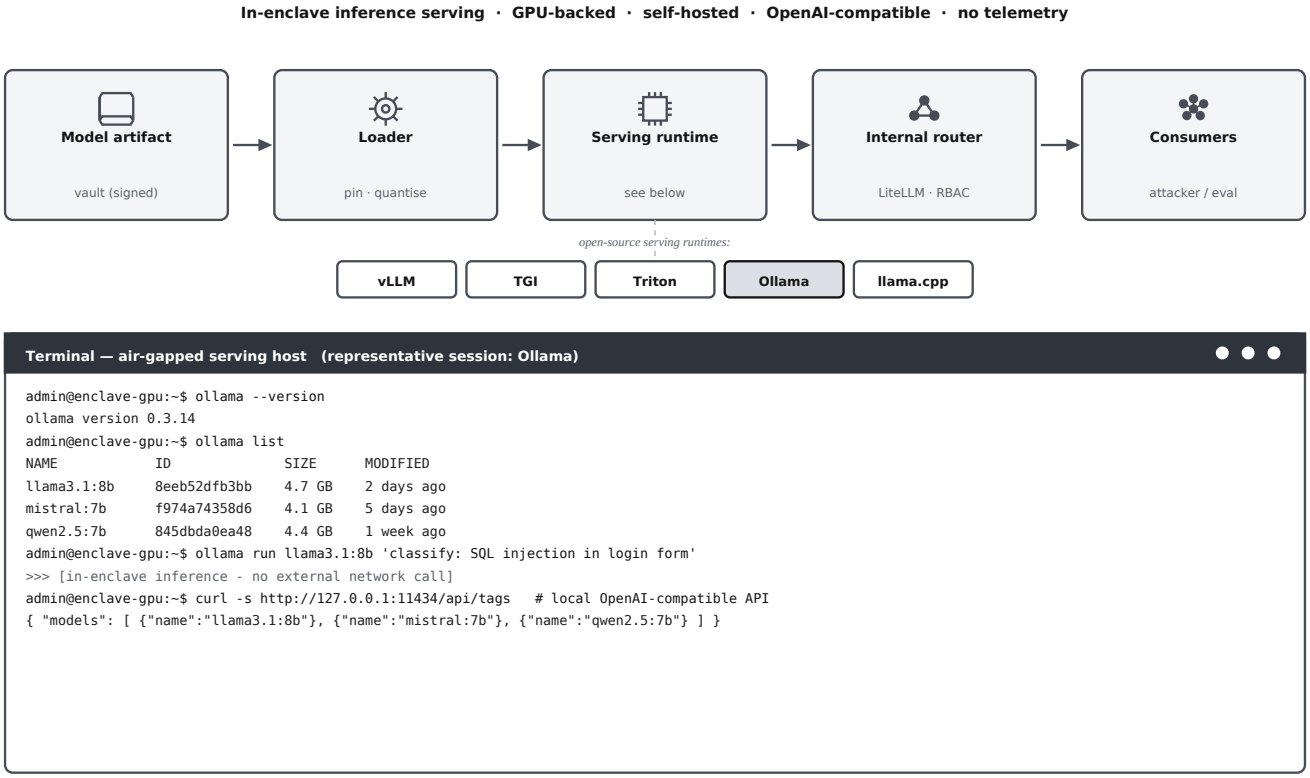



*Figure 39. In-enclave inference-serving topology and a representative Ollama serving session. Signed open-weight models are version-pinned, quantised and served by self-hosted, OpenAI-compatible runtimes (vLLM / TGI / Triton / Ollama / llama.cpp) behind an internal router (LiteLLM); the lower panel shows a representative Ollama setup on the air-gapped host (model pull / list, a local run and the local API), confirming fully self-hosted inference with no external network call or telemetry.*

**Evidence furnished.** Deployment note describing the serving runtimes, model-loading and quantisation, GPU allocation and the internal-router configuration; representative configuration files; and screenshots of a running self-hosted endpoint, available for inspection.

### Source Control and CI/CD

All code, configuration and infrastructure-as-code are held in a single version-controlled monorepo with branch protection and signed commits, built through a secure CI/CD pipeline. Dependency risk — a common supply-chain weakness — is controlled by pinned dependencies with lockfiles, software-composition analysis, an in-enclave package mirror (no public pulls at delivery), SBOM generation and artefact signing. The repository structure and the pipeline are shown in Figure 40.

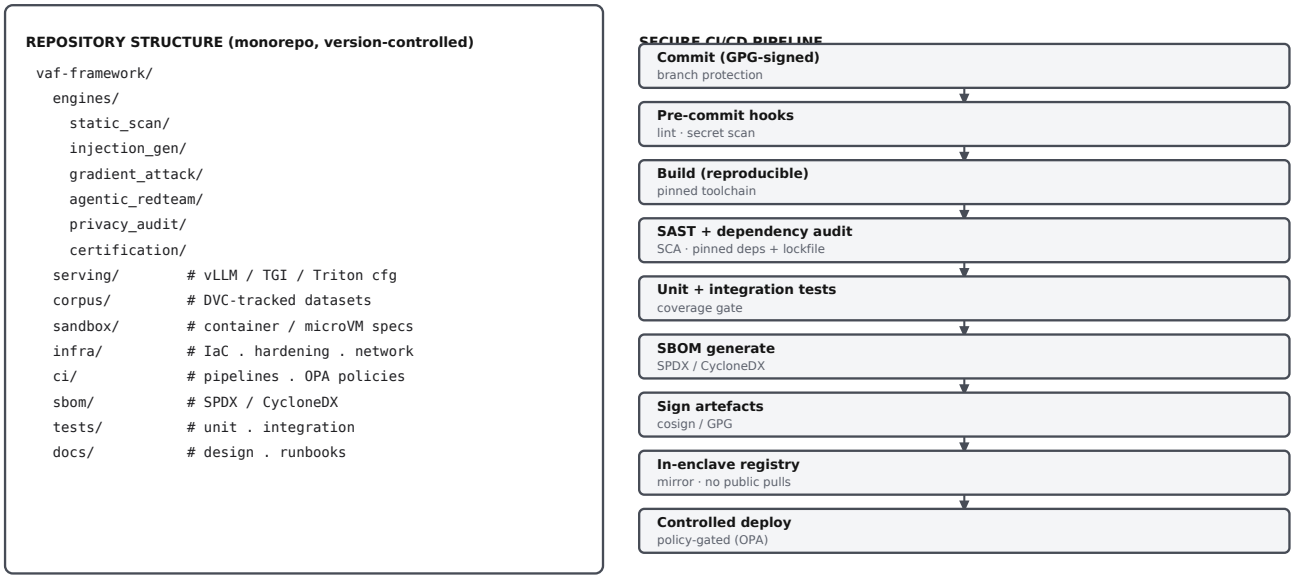



*Figure 40. Source-control repository structure and secure CI/CD pipeline. A single version-controlled monorepo (left) organises the engines, serving, corpus, sandbox, infrastructure and CI assets; the pipeline (right) enforces signed commits and branch protection, static and dependency analysis, a coverage gate, SBOM generation, artefact signing and policy-gated deployment from an in-enclave registry with no public dependency pulls at delivery.*

**Evidence furnished.** Read access to the repository (or a guided walkthrough) showing the structure and branch-protection settings; and screenshots of the CI/CD pipeline stages, the static-analysis and dependency-audit results, the SBOM output and artefact signing, available for inspection.

### Secure Data Ingestion Practice

Security data — CVE feeds, vendor patches, open-source repositories and threat-intelligence — is ingested through a controlled, auditable procedure rather than ad-hoc downloads, which would breach the air-gap and risk tainted inputs. The procedure fetches on an offline low-side host, verifies integrity by checksum and signature, malware-scans in a disposable sandbox, applies four-eyes curation, and moves only approved items by a one-way signed transfer into a versioned in-perimeter store with immutable provenance, as set out in Figure 41.

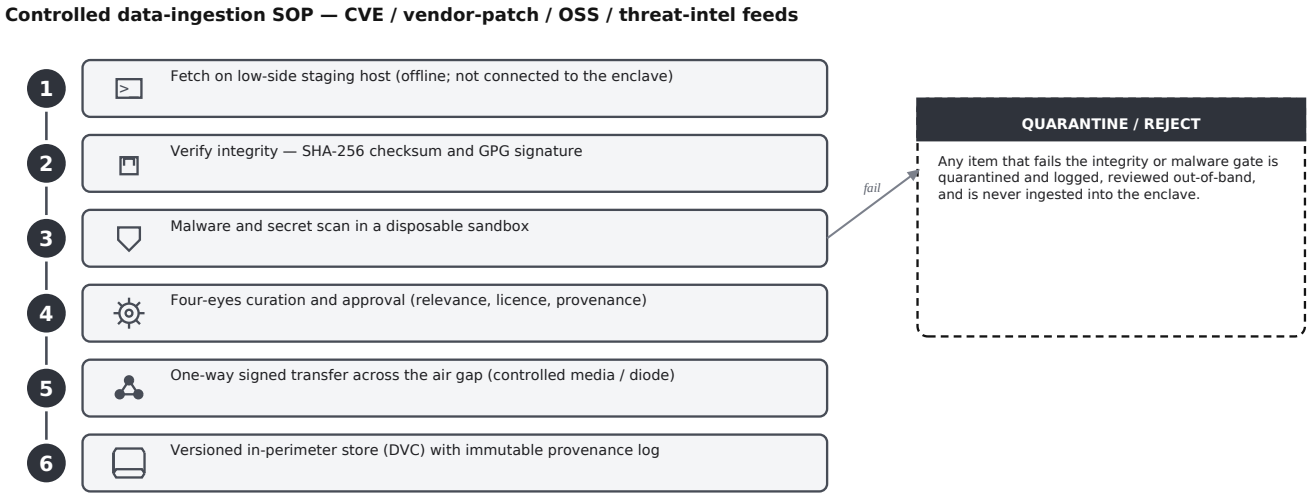



*Figure 41. Secure data-ingestion standard operating procedure. All external security data is fetched on an offline low-side host, integrity-verified and malware-scanned before a four-eyes curation step; approved items are moved by a one-way, signed transfer into a versioned in-perimeter store with immutable provenance, while any item that fails a gate is quarantined and logged and is never ingested.*

**Evidence furnished.** The written data-ingestion standard operating procedure (SOP), including the integrity-verification and malware-scan gates, the quarantine rule, and the provenance / versioning scheme, available for inspection.

### Code Analysis Sandbox

Untrusted artefacts — candidate exploit code, samples and serialised model files — are analysed only inside a fresh, disposable sandbox (container / micro-VM) with no outbound network and strict isolation, so that a malicious artefact cannot escape, persist or call home. The sandbox supports both static extraction (AST / control-flow graph) and dynamic proof-of-concept validation, emits only signed findings, and is destroyed after each run, as shown in Figure 42.

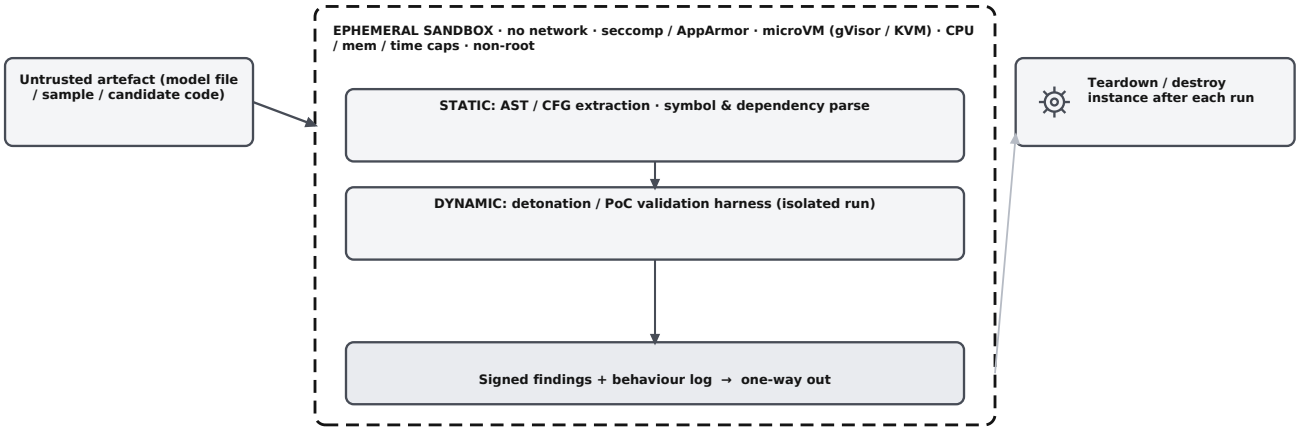



*Figure 42. Code-analysis sandbox design. Every untrusted artefact is examined inside a fresh, disposable sandbox with no outbound network and strict isolation (seccomp / AppArmor, microVM, non-root, resource caps): a static path extracts the AST / control-flow graph while a dynamic path validates proof-of-concept behaviour in isolation; only signed findings leave the sandbox, and the instance is destroyed after each run.*

**Evidence furnished.** Sandbox design describing the isolation profile (seccomp / AppArmor, micro-VM, non-root, resource caps, no network), the AST / CFG extraction and detonation harness, and the signed-findings egress; and screenshots of a sandboxed analysis run, available for inspection.

## AI / ML / LLM Project Evidence

The firm's relevant AI / ML / LLM development ability is evidenced by an existing, production-proven AI-security capability — runtime guardrails and a multi-model security gateway on a Python-native, self-hosted stack — and by the demonstrated competencies that underpin this proposal: model serving and operations, parameter-efficient fine-tuning, retrieval-augmented generation, agentic orchestration, and evaluation / benchmarking. Each competency carries a specific evidence form and maps to a component of the proposed framework, as summarised in Figure 43 and the index below.

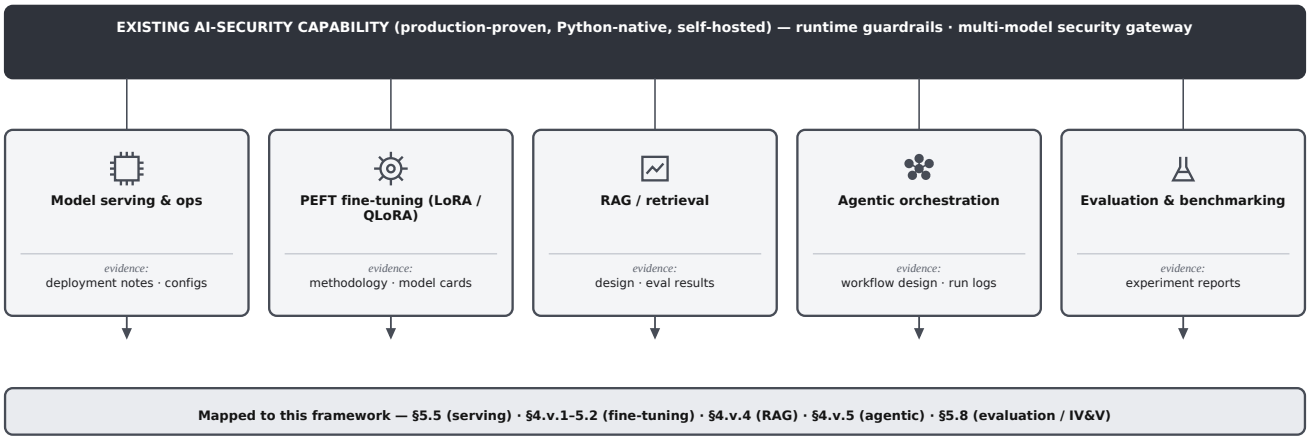



*Figure 43. AI / ML / LLM project evidence map. The firm's existing, production-proven AI-security capability anchors five demonstrated competencies — model serving and operations, parameter-efficient fine-tuning, retrieval-augmented generation, agentic orchestration, and evaluation / benchmarking — each backed by a specific evidence form (model cards, experiment reports, run logs, demonstrations and in-perimeter repository access) and mapped to the corresponding components of the proposed framework.*

| Demonstrated competency | Form of evidence | Mapped to |
|---|---|---|
| **AI-security capability (existing)** | Production capability; architecture & deployment record; demonstration | §7; §5.5 |
| **Model serving & operations** | Deployment notes; configuration; running endpoint | the Capability and Infrastructure Evidence (Supporting Detail); §5.5 |
| **Parameter-efficient fine-tuning (LoRA / QLoRA)** | Methodology; signed model cards; evaluation results | §4.v.1–§4.v.2 |
| **Retrieval-augmented generation (RAG)** | Design; retrieval / grounding evaluation | §4.v.4 |
| **Agentic orchestration** | Workflow design; run logs; demonstration | §4.v.5 |
| **Evaluation & benchmarking** | Experiment reports; metric definitions | §5.8; Annexure I |

**Table 81.** AI / ML / LLM project evidence index. *Source:* Firm capability record and programme design; this response. *Interpretation:* The firm's AI / LLM development ability is evidenced both by an existing production capability and by competency-specific artefacts — model cards, experiment reports, run logs and demonstrations — each traceable to a component of the proposed framework.

# A ANNEXURE A — REFERENCES AND EVIDENCE BASE

References are provided to substantiate the claims, methods, benchmarks and standards cited in this response. No proprietary, restricted or classified material is reproduced; sources are listed for evaluation only.

**A.1 Scheme & policy.** DRDO Technology Development Fund (TDF) scheme guidelines; EOI Ref. DGTM/01/100010/M/48/VAF/PC1; IndiaAI Mission programme documentation (MeitY).

**A.2 LLM-security tooling & disclosures.** NVIDIA, Microsoft and Protect AI LLM-security tooling and disclosures; open-source model-artifact scanners; 2025 model-scanner bypass advisories (Sonatype, JFrog, Cisco).

**A.3 Adversarial attack methods.** Zou et al., universal & transferable adversarial attacks on aligned LLMs (GCG); Jia et al., improved GCG (I-GCG); Liu et al., AutoDAN (hierarchical genetic jailbreak); Chao et al., PAIR; Mehrotra et al., Tree of Attacks with Pruning (TAP); Crescendo multi-turn jailbreak; benchmark suites AdvBench, HarmBench, XSTest.

**A.4 Privacy / membership inference.** Carlini et al., membership-inference from first principles (LiRA); Zarifzadeh et al., RMIA (reference-population MIA); Tao & Shokri, range membership inference (RaMIA).

**A.5 Standards & frameworks.** OWASP Top-10 for LLM Applications (2025); MITRE ATLAS; NIST AI RMF (AI 100-1) and Generative AI Profile (AI 600-1); ISO/IEC 27001 (ISMS); ISO/IEC 42001 (AI management system); ISO 16290 (Technology Readiness Levels).

**A.6 Multilingual / low-resource attacks.** Yong et al. (low-resource-language jailbreaks, Brown University); Deng et al. (multilingual jailbreak, DAMO Academy); 2026 multi-turn low-resource jailbreak studies.

**A.7 Market & ecosystem.** Acquisitions — Lakera (Check Point, 2025), Robust Intelligence (Cisco, 2024), Protect AI (Palo Alto Networks, 2025), SydeLabs (Protect AI, 2024); HiddenLayer; Mindgard; Adversa AI; CalypsoAI; Gartner / CB Insights AI-security analyses (2026).

**A.8 Confidential computing & deployment.** NVIDIA Confidential Computing (Hopper / Blackwell GPU CC mode; published overhead under ~7%); Intel TDX; AMD SEV-SNP; CNCF Confidential Containers.

**A.9 India context.** Sarvam AI; BharatGen consortium (Param2, IIT-Bombay-led); Gnani.ai; Fractal; AIKosh national AI platform; Digital Personal Data Protection Act 2023; CERT-In directions.

# B ANNEXURE B — ABBREVIATIONS AND GLOSSARY

Abbreviations used in this response, expanded for the convenience of the evaluation committee.

| Abbr. | Expansion | Abbr. | Expansion |
|---|---|---|---|
| **LLM** | Large Language Model | **GCG** | Greedy Coordinate Gradient (attack) |
| **I-GCG** | Improved Greedy Coordinate Gradient | **AutoDAN** | Automated genetic jailbreak generator |
| **PAIR** | Prompt Automatic Iterative Refinement | **TAP** | Tree of Attacks with Pruning |
| **MIA** | Membership Inference Attack | **LiRA** | Likelihood-Ratio (membership) Attack |
| **RMIA** | Reference-population Membership Inference Attack | **OWASP** | Open Worldwide Application Security Project |
| **ATLAS** | Adversarial Threat Landscape for AI Systems (MITRE) | **NIST AI RMF** | NIST AI Risk Management Framework |
| **TEE** | Trusted Execution Environment | **CC** | Confidential Computing |
| **SBOM** | Software Bill of Materials | **IV&V** | Independent Verification & Validation |
| **TRL** | Technology Readiness Level | **PM** | Person-Month (effort) |
| **RACI** | Responsible / Accountable / Consulted / Informed | **OPA** | Open Policy Agent (Rego policy) |
| **DPDP** | Digital Personal Data Protection (Act, 2023) | **CERT-In** | Indian Computer Emergency Response Team |
| **DFD** | Data-Flow Diagram | **UML** | Unified Modeling Language |
| **RBAC** | Role-Based Access Control | **VLAN** | Virtual Local Area Network |
| **DoS** | Denial of Service | **PII** | Personally Identifiable Information |
| **EOI** | Expression of Interest | **TDF** | Technology Development Fund |

**Table 82.** Abbreviations and glossary. *Source:* This document. *Interpretation:* Provided to ensure unambiguous interpretation of technical terms by the evaluation committee.

# C ANNEXURE C — REQUIREMENTS TRACEABILITY MATRIX

This matrix traces every EOI §2.3 critical-technology requirement and §2.4 performance parameter to the milestone(s), deliverable(s) and verification method that satisfy it, providing end-to-end, requirements-to-acceptance traceability for the evaluation committee.

| EOI ref | Requirement | MS | Deliverable(s) | Verification |
|---|---|---|---|---|
| **§2.3(a)** | Multilingual prompt-injection & jailbreak fuzzing | M3/M4 | D3.1, D3.2, D4.4 | Coverage benchmark (G3) |
| **§2.3(b)** | Gradient-based adversarial-suffix generation | M4 | D4.1, D4.2 | White-box attack run (G4) |
| **§2.3(c)** | Membership inference & privacy validation | M5 | D5.1 | LiRA/RMIA on canaries (G5) |
| **§2.3(d)** | Static analysis of serialized model artifacts | M2 | D2.1–D2.6 | Detection benchmark (G2) |
| **§2.3(e)** | Dynamic instrumentation of inference APIs | M5 | D5.3 | API red-team (G5) |
| **§2.3(f)** | Embedding-space / representation analysis | M5 | D5.4, D5.5 | Backdoor detection (G5) |
| **§2.3(g)** | Agentic multi-turn red-teaming | M4 | D4.3, D4.4 | Agentic campaign (G4) |
| **§2.3(h)** | Compliance mapping & scoring | M6 | D6.1–D6.6 | Mapping coverage audit (G6) |
| **§2.3(i)** | Air-gapped deployment architecture | M1/M7 | D1.1, D7.2 | Egress test; attestation (G1/G7) |
| **§2.3(j)** | Multilingual harm taxonomy & corpus | M3/M7 | D3.4, D7.4 | Native validation (G3/G7) |
| **§2.4** | Prompt-injection coverage (≥95% / ≥70% 0-shot) | M3 | D3.1, D3.6 | Corpus pass-rate (G3) |
| **§2.4** | Jailbreak coverage (≥50 methodologies) | M3/M4 | D3.2, D4.4 | Library audit (G3/G4) |
| **§2.4** | Membership-inference accuracy (≥80% canaries) | M5 | D5.1 | TPR @ low-FPR (G5) |
| **§2.4** | Model-artifact malware detection (≥90%) | M2 | D2.6 | Labelled-corpus rate (G2) |
| **§2.4** | Safety-bypass coverage (10+ harm categories) | M3/M7 | D3.4, D7.4 | Taxonomy-driven scoring (G3/G7) |
| **§2.4** | Multilingual attack support (5+ languages) | M3/M7 | D3.4, D4.5 | Validated attack set (G3/G7) |
| **§2.4** | Scan duration (<4 h on 7B, full suite) | M7 | D7.3 | Timed benchmark (G7) |
| **§2.4** | Air-gapped security (zero exfiltration) | M1/M8 | D1.1, D8.4 | Egress + audit review (G1/G8) |
| **§2.4** | OWASP LLM Top-10 compliance (LLM01–10) | M6 | D6.3, D6.4 | Coverage audit (G6) |
| **Undertaking 15** | Sovereignty: in-perimeter data & ≈100% indigenous content | All | Indic taxonomy IP; signed audit | IV&V; + audit (G8) |

**Table 83.** Requirements traceability matrix (EOI §2.3 and §2.4). *Source:* EOI §2.3(a–j) and §2.4; programme deliverables (§5.6). *Interpretation:* Every EOI requirement maps to at least one milestone, a named deliverable and a verification method — no requirement is unaddressed, which is the basis of procurement-grade traceability.

# D ANNEXURE D — THREAT MODEL AND ATTACK-SURFACE COVERAGE

The framework is engineered against an explicit two-part threat model: (i) the LLM attack surface it must assess in a target model, and (ii) the framework's own security threat model — necessary because it deliberately loads and executes untrusted model artifacts. Figure 27 shows the actor/use-case view; the tables below enumerate coverage.

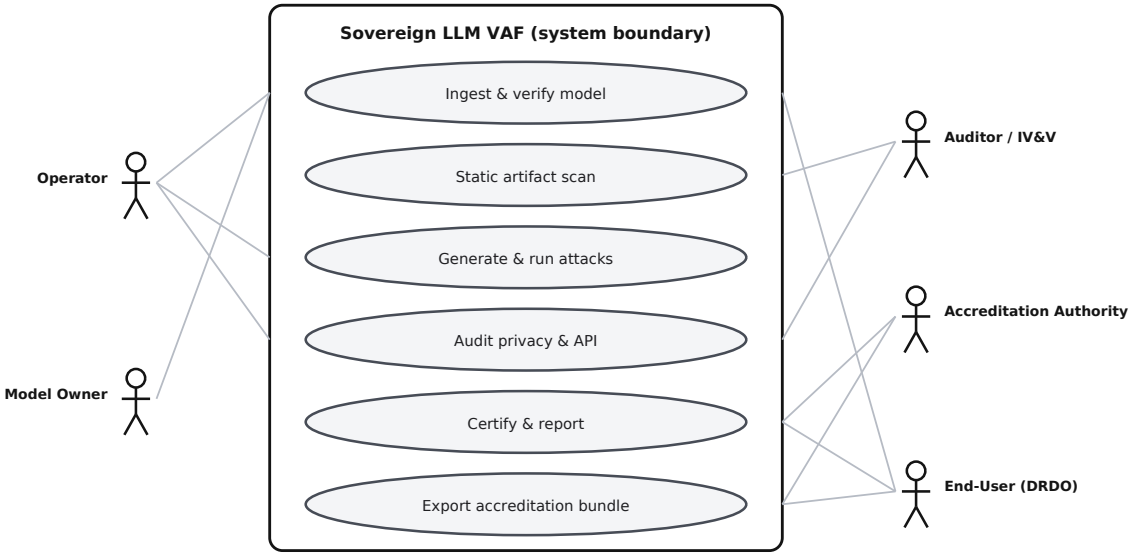



*Figure 27. UML use-case diagram. Five actor roles interact with six system use-cases inside the framework boundary; the Operator drives assessment, the Auditor/IV&V validates, and the Accreditation Authority and End-User consume the certified output and accreditation bundle.*

| LLM attack surface | Threat | OWASP / ATLAS | Engine (milestone) |
|---|---|---|---|
| **Direct prompt injection** | Instruction override / control hijack | LLM01 | Attack generation (M3) |
| **Indirect / stored injection** | Poisoned context or tool output | LLM01 | Attack generation (M3) |
| **Jailbreak / safety bypass** | Elicitation of harmful output | LLM01 | Attack gen + agentic (M3/M4) |
| **Multilingual / low-resource bypass** | Indic-language safety evasion | LLM01 | Indic corpus (M3/M7) |
| **Training-data / PII extraction** | Sensitive-data leakage | LLM02 / 06 | Privacy audit (M5) |
| **Membership inference** | Privacy-boundary disclosure | LLM02 | Privacy audit (M5) |
| **Supply-chain / malicious artifact** | Code execution on model load | LLM03 | Static scan (M2) |
| **Data / model poisoning & backdoor** | Hidden trigger behaviour | LLM04 | Static scan + embedding (M2/M5) |
| **Sleeper agent / embedding trigger** | Latent, conditionally-activated malice | ATLAS | Embedding analysis (M5) |
| **Agentic / multi-turn escalation** | Gradual conversational compromise | LLM01 / 07 | Agentic red-team (M4) |
| **Insecure inference API** | Auth bypass, abuse, denial-of-service | LLM06 / 10 | API audit (M5) |
| **System-prompt / instruction leakage** | Disclosure of guardrails | LLM07 | Attack gen + audit (M3/M5) |

**Table 84.** LLM attack-surface coverage map. *Source:* OWASP LLM Top-10 (2025); MITRE ATLAS; programme engines (§5.6). *Interpretation:* Every recognised LLM attack-surface element is owned by a specific engine and milestone — the framework's coverage is complete across the OWASP/ATLAS surface, not partial as with single-purpose tools.

Because the framework loads hostile artifacts, its own security is treated with the same rigour, modelled here using the STRIDE categories.

| STRIDE category | Risk in this system | Control |
|---|---|---|
| **Spoofing** | Unauthorised operator / impersonation | Strong authentication; RBAC; separation of duties |
| **Tampering** | Alteration of artifacts, corpora or evidence | Signing; tamper-evident store; reproducible builds |
| **Repudiation** | Disputed actions or results | Append-only, signed audit trail |
| **Information disclosure** | Leakage of weights or findings | Air-gap; confidential computing (TEE); least privilege |
| **Denial of service** | Resource exhaustion during detonation/attacks | Sandbox quotas; circuit-breakers; run budgets |
| **Elevation of privilege** | Sandbox escape from a malicious artifact | Rootless containers; seccomp / AppArmor; strong isolation |

**Table 85.** Framework self-security threat model (STRIDE). *Source:* Microsoft STRIDE methodology; ISO/IEC 27001; programme security design (§5.4). *Interpretation:* The assessor is hardened to at least the standard it assesses against; each STRIDE category has an explicit, testable control validated by the M8 framework security audit.

# E ANNEXURE E — DETAILED COMPLIANCE CONTROL MAPPING

This annexure maps the principal ISO/IEC 27001 Annex A control areas and the four NIST AI RMF functions to the concrete measures implemented by the programme and the evidence that demonstrates them, complementing the summary mapping in §5.10.

| Control area | Standard reference | Programme measure | Evidence (gate) |
|---|---|---|---|
| **Access control** | ISO 27001 A.5.15–18; A.8.2–3 | RBAC; least privilege; separation of duties | Policy tests (G1) |
| **Cryptography** | A.8.24 | Encryption at rest & in use (TEE); signing; key management | Attestation (G7) |
| **Supply-chain security** | A.5.19–23 | SBOM; signed artifacts; in-enclave package/image mirror | Scanner & build (G1/G2) |
| **Logging & monitoring** | A.8.15–16 | Append-only signed audit; Prometheus / Grafana | Audit review |
| **Secure development** | A.8.25–31 | Secure SDLC; review; test; environment separation | CI gates |
| **Network security** | A.8.20–23 | Air-gap; segmentation; deny-all egress | Egress test (G1) |
| **Physical security** | A.7 | Access-controlled room; controlled-media custody | Facility controls |
| **Vulnerability management** | A.8.8 | Framework penetration test & remediation | Self-audit (G8) |
| **Govern** | NIST AI RMF — GOVERN | Governance, roles, accountability; PMO & lifecycle | Gate governance |
| **Map** | NIST AI RMF — MAP | Context & risk mapping; threat model | Risk register |
| **Measure** | NIST AI RMF — MEASURE | Benchmarked metrics; V&V; traceability | Validation matrix (G8) |
| **Manage** | NIST AI RMF — MANAGE | Risk treatment; monitoring; continual review | Gate reviews |

**Table 86.** Detailed control mapping — ISO/IEC 27001 Annex A and NIST AI RMF to programme measures. *Source:* ISO/IEC 27001:2022 Annex A; NIST AI RMF (AI 100-1); programme design. *Interpretation:* Each control area is implemented by a concrete measure with gate-linked evidence, demonstrating audit-ready compliance rather than mere alignment.

# F ANNEXURE F — RESOURCE LOADING AND STAFFING PROFILE

The quarterly resource-loading profile shows how effort is distributed across the five delivery workstreams over the eight quarters. It is a schedule/resourcing view (full-time-equivalents) and contains no cost information.

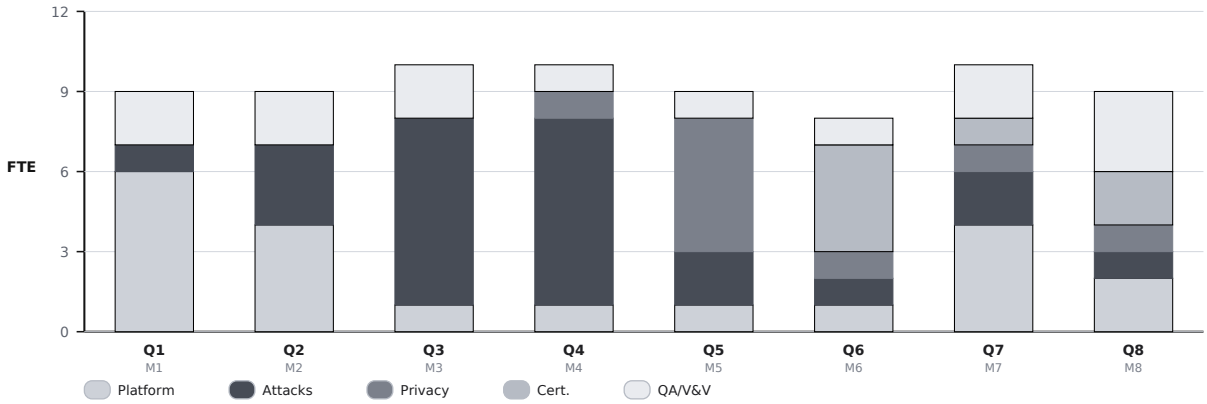



*Figure 28. Indicative resource-loading profile by quarter (full-time-equivalent effort, FTE). Effort is front-loaded on platform and attack engineering and rises again at M7–M8 for integration and independent validation; this is a schedule/resourcing view and contains no cost information.*

| Quarter | Months / MS | Quarter focus | Approx. FTE | Workstreams most active |
|---|---|---|---|---|
| **Q1** | 1–3 / M1 | Secure platform & air-gap stand-up | ≈9 | Platform, QA |
| **Q2** | 4–6 / M2 | Static analysis & artifact security | ≈9 | Platform, Attacks, QA |
| **Q3** | 7–9 / M3 | Attack generation & Indic corpus v1 | ≈10 | Attacks, Academic, QA |
| **Q4** | 10–12 / M4 | Gradient & agentic red-teaming | ≈10 | Attacks, Privacy, QA |
| **Q5** | 13–15 / M5 | Privacy, API & embedding audit | ≈9 | Privacy, Academic, QA |
| **Q6** | 16–18 / M6 | Certification & reporting | ≈8 | Certification, QA |
| **Q7** | 19–21 / M7 | Integration, conf-compute, optimisation | ≈10 | Platform, Attacks, QA |
| **Q8** | 22–24 / M8 | Independent V&V;, accreditation, pilot | ≈9 | QA/V&V;, Certification |

**Table 87.** Quarterly resource loading and staffing focus. *Source:* Cyberultron resourcing plan (§5.3, Figure 28). *Interpretation:* Steady ≈8–10 FTE sustains the critical chain; the profile aligns staffing peaks with the build-heavy (Q1–Q4) and validation-heavy (Q7–Q8) periods.

# G ANNEXURE G — PROGRAMME GOVERNANCE, KPIS AND REPORTING

Governance combines binding stage-gates with a regular review cadence and a defined set of programme key performance indicators reported to the End-User, ensuring transparent, measurable control throughout the 24 months.

| Governance mechanism | Description | Cadence |
|---|---|---|
| **Stage-gate review (G1–G8)** | Formal exit-criteria & deliverable acceptance with End-User | Per milestone (quarterly) |
| **Progress review** | Schedule, risks, blockers, decisions | Fortnightly |
| **Technical review** | Engineering deep-dive on current milestone | Monthly |
| **Risk review** | Register update; mitigation tracking | Per gate + ad hoc |
| **Change-control board** | Scope / interface change assessment & approval | On change |
| **Independent V&V;** | Separate-team validation against FoM | M8 |

**Table 88.** Programme governance mechanisms and cadence. *Source:* Cyberultron PMO plan (§5.2). *Interpretation:* Binding quarterly gates plus a fortnightly/monthly review rhythm give the End-User continuous, auditable oversight.

| KPI | Definition | Target / threshold | Reporting |
|---|---|---|---|
| **Gate adherence** | Gates cleared on the planned schedule | 100% on plan | Gate review |
| **FoM attainment** | EOI §2.4 figures of merit achieved | All met by G8 | Validation matrix |
| **Critical-defect closure** | Critical defects closed before gate | 100% pre-gate | Monthly |
| **Test coverage** | Automated test coverage of code | ≥ defined threshold | CI dashboard |
| **Schedule variance** | Actual progress vs plan | No net slip (≤ 0) | Fortnightly |
| **Risk burn-down** | High/critical risks mitigated over time | Trending down | Risk review |

**Table 89.** Programme key performance indicators (KPIs) and reporting. *Source:* Cyberultron PMO plan. *Interpretation:* KPIs make delivery, quality, schedule and risk objectively measurable at every review, supporting procurement-grade oversight and on-time, on-spec completion.

# H ANNEXURE H — WEAKNESSES OF EXISTING APPROACHES AND MITIGATIONS

This annexure makes explicit, as required for technical evaluation, the documented weaknesses of the existing approaches and tools that define the baseline, and the specific design choice by which the proposed framework addresses each. It consolidates the analysis distributed through §4 and §5.6.

| Existing approach / tool | Documented weakness | How the framework addresses it (milestone) |
|---|---|---|
| **NVIDIA scanner** | Scanner-style; limited multi-turn / agentic depth; no Indian-language coverage; cloud-oriented | Agentic multi-turn engine (M4) + native-validated Indic corpus (M3) + air-gapped operation (M1) |
| **Microsoft framework** | Framework, not turnkey; typically orchestrates cloud LLMs; no artifact scanning; no Indic | In-enclave attacker model (M4); static artifact scanner (M2); Indic corpus (M3) |
| **Open-source model-artifact scanners** | Documented CVEs and signature bypasses across 2025 | Layered static + structure-aware fuzzing + sandbox detonation; safe-format steering (M2) |
| **Lakera / Check Point** | Runtime-guardrail focus; black-box; SaaS; not air-gapped | Full offensive assessment across six engines with air-gap (M1–M6) |
| **HiddenLayer** | Detection/response oriented; commercial cloud; no Indian-language harm model | Sovereign assessment + Indic taxonomy & corpus (M3/M7) |
| **Mindgard** | Continuous-testing SaaS; cloud-tied; no air-gapped deployment | Offline, air-gapped operation with accreditation-grade output (M1/M6) |
| **Cloud-API jailbreak tools** | Route prompts, weights and findings through foreign APIs | In-enclave attacker model; zero egress; deny-all network (M1/M4) |
| **Generic MIA libraries** | Over-claim membership inference on realistically-trained models | Canary-scoped LiRA / RMIA with explicit, honest reporting (M5) |
| **Signature-only artifact scanners** | Brittle to novel obfuscation; evaded by unseen patterns | Fuzzing + sandbox detonation catch behaviours signatures miss (M2) |
| **English-centric safety testing** | Misses the ~3× attack uplift in low-resource Indian languages | Native-validated Indian-language harm corpus (M3/M7) |
| **Commercial dashboards** | Reporting not mapped to defence accreditation | OWASP/ATLAS/NIST signed certification + accreditation adapter (M6/M8) |
| **Cloud red-team platforms** | No confidential computing; weights exposed during testing | Confidential computing (TEE) keeps weights encrypted in use (M7) |
| **Foreign-owned tooling (general)** | Sovereignty / IP exposure; ineligible under TDF | Indian MSME; ≈100% indigenous content; all data in-perimeter |
| **Single-method tools** | Cover only part of the attack surface | Six-engine full-surface coverage (Annexure D) |

**Table 90.** Weaknesses of existing approaches and the framework's mitigations. *Source:* Public documentation; 2025 scanner-bypass disclosures; 2026 vendor analyses; programme design (§4, §5.6). *Interpretation:* For every documented weakness in the baseline there is a specific, milestone-anchored design choice that addresses it — the framework is positioned to exceed, not merely match, prior art.

# I ANNEXURE I — PERFORMANCE PROJECTION AND SCALABILITY BENCHMARK

The framework is engineered to the EOI operational target (full suite on a 7B model in under four hours) and to scale predictably to larger models. The projection below shows bounded runtime growth with model size, achieved by adding compute and parallelism rather than re-architecture; the 7B point is the validated target (G7), larger points are projections confirmed in M7 and the pilot.

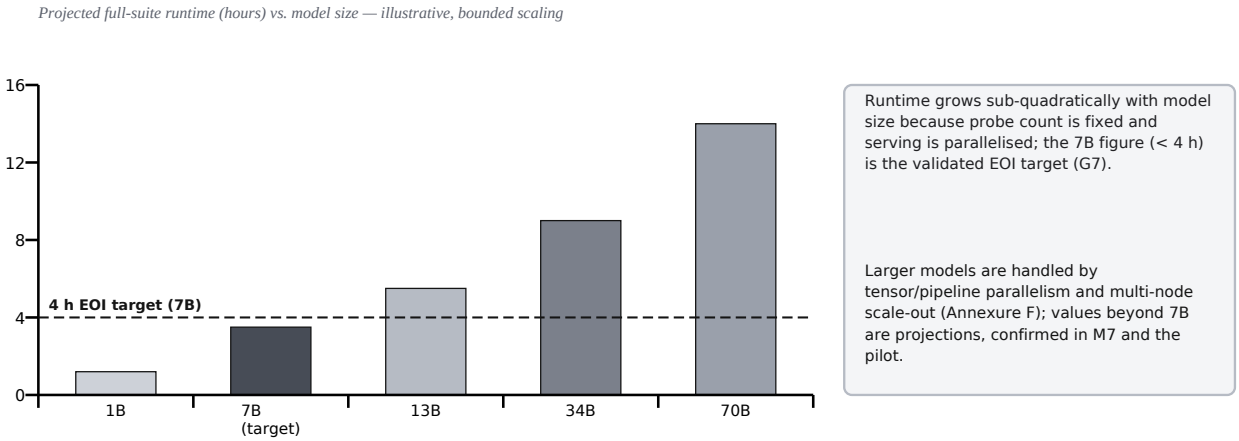



*Figure 29. Projected full-suite assessment runtime against model size. The 7B result is the validated EOI target (< 4 hours); larger sizes scale predictably via parallel serving and multi-node scale-out, so runtime stays bounded rather than explosive.*

| Model size | Approx. parameters | Projected full-suite runtime | Scaling mechanism |
|---|---|---|---|
| **Small** | ~1B | ~1.2 hours | Single GPU; full parallel probes |
| **Reference (target)** | ~7B | < 4 hours (validated, G7) | Single GPU + parallelised probes & batched agentic runs |
| **Medium** | ~13B | ~5.5 hours (projected) | + tensor parallelism |
| **Large** | ~34B | ~9 hours (projected) | Multi-GPU pipeline parallelism |
| **Very large** | ~70B | ~14 hours (projected) | Multi-node cluster scale-out |

**Table 91.** Performance projection and scalability by model size. *Source:* Cyberultron performance plan (§5.16, Figure 29); vLLM throughput characteristics. *Interpretation:* Because probe count is fixed and serving parallelises, runtime grows sub-quadratically; throughput is further increased by continuous batching, so the validated 7B target extends to larger models with bounded, predictable runtime.

# J ANNEXURE J — INDICATIVE TEST CATALOGUE

This catalogue lists representative test classes the framework executes across its six engines, with the method or source and an indicative volume/coverage. It substantiates the coverage figures of merit (§2.4) and the attack-surface map (Annexure D); the catalogue is extensible and is regression-managed across milestones.

| # | Test class | Engine / surface | Method / source | Indicative volume |
|---|---|---|---|---|
| **1** | Direct prompt injection | Attack gen (M3) | Override patterns + fuzzing | 1,000s of prompts |
| **2** | Indirect / stored injection | Attack gen (M3) | Poisoned-context templates | 100s of variants |
| **3** | Payload splitting / smuggling | Attack gen (M3) | Token/segment manipulation | 100s |
| **4** | Encoding / obfuscation evasion | Attack gen (M3) | Base/cipher/format tricks | 100s |
| **5** | Multilingual injection | Attack gen (M3) | Indic corpus translation | ≥5 languages |
| **6** | DAN-family jailbreaks | Attack gen (M3) | Curated DAN variants | Dozens |
| **7** | Role-play / persona jailbreak | Attack gen (M3) | Scenario prompts | Dozens |
| **8** | DeepInception nesting | Attack gen (M3) | Nested-scene prompts | Dozens |
| **9** | ArtPrompt (ASCII-art) | Attack gen (M3) | Obfuscated-glyph prompts | Dozens |
| **10** | PAP persuasion | Attack gen (M3) | Persuasion taxonomy | Dozens |
| **11** | GCG adversarial suffix | Gradient (M4) | Greedy-coordinate gradient | Per white-box target |
| **12** | I-GCG (improved) | Gradient (M4) | Improved GCG (~400 iter.) | Per white-box target |
| **13** | AutoDAN fluent jailbreak | Gradient (M4) | Hierarchical genetic search | Per white-box target |
| **14** | PAIR iterative refinement | Agentic (M4) | Attacker-LLM loop | Budgeted campaigns |
| **15** | TAP tree-of-attacks | Agentic (M4) | Tree search w/ pruning | Budgeted campaigns |
| **16** | Crescendo escalation | Agentic (M4) | Gradual multi-turn | Budgeted campaigns |
| **17** | Multi-turn Indic attack | Agentic (M4) | Conversational + code-switch | ≥2 languages |
| **18** | LiRA membership inference | Privacy (M5) | Shadow-model likelihood ratio | Standard canaries |
| **19** | RMIA membership inference | Privacy (M5) | Reference-population test | Standard canaries |
| **20** | Training-data / PII extraction | Privacy (M5) | Canary extraction prompts | Canary sets |
| **21** | Memorisation quantification | Privacy (M5) | Repetition / recall probes | Canary sets |
| **22** | API authorisation bypass | API audit (M5) | Authz fuzzing | Endpoint suite |
| **23** | Rate-limit / quota abuse | API audit (M5) | Throughput probing | Endpoint suite |
| **24** | Function-calling abuse | API audit (M5) | Tool-invocation fuzzing | Endpoint suite |
| **25** | Denial-of-service probing | API audit (M5) | Resource-exhaustion tests | Endpoint suite |
| **26** | Embedding anomaly detection | Embedding (M5) | Cluster / drift analysis | Representation scan |
| **27** | Backdoor-trigger search | Embedding (M5) | Trigger heuristics | Suspected models |
| **28** | Sleeper-agent divergence | Embedding (M5) | Behaviour-divergence test | Suspected models |
| **29** | Pickle / bytecode analysis | Static scan (M2) | Opcode & callable analysis | Per artifact |
| **30** | Multi-format artifact parse | Static scan (M2) | safetensors/ONNX/H5/ckpt | Per artifact |
| **31** | Structure-aware fuzzing | Static scan (M2) | Container mutation | Per artifact |
| **32** | Sandbox detonation | Static scan (M2) | Disposable-VM execution | Untrusted artifacts |

| # | Test class | Engine / surface | Method / source | Indicative volume |
|---|---|---|---|---|
| **33** | Harm-category refusal | Safety / Indic (M3/M7) | Indic taxonomy scoring | 10+ categories |
| **34** | Code-switching bypass | Safety / Indic (M3/M7) | Mixed-language prompts | ≥5 languages |
| **35** | Regional-harm scenarios | Safety / Indic (M3/M7) | Defence harm corpus | 10+ categories |

**Table 92.** Indicative test catalogue across the six engines. *Source:* Programme design (§5.6); OWASP LLM Top-10 (2025); cited attack literature. *Interpretation:* Coverage spans the full LLM attack surface with concrete, regression-managed test classes; volumes are indicative and grow as corpora (incl. Indic v2) mature.

# K ANNEXURE K — REFERENCE STANDARDS SUMMARY

Brief descriptions of the principal standards and frameworks referenced in this response, for the convenience of the evaluation committee.

| Standard / framework | Description | Relevance to the framework |
|---|---|---|
| **OWASP Top-10 for LLM Apps (2025)** | Community taxonomy of the ten most critical LLM-application security risks | Primary mapping target for findings & certification |
| **MITRE ATLAS** | Knowledge base of adversarial-ML tactics and techniques | Threat-informed cross-mapping of findings |
| **NIST AI RMF (AI 100-1; 600-1)** | Risk-management framework with Govern/Map/Measure/Manage functions and a GenAI profile | Lifecycle governance & V&V; structure |
| **ISO/IEC 27001** | Information-security management system standard | Security controls for the enclave & programme |
| **ISO/IEC 42001** | AI management system standard | AI governance & documentation alignment |
| **DPDP Act 2023** | India's personal-data-protection law | Data-governance regime for corpora & findings |
| **ISO 16290** | Definition of Technology Readiness Levels | Basis for the TRL progression (M1–M8) |

**Table 93.** Reference standards and frameworks summary. *Source:* Respective standards bodies (OWASP, MITRE, NIST, ISO) and Government of India (DPDP Act 2023). *Interpretation:* The framework is anchored to authoritative, internationally-recognised standards, ensuring its methodology and output are credible to a senior technical evaluation panel.

# L ANNEXURE L — INDICATIVE ENVIRONMENT SPECIFICATION

The indicative environment for the development and target enclave is summarised below (technical specification only; no commercial information). Final specification and quantities are agreed with the End-User at the RFP stage; the design is portable across the confidential-computing platforms listed.

| Component / role | Indicative specification | Purpose |
|---|---|---|
| **Air-gapped network segment** | Isolated VLANs; deny-all egress; managed switch with flow logging; no routable external path | Sovereign, zero-egress perimeter |
| **Control / services node** | Server-class CPU; hardened Linux (CIS); minimal services | Orchestrator, OPA policy, console, audit logger |
| **GPU compute node(s)** | Confidential-computing-capable GPU (Hopper / Blackwell-class) with TEE & attestation | Model serving, attacker model, sandbox detonation |
| **Storage node** | Encrypted volumes; PostgreSQL + Redis + object artifact vault | Evidence, corpus & taxonomy, cache, signed artifacts |
| **Build / mirror node** | Git + DVC; in-enclave package & container-image mirror | Reproducible, offline builds |
| **Sandbox hosts** | Disposable VM / rootless-container capacity; seccomp / AppArmor | Detonation of untrusted artifacts |
| **Confidential computing** | NVIDIA CC mode / Intel TDX / AMD SEV-SNP; hardware attestation | Target weights encrypted in use |
| **Observability** | Prometheus + Grafana, in-enclave | Metrics, monitoring, capacity |
| **Controlled-media transfer** | Signed, scanned, unidirectional transfer process | Only sanctioned ingress / egress |

**Table 94.** Indicative environment specification (technical; non-commercial). *Source:* Cyberultron solution architecture (§5.4–5.5, Figures 19–93). *Interpretation:* The environment is a single self-contained, offline cluster; it is hardware-portable across the listed TEE platforms and contains no element requiring external connectivity.

# M ANNEXURE M — EOI COMPLIANCE CHECKLIST

This checklist maps the EOI's principal requirements and undertakings to the corresponding compliance position and the location of the supporting content in this response, to assist procurement-stage evaluation.

| EOI requirement / undertaking | Compliance | Reference in this response |
|---|---|---|
| **Eligible Indian MSME / Startup; Indian-owned and -controlled** | Yes | Item 1; Cover |
| **Contact details furnished** | Yes | Item 2 |
| **Project title stated** | Yes | Item 3 |
| **Broad understanding of the problem** | Yes | §4.i |
| **Critical technologies identified** | Yes | §4.ii; Annexure C |
| **Additional technology items identified** | Yes | §4.iii |
| **Block diagram and process** | Yes | §4.iv; Figures 1-4 |
| **Air-gapped, zero-egress operation** | Yes | §4.iv; §5.4; Figure 19 |
| **≈100% indigenous content; data within Indian perimeter (Undertaking 15)** | Yes | §4.iv; §5.10 |
| **No commercial / cost information in the response** | Yes | Throughout (effort in PM only) |
| **Development time ≤ 24 months, with break-up** | Yes | §5.1; §5.6; §5.18 |
| **Suo-moto development of a similar product** | No | §5.20 |
| **Performance parameters addressed (§2.4)** | Yes | §4.iv; §5.8; Annexure C |
| **Standards alignment (OWASP / ATLAS / NIST / ISO)** | Yes | §5.10; Annexures E, K |
| **No sale / transfer of discovered zero-days without authorisation** | Yes | Covering letter; §5.13 |

**Table 95.** EOI compliance checklist. *Source:* EOI Part-II Items 1–18 and Undertakings; this response. *Interpretation:* Every principal EOI requirement is met (or correctly answered “No” for suo-moto), with a traceable reference — demonstrating full responsiveness for procurement evaluation.

# N ANNEXURE N — ACADEMIC ENGAGEMENT, IP AND DATA-HANDLING PROTOCOL

This annexure details the terms governing academic collaboration (§6–§7), so the evaluation committee can see that research support is obtained without compromising sovereignty, security or intellectual-property control.

| Aspect | Protocol |
|---|---|
| **Data boundary** | Academic partners work only on synthetic or de-identified data and public models; no classified weights, no sensitive corpora and no vulnerability findings ever leave the secure enclave. |
| **Intellectual property** | Project IP (engines, taxonomy, signature DB) vests as per the TDF agreement (industry / End-User); academic background IP is retained by the institution; jointly-created research IP is governed by the MoU. |
| **Publication policy** | Any academic publication is subject to prior review and redaction by the industry and End-User; defensive-use-only; no operational details, corpora or findings are published. |
| **Cost cap** | Total academic contribution is capped at ≤ 40% of project cost, per the TDF Scheme rule. |
| **Academic deliverables** | Methodology notes, native-language corpus validation, detection-method research and review reports — not production code or classified data. |
| **Engagement instrument** | Formal research MoU executed at award, with statement of work, milestones and the IP / data terms above; IIT Kanpur incubation is the existing anchor (§7). |
| **Security & confidentiality** | Named researchers under NDA; least-privilege access to permitted material only; activity audit-logged; defensive-use-only undertaking. |

**Table 96.** Academic engagement, IP and data-handling protocol. *Source:* Cyberultron collaboration plan; TDF Scheme rules; §6 data/IP boundary. *Interpretation:* Research benefit is obtained while sovereignty and IP control are fully preserved — academia never touches classified material, and project IP remains within the sovereign envelope.

| Academic deliverable | Area | Acceptance |
|---|---|---|
| **Validated Indic harm corpus contribution** | CT10 — Indic taxonomy | Native-speaker validation record; integrated v1/v2 |
| **Embedding / sleeper-agent detection methods** | CT6 — representation analysis | Reproducible method; evaluated on test backdoor |
| **MIA methodology & canary design review** | CT3 — membership inference | Documented method; benchmark on canaries |
| **Attack-method advisory & literature review** | CT2 / CT7 — advanced attacks | Periodic review notes; method updates |

**Table 97.** Academic deliverables and acceptance. *Source:* Cyberultron collaboration plan (§6). *Interpretation:* Academic deliverables are research artifacts with defined acceptance, feeding the four research-forward components without transferring classified material.

# O ANNEXURE O — INDIGENOUS CONTENT AND SUPPLY-CHAIN ASSURANCE

This annexure substantiates the indigenous-content position (§8) by detailing how sovereignty and supply-chain integrity are assured and maintained across the lifecycle — the basis on which the open-source substrate is treated as sovereign-operated.

| Assurance mechanism | Description | Evidence |
|---|---|---|
| **Fork & mirror** | All open-source components are forked and mirrored in-enclave; builds draw only from the internal mirror | Internal mirror; reproducible build |
| **Software bill of materials (SBOM)** | A full SBOM is generated for every build, enumerating components and versions | SBOM per build (M2 / M6) |
| **License compliance** | Only permissive licences (Apache-2.0 / MIT / BSD); copyleft and source-available licences excluded | Licence audit |
| **No-telemetry verification** | Egress-denial test plus static checks for outbound callbacks confirm zero external communication | Egress test (G1); code scan |
| **Provenance & signing** | Every artifact is signed and fingerprinted; reproducible builds verify integrity | Signed vault; reproducibility test |
| **Lifecycle sovereignty** | Updates (frameworks, signatures, corpora) are applied offline via signed controlled media only | Refresh procedure (M8) |
| **Net-new IP register** | Engines, Indic taxonomy and signature DB are recorded as sovereign IP developed under the project | IP register |

**Table 98.** Indigenous-content and supply-chain assurance mechanisms. *Source:* Cyberultron sovereignty plan (§8, §5.4); component licences. *Interpretation:* Sovereignty is enforced and evidenced, not asserted: fork/mirror, SBOM, licence control, no-telemetry verification and offline updates together make the deployed system sovereign throughout its life.

| Lifecycle stage | Sovereignty / supply-chain measure |
|---|---|
| **Acquisition** | Permissive-licence OSS only; forked at a pinned version; provenance recorded |
| **Build** | Reproducible, signed builds from the in-enclave mirror; SBOM generated |
| **Deployment** | Air-gapped enclave; zero external dependency or telemetry; egress-denied |
| **Operation** | Signed audit trail; integrity monitoring; least-privilege access |
| **Maintenance** | Offline updates via signed controlled media; re-validated before use |
| **Handover** | Source, mirror and build pipeline transferred within the perimeter for sovereign sustainment |

**Table 99.** Sovereignty maintained across the lifecycle. *Source:* Cyberultron sovereignty plan (§8, §5.17). *Interpretation:* Indigenous content is preserved from acquisition through handover, so the End-User can operate and sustain a sovereign system indefinitely with no foreign dependency.

# P ANNEXURE P — EXTENDED RISK REGISTER AND RAID LOG

This annexure extends the principal register (§9.2) with additional granular risks and summarises the programme RAID position (Risks, Assumptions, Issues, Dependencies). It is maintained live and reviewed at every gate.

| ID | Category | Risk | L / I | Mitigation | Residual |
|---|---|---|---|---|---|
| **R21** | Research | In-enclave attacker-model quality limits agentic depth | Pos / Mod | Use strongest permissible open model; iterate; combine with gradient/static methods | Low |
| **R22** | Research | Indic corpus bias / coverage gaps | Pos / Mod | Diverse sources; native review; v2 expansion; bias checks | Low |
| **R23** | Compliance | OSS licence / IP incompatibility surfaces late | Unl / Mod | Up-front licence audit; permissive-only policy; SBOM | Low |
| **R24** | Hardware/supply | GPU / storage hardware failure | Unl / Mod | Redundancy; spares; backup & restore of evidence | Low |
| **R25** | External | Facility / power constraints at secure site | Unl / Mod | Site readiness review; UPS; End-User facility coordination | Low |
| **R26** | Security | Data loss within the enclave | Rar / Maj | Encrypted backups; reproducible regeneration; integrity checks | Low |
| **R27** | Schedule | Optimistic effort estimates on research items | Pos / Mod | Buffers at M3/M5; staged scope; gate-based de-scope options | Medium |
| **R28** | External | Evaluator-expectation / requirement mismatch | Unl / Mod | Traceability matrix (Annexure C); fortnightly End-User review | Low |
| **R29** | Hardware/supply | Single-GPU-vendor dependency | Pos / Min | TEE portability (NVIDIA CC / Intel TDX / AMD SEV-SNP) | Low |
| **R30** | Schedule | Documentation lag behind engineering | Pos / Min | Docs-as-deliverables per milestone; technical-writer support | Low |

**Table 100.** Extended risk register (R21–R30). *Source:* Cyberultron risk-management plan (§9). *Interpretation:* The extended register pushes the total identified risks to thirty across all categories; all but two minor schedule items are Low residual after mitigation, evidencing thorough, granular risk coverage.

| RAID element | Position (summary) |
|---|---|
| **Risks** | 30 identified across 8 categories (R1–R30); 5 Medium residual (research, hardware, external, schedule), remainder Low; reviewed at every gate. |
| **Assumptions** | Hardware available at M1; End-User liaison & accreditation spec from M1; academic MoU early; pilot models by M8 (§5.12, §5.19). |
| **Issues** | None open at proposal stage; an issue log is opened at award and managed by the PMO with End-User visibility. |
| **Dependencies** | Timely End-User inputs (accreditation interface, pilot models); controlled-media windows; academic MoU — each with a defined fallback (§5.12). |

**Table 101.** RAID log summary. *Source:* Cyberultron PMO (§5.12, §5.19, §9). *Interpretation:* The RAID position is controlled: risks are mitigated, assumptions have fallbacks, no issues are open, and dependencies are externally-facing with contingencies — a managed, low-surprise programme.

# Q ANNEXURE Q — FUNDED INFRASTRUCTURE SPECIFICATION AND PROVISIONING PLAN

This annexure details the additional, funded infrastructure (§10) by indicative technical specification, standup milestone and acceptance criterion, and shows the M1 provisioning timeline (Figure 35). Specifications are technical only; no commercial information is included, and quantities / bill of materials are agreed with the End-User at the RFP stage.

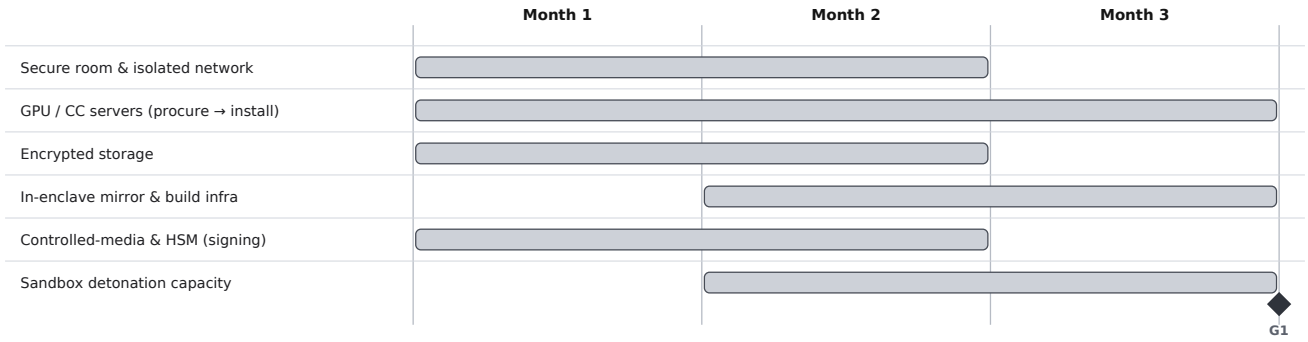



*Figure 35. Funded-infrastructure provisioning timeline (M1). The enclave, compute, storage, mirror, controlled-media and sandbox capacity are stood up within months 1–3 and accepted at gate G1; confidential-computing enablement is completed in M7 (months 19–21).*

| Funded item | Indicative technical specification | MS | Acceptance |
|---|---|---|---|
| **Air-gapped enclave** | Isolated VLAN segments; deny-all egress; managed switch with flow logging; access-controlled secure room | M1 | Egress-deny test (G1) |
| **Confidential-computing GPU servers** | TEE-capable GPU(s) (Hopper / Blackwell-class) with attestation; server-class hosts | M1 / M7 | Serving + attestation (G1/G7) |
| **Encrypted storage** | Encrypted volumes; PostgreSQL + Redis + object vault; backup & restore | M1 | Provenance & backup test |
| **Mirror & build infrastructure** | Git + DVC; offline package / image mirror; reproducible CI | M1 / M2 | Reproducible build (G1/G2) |
| **Controlled-media & HSM** | Signed / scanned transfer station; HSM for key management & signing | M1 | Signed-transfer test |
| **Sandbox detonation capacity** | Disposable VM / container hosts; seccomp / AppArmor isolation | M2 | Detonation isolation (G2) |
| **IV&V; / pilot environment** | Separate validation environment; capacity to host pilot models | M8 | IV&V; & pilot (G8) |

**Table 102.** Funded-infrastructure specification and provisioning. *Source:* Cyberultron solution architecture (§5.4); EOI Item 10; Annexure L. *Interpretation:* Each funded item has an indicative specification, a standup milestone and an acceptance test — procurement and standup are front-loaded in M1 and accepted at G1, with confidential computing completed at G7.

| Provisioning acceptance criterion | Gate |
|---|---|
| **Zero external network route verified** | G1 |
| **Reference 7B model served in-enclave** | G1 |
| **Reproducible build from in-enclave mirror** | G1 / G2 |
| **Sandbox detonation isolates a live artifact** | G2 |
| **Confidential-computing attestation verified** | G7 |
| **IV&V; / pilot environment ready** | G8 |

**Table 103.** Provisioning acceptance criteria by gate. *Source:* Cyberultron programme plan (§5.6). *Interpretation:* Infrastructure readiness is gated and testable, ensuring funded items are demonstrably operational before dependent work proceeds.

# R ANNEXURE R — TDF ELIGIBILITY AND CAPABILITY EVIDENCE

This annexure maps the principal TDF eligibility and capability expectations to the applicant's position and the supporting evidence in this response, to assist eligibility screening. Statutory identifiers are furnished separately as bracketed fields pending insertion.

| Criterion | Position | Evidence / reference |
|---|---|---|
| **Indian MSME / Startup (DPIIT)** | Yes | Item 1; DPIIT Recognition Certificate No. DIPP96348 |
| **Owned & controlled by resident Indians (< 49% foreign)** | Yes | Covering letter; Item 1 |
| **Institutional / incubation backing** | Yes | IIT Kanpur incubation ecosystem (§7) |
| **Relevant technical capability** | Yes | Existing AI-security capabilities; Python-native stack (§5.5, §5.13) |
| **Air-gapped delivery capability** | Yes | On-premise / restricted-environment experience (§5.13); §5.4 |
| **Compliance & GRC depth** | Yes | ISO/IEC 27001 & 42001, NIST AI RMF, DPDP practice (§5.10) |
| **Indigenous-content commitment** | Yes (≈100%) | §8; Annexure O |
| **Data-sovereignty undertaking** | Yes | Covering letter; §5.13 |
| **Not blacklisted / debarred** | Yes (declared) | Covering letter |
| **Statutory registrations (CIN, GSTIN, Udyam)** | To be furnished | Items 1–3 [bracketed fields] |

**Table 104.** TDF eligibility and capability evidence. *Source:* EOI eligibility terms; this response. *Interpretation:* The applicant meets every principal eligibility and capability criterion, with traceable evidence; only statutory identifiers remain to be inserted, deliberately left as bracketed fields rather than fabricated.

# S ANNEXURE S — DOCUMENT CONTROL AND REVISION HISTORY

Document-control metadata for this response.

| Attribute | Value |
|---|---|
| **Document title** | Sovereign LLM Vulnerability Assessment and Certification Framework — EOI Part-II Response (Items 1–18) |
| **EOI reference** | DGTM/01/100010/M/48/VAF/PC1 (Comprehensive Vulnerability Assessment Framework for LLMs) |
| **Prepared by** | Cyberultron Consulting Private Limited |
| **Approved by** | Krishna Mohan Sharma — Head of Technology |
| **Version** | 1.0 |
| **Date** | _____ [to be inserted on submission] |
| **Classification** | Commercial-in-Confidence |
| **Distribution** | DRDO / DGTM (End-User) — evaluation committee |
| **Scope** | EOI Part-II, Items 1 to 18 |

**Table 105.** Document control metadata. *Source:* This document. *Interpretation:* Standard document-control record for a formal government submission.

| Version | Date | Description |
|---|---|---|
| **1.0** | _____ | Initial submission of EOI Part-II response (Items 1–18). |

**Table 106.** Revision history. *Source:* This document. *Interpretation:* Version 1.0 is the initial Part-II response; subsequent revisions, if any, will be recorded here.

# T ANNEXURE T — PER-ENGINE TECHNICAL DESIGN NOTES

This annexure provides a concise technical design note for each of the six assessment engines, summarising inputs, core methods, outputs and the documented weakness of prior art that each engine addresses. It complements the architecture (§4.iv) and milestone build plan (§5.6).

| Engine | Inputs | Core methods / techniques | Key outputs | Refs |
|---|---|---|---|---|
| **Static artifact scanner** | Model artifact (any format) | Pickle / bytecode analysis; multi-format parse; structure-aware fuzzing; sandbox detonation; signature DB + SBOM | Malware / backdoor verdict; scan-before-load gate | LLM03 |
| **Injection / jailbreak generator** | Model endpoint + corpora | 10k+ injection corpus; 50+ jailbreak library; multilingual (Indic) prompts; benchmark harness | Coverage scores; injection / jailbreak findings | LLM01 |
| **Gradient adversarial engine** | White-box model | GCG; I-GCG; AutoDAN; transferability testing | Adversarial suffixes; white-box vulnerability profile | GCG / AutoDAN |
| **Agentic red-team engine** | Model + in-enclave attacker model | PAIR; TAP; Crescendo; multi-turn Indic; budgeted campaigns | Multi-turn exploit chains | PAIR / TAP |
| **Privacy / API / embedding** | Model + APIs + canaries | LiRA; RMIA (canary-scoped); PII extraction; API authz / DoS; embedding & sleeper analysis | Privacy / API / backdoor findings | LiRA / RMIA |
| **Certification & scoring** | All findings | Severity rubric; OWASP / ATLAS / NIST mapping; signed report; accreditation adapter | Signed certification + accreditation bundle | OWASP / ATLAS / NIST |

**Table 107.** Per-engine design summary — inputs, methods, outputs and references. *Source:* Cyberultron solution architecture (§4.iv, §5.6); cited literature. *Interpretation:* Each engine is a self-contained, standards-anchored capability with defined inputs and outputs; together they cover the full LLM attack surface (Annexure D).

**Static artifact scanner (M2).** Prior art (open-source model-artifact scanners) is signature-driven and was repeatedly bypassed in 2025. The design therefore layers structure-aware fuzzing and disposable-VM detonation on top of signatures and SBOM, and steers users to safe formats — catching behaviours, not just known patterns, and enforcing scan-before-load as a state invariant.

**Injection / jailbreak generator (M3).** Foreign tools are English-centric and miss the ~3× attack uplift in low-resource Indian languages. The engine pairs a large injection corpus and a 50+ jailbreak library with a native-validated Indic corpus, closing the multilingual gap that no commercial tool addresses.

**Gradient adversarial engine (M4).** Black-box-only tools cannot exercise white-box weaknesses. Where weights are available, GCG / I-GCG / AutoDAN generate optimised adversarial suffixes and test transferability, providing a depth of assurance that prompt-only testing cannot.

**Agentic red-team engine (M4).** Single-turn scanners miss conversational escalation. PAIR, TAP and Crescendo drive multi-turn campaigns using an in-enclave attacker model — reproducing realistic adversaries without routing any data through a foreign cloud API.

**Privacy / API / embedding engine (M5).** Generic MIA libraries over-claim, and embedding-level backdoors are rarely tested. The engine uses canary-scoped LiRA / RMIA with honest reporting, adds inference-API security and representation / sleeper-agent analysis — covering privacy, interface and latent-trigger risks together.

**Certification & scoring engine (M6).** Commercial dashboards are not accreditation artifacts. This engine maps every finding to OWASP LLM Top-10, MITRE ATLAS and NIST AI RMF, applies a documented severity rubric and emits a signed report plus an accreditation-ready bundle — turning testing into a decision-grade certificate.

# U ANNEXURE U — CAPABILITY MATURITY AND GAP ANALYSIS

This annexure analyses, capability area by capability area, the status quo (foreign tools and existing practice), the resulting gap for sovereign defence use, the framework's approach to closing it, and the target maturity (TRL). It consolidates the comparative material of §4.i and Annexure H into a single gap view.

| Capability area | Status quo (foreign / existing) | Gap for sovereign use | Framework approach | Target TRL |
|---|---|---|---|---|
| **Air-gapped operation** | SaaS / cloud only | Cannot test classified weights | Fully offline enclave; zero egress | 7–8 |
| **Artifact security** | Signature-only; CVE-prone | Evaded by novel obfuscation | Fuzzing + detonation + SBOM | 5–6 |
| **Injection / jailbreak** | Partial; varies by tool | Inconsistent coverage | 10k+ corpus; 50+ library; benchmarked | 5–6 |
| **Gradient attacks** | Mostly black-box | White-box weakness untested | GCG / I-GCG / AutoDAN | 5 |
| **Agentic multi-turn** | Limited in most tools | Escalation paths missed | PAIR / TAP / Crescendo, in-enclave | 5 |
| **Membership inference** | Rare; over-claimed | Unreliable privacy signal | Canary-scoped LiRA / RMIA | 5 |
| **Embedding / backdoor** | Largely absent | Latent triggers undetected | Representation & sleeper analysis | 3–5 |
| **Multilingual (Indic)** | Absent in all | ~3× attack uplift unaddressed | Native-validated Indic corpus | 5–6 |
| **Confidential computing** | Not offered | Weights exposed in test | TEE + attestation (<7% overhead) | 6 |
| **Certification mapping** | Cloud dashboards | Not accreditation-grade | OWASP / ATLAS / NIST + signing | 6 |
| **Accreditation output** | None | No bridge to decision | Accreditation-ready adapter & bundle | 6–7 |
| **Sovereignty / eligibility** | Foreign-owned | IP exposure; TDF-ineligible | Indian MSME; ≈100% indigenous | — |

**Table 108.** Capability-maturity and gap analysis. *Source:* §4.i; Annexure H; 2025–26 vendor and literature analysis. *Interpretation:* On every capability the status quo leaves a sovereign-use gap that the framework closes to a defined target TRL; the analysis demonstrates the solution is gap-driven, not feature-driven.

# V ANNEXURE V — DELIVERABLES ACCEPTANCE INDEX

This annexure consolidates the milestone deliverables (§5.6–§5.7) into a single acceptance index, each with its acceptance basis and the gate at which it is accepted, to support deliverable-by-deliverable procurement evaluation.

| ID | Deliverable | Type | Acceptance basis | Gate |
|---|---|---|---|---|
| **D1.1** | Air-gapped secure platform (enclave + serving + ingestion) | System | Zero-egress test; reference model served | G1 |
| **D1.2** | Security baseline & CI/CD with in-enclave mirror | System | Reproducible signed build | G1 |
| **D2.1** | Pickle / bytecode analyzer | Software | Detection on malicious-artifact corpus | G2 |
| **D2.4** | Multi-format parser + safe-format steering | Software | Format coverage test | G2 |
| **D2.6** | Signature DB + SBOM; scan-before-load gate | Software | ≥ 90% detection on corpus | G2 |
| **D3.1** | Injection fuzzing engine (10k+ corpus) | Software | Coverage ≥ target on corpus | G3 |
| **D3.2** | Jailbreak library (50+) | Software | Library audit | G3 |
| **D3.4** | Indic harm taxonomy & corpus v1 (≥5 languages) | Data/IP | Native-speaker validation record | G3 |
| **D3.6** | Benchmark harness & coverage report | Report | Reproducible coverage run | G3 |
| **D4.1** | GCG / I-GCG gradient module | Software | White-box attack run | G4 |
| **D4.3** | AutoDAN genetic attack | Software | Fluent-jailbreak generation | G4 |
| **D4.4** | Agentic engine (PAIR / TAP / Crescendo) | Software | Multi-turn campaign | G4 |
| **D4.5** | Multi-turn Indic attack set | Data/IP | Validated ≥ 2 languages | G4 |
| **D5.1** | MIA harness (LiRA / RMIA, canary-scoped) | Software | TPR @ low-FPR on canaries | G5 |
| **D5.3** | Inference-API security tester | Software | Authz / DoS test suite | G5 |
| **D5.4** | Embedding / representation analysis | Software | Backdoor detection on test model | G5 |
| **D5.5** | Sleeper-agent divergence analysis | Software | Divergence test | G5 |
| **D6.1** | Severity-scoring model & rubric | Software | Calibrated on reference set | G6 |
| **D6.3** | OWASP / ATLAS / NIST mapping engine | Software | Mapping coverage audit | G6 |
| **D6.4** | Signed certification report generator | Software | Signed, reproducible report | G6 |
| **D6.6** | Audit-evidence bundle & traceability | Report | Cross-mapping complete | G6 |
| **D7.2** | Confidential computing & attestation | System | Attestation verified | G7 |
| **D7.3** | Performance optimisation (< 4 h / 7B) | System | Timed full-suite benchmark | G7 |
| **D7.4** | Indic taxonomy & corpus v2 | Data/IP | v2 validation record | G7 |
| **D8.1** | Independent V&V; report | Report | Separate-team validation vs FoM | G8 |
| **D8.2** | Framework penetration-test & remediation | Report | Findings closed | G8 |
| **D8.3** | Accreditation-export adapter | Software | Bundle accepted by adapter | G8 |
| **D8.4** | Pilot assessment (indigenous + procured) | Report | Pilot results in relevant env | G8 |
| **D8.5** | Documentation, training & sustainment pack | Docs | Operator / maintainer sign-off | G8 |
| **D8.6** | Final certification & handover | Report | Final acceptance | G8 |

**Table 109.** Consolidated deliverables acceptance index. *Source:* Cyberultron programme plan (§5.6–§5.7); Annexure C. *Interpretation:* Thirty representative deliverables are each tied to an acceptance basis and a binding gate, giving a single, auditable acceptance reference for procurement.

# W ANNEXURE W — PROGRAMME COMMUNICATIONS AND REPORTING PLAN

This annexure defines how the programme communicates with stakeholders and reports progress, complementing the governance and KPI framework (Annexure G).

| Stakeholder | Primary interest | Channel | Cadence |
|---|---|---|---|
| **DRDO End-User / DGTM** | Progress, risk, FoM attainment, gate acceptance | Gate reviews; progress reports; reviews | Fortnightly + per gate |
| **Programme sponsor / PMO** | Schedule, budget posture, escalations | PMO dashboard; status report | Monthly |
| **Engineering team** | Technical decisions, blockers | Stand-ups; technical reviews | Weekly |
| **Academic partners** | Research deliverables, validation | Research reviews (within boundary) | Per milestone |
| **Independent V&V;** | Validation scope & findings | Formal V&V; interface | M8 |

**Table 110.** Stakeholder communications plan. *Source:* Cyberultron PMO plan (Annexure G). *Interpretation:* Each stakeholder has a defined interest, channel and cadence, ensuring transparent, role-appropriate communication throughout the programme.

| Report | Content | Audience | Frequency |
|---|---|---|---|
| **Progress report** | Schedule, milestones, risks, decisions, blockers | End-User; PMO | Fortnightly |
| **Gate review pack** | Exit-criteria evidence; deliverable acceptance; next-gate plan | End-User; PMO | Per gate (G1–G8) |
| **Risk & RAID report** | Register updates; mitigation status; RAID log | End-User; PMO | Per gate + ad hoc |
| **Technical report** | Engineering deep-dive; benchmark results | End-User technical | Monthly |
| **Certification / V&V; report** | Findings, mappings, validation results | End-User; accreditation | M6 / M8 |

**Table 111.** Reporting plan. *Source:* Cyberultron PMO plan. *Interpretation:* A defined report set with content, audience and frequency gives the End-User continuous, evidence-based visibility and a documentary trail for evaluation and accreditation.

# X ANNEXURE X — DETAILED WORK BREAKDOWN STRUCTURE AND EFFORT DISTRIBUTION

This annexure decomposes the programme to the work-package level with indicative effort in person-months (PM) and the key output of each package, mapped to its milestone. Effort is expressed in PM only (no commercial information), consistent with §5.3.

| WBS | Work package | MS | PM | Key output |
|---|---|---|---|---|
| **1.1** | Air-gapped enclave network design & build | M1 | 6 | Zero-egress segment |
| **1.2** | Model-serving substrate (vLLM / TGI / Triton) | M1 | 5 | Reference model served |
| **1.3** | Orchestrator & OPA policy plane | M1 | 6 | Workflow + policy engine |
| **1.4** | Ingestion & provenance / signing | M1 | 4 | Verified ingestion |
| **1.5** | Disposable sandbox substrate | M1 | 4 | Isolated detonation host |
| **1.6** | CI/CD + in-enclave mirror | M1 | 4 | Reproducible build |
| **1.7** | Security baseline & hardening | M1 | 4 | Hardened baseline (G1) |
| **2.1** | Pickle / bytecode analyzer | M2 | 6 | Opcode analysis |
| **2.2** | Multi-format parser + steering | M2 | 5 | Format coverage |
| **2.3** | Structure-aware fuzzer | M2 | 5 | Mutation fuzzing |
| **2.4** | Detonation harness | M2 | 4 | Behavioural detection |
| **2.5** | Signature DB + SBOM | M2 | 4 | Signature coverage |
| **2.6** | Integrate + scan-before-load gate | M2 | 4 | Scanner ≥ 90% (G2) |
| **3.1** | Injection fuzzing engine | M3 | 6 | 10k+ corpus engine |
| **3.2** | Jailbreak library (50+) | M3 | 5 | Jailbreak coverage |
| **3.3** | Benchmark harness | M3 | 4 | Coverage measurement |
| **3.4** | Indic taxonomy & corpus v1 | M3 | 7 | Indic corpus v1 |
| **3.5** | Native-speaker validation | M3 | 4 | Validation record (G3) |
| **4.1** | GCG / I-GCG gradient module | M4 | 6 | Adversarial suffixes |
| **4.2** | AutoDAN genetic attack | M4 | 5 | Fluent jailbreaks |
| **4.3** | Agentic orchestrator (in-enclave attacker) | M4 | 6 | Agentic loop |
| **4.4** | PAIR / TAP / Crescendo | M4 | 5 | Multi-turn campaigns |
| **4.5** | Multi-turn Indic attack set | M4 | 4 | Validated set (G4) |
| **4.v.1** | MIA harness (LiRA / RMIA) | M5 | 6 | Canary MIA |
| **4.v.2** | Data / PII extraction tests | M5 | 4 | Extraction findings |
| **4.v.3** | Inference-API security tester | M5 | 5 | API test suite |
| **4.v.4** | Embedding / representation analysis | M5 | 6 | Backdoor detection |
| **4.v.5** | Sleeper-agent analysis | M5 | 4 | Divergence test (G5) |
| **6.1** | Severity-scoring model & rubric | M6 | 5 | Calibrated scoring |
| **6.2** | Mapping engine (OWASP/ATLAS/NIST) | M6 | 6 | Framework mapping |
| **6.3** | Certification dashboard & report | M6 | 6 | Signed report |
| **6.4** | Audit-evidence bundle & traceability | M6 | 5 | Evidence bundle (G6) |
| **7.1** | End-to-end integration & regression | M7 | 7 | Integrated suite |
| **7.2** | Confidential computing & attestation | M7 | 6 | Attestation verified |
| **7.3** | Performance optimisation (< 4 h/7B) | M7 | 6 | Timed benchmark |
| **7.4** | Indic taxonomy & corpus v2 | M7 | 5 | Indic v2 (G7) |
| **8.1** | Independent V&V; (separate team) | M8 | 6 | IV&V; report |
| **8.2** | Framework penetration test & remediation | M8 | 5 | Findings closed |

| WBS | Work package | MS | PM | Key output |
|---|---|---|---|---|
| **8.3** | Accreditation adapter & pilot | M8 | 6 | Pilot results |
| **8.4** | Documentation, training & final handover | M8 | 6 | Final acceptance (G8) |

**Table 112.** Detailed WBS with indicative effort (person-months) and key output. *Source:* Cyberultron programme plan (§5.3, §5.6). *Interpretation:* Forty work packages decompose the eight milestones to executable units, each with indicative effort and a tangible output — the basis for resource loading (Annexure F) and gate-based acceptance; effort is shown in PM only, with no commercial figures.

# Y ANNEXURE Y — SECURITY OPERATIONS AND INCIDENT-RESPONSE PLAN

Because the framework operates on hostile artifacts within a secure enclave, its own operation is governed by a security-operations and incident-response regime. The air-gapped design bounds the blast radius of any incident; the controls and runbook below ensure detection, containment and recovery.

| Control | Mechanism | Cadence |
|---|---|---|
| **Monitoring & alerting** | Prometheus + Grafana (in-enclave); thresholds on resource & behaviour | Continuous |
| **Integrity monitoring** | Signature / fingerprint verification; file-integrity monitoring | Continuous |
| **Access review** | RBAC review; least-privilege re-attestation | Per gate |
| **Log review** | Append-only signed audit-trail review | Continuous / per gate |
| **Vulnerability management** | Framework self-scan; dependency review via SBOM | Per build |
| **Backup & restore** | Encrypted backups of evidence & corpora; restore test | Periodic |
| **Patch management** | Offline updates via signed controlled media; re-validation | As required |

**Table 113.** Security-operations controls. *Source:* Cyberultron security plan (§5.4); ISO/IEC 27001. *Interpretation:* Operational security is continuous and gate-reviewed; the enclave and signed audit trail make detection and accountability inherent to the design.

| IR stage | Actions |
|---|---|
| **Detect** | Alert from monitoring / integrity checks; anomalous behaviour during detonation or attack runs flagged. |
| **Triage & classify** | Assess severity and scope; determine whether an artifact, a node or the framework is implicated. |
| **Contain** | Isolate the affected node; invoke kill-switch / circuit-breaker; halt the run; preserve evidence. |
| **Eradicate** | Destroy the disposable sandbox; quarantine the artifact; remove any persistence. |
| **Recover** | Restore from signed backups; rebuild reproducibly from the in-enclave mirror; verify integrity. |
| **Review** | Post-incident review; update the risk register and controls; record lessons. |

**Table 114.** Incident-response runbook. *Source:* Cyberultron security plan; NIST incident-handling practice. *Interpretation:* A standard detect-contain-eradicate-recover-review cycle, bounded by air-gap isolation and disposable sandboxes, keeps any incident contained and recoverable without external exposure.

# Z ANNEXURE Z — INNOVATION AND SOVEREIGN-IP REGISTER

This annexure registers the net-new intellectual property created under the programme, its novelty relative to prior art, and how it is protected — substantiating the indigenous-content and differentiation claims (§8, Annexure U).

| IP item | Description | Novelty / differentiation | Protection |
|---|---|---|---|
| **Indian-language harm taxonomy & corpus** | Native-validated harm taxonomy and attack corpus across ≥5 languages | Absent in all foreign tools; sovereign linguistic asset | Trade-secret; enclave-only; access-controlled |
| **Six-engine integrated framework** | Unified static, attack, gradient, agentic, privacy and certification engines | Full-attack-surface coverage in one air-gapped system | Copyright (code); in-enclave |
| **Backdoor-signature database** | Offline signature & heuristic base for malicious artifacts | Sovereign, offline-refreshable; not cloud-tied | Trade-secret; controlled refresh |
| **Air-gapped assessment methodology** | End-to-end offline red-team & certification method | No commercial tool operates fully air-gapped | Trade-secret; documentation copyright |
| **Accreditation-mapping & signing engine** | OWASP/ATLAS/NIST mapping with signed, accreditation-ready output | Decision-grade vs dashboard-only tools | Copyright; controlled access |
| **Canary-scoped MIA methodology** | Honestly-scoped LiRA / RMIA with canary design | Rigorous where others over-claim | Documentation; method control |

**Table 115.** Innovation and sovereign-IP register. *Source:* Cyberultron IP register (§8, Annexure O, Annexure U). *Interpretation:* Six net-new IP assets — led by the Indic harm corpus — are recorded with their novelty and protection, evidencing both the sovereign character and the defensible differentiation of the solution.

# AA ANNEXURE AA — INDICATIVE ACCEPTANCE TEST PLAN (ATP)

This annexure defines the indicative acceptance test plan by which the framework itself is accepted, mapping each test to its method, pass criterion and gate. It operationalises the figures of merit (§2.4) and the validation matrix (§5.8) as a final, evidence-based acceptance instrument.

| ID | Acceptance test | Method | Pass criterion | Gate |
|---|---|---|---|---|
| **AT-01** | Air-gapped isolation | Egress-denial test; traffic capture | Zero outbound communication | G1 |
| **AT-02** | Scan-before-load enforcement | Attempt load of unscanned artifact | Load blocked until scan clears | G2 |
| **AT-03** | Artifact malware detection | Run on labelled malicious-model corpus | ≥ 90% detection | G2 |
| **AT-04** | Injection coverage | Run injection corpus (known + held-out) | ≥ 95% / ≥ 70% 0-shot | G3 |
| **AT-05** | Jailbreak coverage | Audit jailbreak library | ≥ 50 methodologies | G3 |
| **AT-06** | Indic attack coverage | Run native-validated Indic set | ≥ 5 languages | G3 |
| **AT-07** | Gradient attack | White-box GCG / I-GCG / AutoDAN run | Adversarial suffix generated & transfers | G4 |
| **AT-08** | Agentic campaign | Multi-turn PAIR / TAP / Crescendo run | Multi-turn exploit chain produced | G4 |
| **AT-09** | Membership inference | LiRA / RMIA on canaries | ≥ 80% on canaries (TPR @ low-FPR) | G5 |
| **AT-10** | Inference-API security | Authz / DoS test suite | Validated findings; no false positives | G5 |
| **AT-11** | Embedding / backdoor | Representation & sleeper analysis on test model | Planted backdoor detected | G5 |
| **AT-12** | Certification mapping | Coverage audit of OWASP/ATLAS/NIST mapping | LLM01–10 + ATLAS + RMF covered | G6 |
| **AT-13** | Signed certification report | Generate & verify report | Signed, reproducible certificate | G6 |
| **AT-14** | Confidential computing | Hardware attestation check | Attestation verified; weights protected | G7 |
| **AT-15** | Performance | Timed full-suite run on 7B model | < 4 hours | G7 |
| **AT-16** | Independent V&V; | Separate-team validation vs FoM | All FoM met / variances closed | G8 |
| **AT-17** | Pilot assessment | Assess indigenous + procured pilot models | Pilot completed in relevant env | G8 |

**Table 116.** Indicative acceptance test plan (ATP). *Source:* EOI §2.4; Cyberultron V&V; plan (§5.8); Annexure C. *Interpretation:* Seventeen acceptance tests, each with a method, a quantified pass criterion and a gate, convert the figures of merit into a binding, auditable acceptance regime for the framework.

# AB ANNEXURE AB — GLOSSARY OF KEY TECHNICAL CONCEPTS AND METHODS

Concise definitions of the principal attack methods, defence concepts and techniques referenced in this response, for the convenience of the evaluation committee. This complements the abbreviations (Annexure B) and reference standards (Annexure K).

| Term / method | Definition |
|---|---|
| **Prompt injection** | An attack that embeds adversarial instructions in input (or retrieved content) to override a model's intended behaviour or system prompt. |
| **Jailbreak** | A prompt or technique that bypasses a model's safety alignment to elicit content it should refuse. |
| **Adversarial suffix** | A crafted token sequence appended to a prompt that induces unsafe output; often produced by gradient optimisation. |
| **GCG (Greedy Coordinate Gradient)** | A white-box method that optimises an adversarial suffix using gradients of the target model to maximise the probability of a harmful response. |
| **I-GCG (Improved GCG)** | An efficiency- and success-rate-improved variant of GCG that converges in fewer iterations. |
| **AutoDAN** | A method that generates fluent, human-readable jailbreak prompts via a hierarchical genetic search, evading perplexity-based filters. |
| **PAIR** | Prompt Automatic Iterative Refinement — an attacker LLM iteratively refines prompts against a target to find a jailbreak in few queries. |
| **TAP (Tree of Attacks with Pruning)** | A black-box method that explores a tree of attack prompts with pruning of unpromising branches. |
| **Crescendo** | A multi-turn attack that escalates gradually over a conversation to reach a harmful objective that a single turn would refuse. |
| **Membership inference attack (MIA)** | A privacy attack that infers whether a specific record was in a model's training data. |
| **LiRA (Likelihood Ratio Attack)** | A strong, shadow-model-based MIA that compares the likelihood of a sample under in- and out-of-training distributions. |
| **RMIA** | A robust MIA using a reference population that achieves strong results with fewer shadow models. |
| **Canary** | A deliberately inserted, unique training record used to measure memorisation and validate membership-inference / extraction tests. |
| **Model artifact / serialization** | The stored form of a model (weights, config, tokenizer). Unsafe formats (e.g. Python pickle) can execute code on load — a supply-chain risk. |
| **Backdoor / data poisoning** | A hidden behaviour implanted (often via poisoned training data) that activates on a specific trigger while behaving normally otherwise. |
| **Sleeper agent** | A model with a latent, conditionally-activated malicious behaviour that evades ordinary testing. |
| **Embedding / representation analysis** | Examination of a model's internal representations to detect anomalies, triggers or backdoors not visible from outputs alone. |
| **Confidential computing / TEE** | Hardware-based trusted execution environments (e.g. NVIDIA CC, Intel TDX, AMD SEV-SNP) that keep data and model weights encrypted while in use. |
| **Attestation** | A cryptographic proof that code / data is running inside a genuine, unmodified trusted execution environment. |
| **Air-gap** | Physical and logical isolation of a system from external networks, preventing any data egress or remote access. |
| **SBOM (Software Bill of Materials)** | A complete inventory of software components and versions in a build, used for supply-chain assurance. |
| **Red-teaming** | Structured adversarial testing that emulates real attackers to find vulnerabilities before deployment. |
| **Defence in depth** | A layered security design in which multiple independent controls each provide protection, so no single failure is catastrophic. |
| **Stage-gate** | A delivery model in which the programme proceeds only after a formal gate confirms exit-criteria and deliverable acceptance. |

**Table 117.** Glossary of key technical concepts and methods. *Source:* Cited literature (OWASP, MITRE ATLAS, academic sources); standards bodies. *Interpretation:* Plain-language definitions of every principal method and concept used in this response, ensuring the document is fully

self-contained for technical and procurement evaluators.

# AC ANNEXURE AC — EOI ITEM-TO-RESPONSE CROSSWALK

This crosswalk maps each EOI Part-II item to the section(s) of this response that address it and the principal supporting artifacts (figures, tables and annexures), so the evaluation committee can navigate directly from any requirement to its treatment. It complements the requirements-traceability matrix (Annexure C) and the EOI compliance checklist (Annexure M).

| EOI item | Requirement (abridged) | Addressed in | Principal supporting artifacts |
|---|---|---|---|
| **1–3** | Applicant, contact details and project title | §1–3; Cover | Item 1–3 tables; Annexure R, S |
| **4** | Project description (understanding, technologies, block diagram, process) | §4.i–iv | Figures 1-6; Tables 1–5; Annexures C, D |
| **5(i)** | Estimated development time with break-up (≤ 24 months) | §5.1, §5.6, §5.18 | Figure 16 (Gantt); milestone tables; Annexures F, V, X |
| **5(ii)** | Suo-moto development of a similar product (Yes/No) | §5.20 | Foundational-capabilities table (“No”) |
| **6** | Academic partners / R&D; required; technologies needing support | §6.1–§6.2 | Figure 30; Annexure N |
| **7** | Existing academic / research support with the industry | §7 | IIT Kanpur incubation; Annexures N, R |
| **8** | Likely indigenous content in the proposed solution | §8.1–§8.2 | Figure 31; Annexures O, Z |
| **9** | Risk identification and mitigation plan | §9.1–§9.3 | Figures 24, 32, 33; Annexure P |
| **10** | Additional infrastructure requiring funding support | §10.1–§10.2 | Figures 34, 35; Annexures L, Q |
| **11** | Experience in design and development, incl. tools (A1–A9) | §11, §11.1–§11.2 | Item 11 tables; Figure 36; Annexures T, U |
| **12** | Essential test infrastructure (A1–A7) | §12 | Item 12 table; Figure 37; Annexures L, Q |
| **13** | Availability of experienced manpower (A1–A7) | §13, §13.1 | Item 13 table; role-coverage matrix; Annexure F |
| **14** | Management capabilities | §14 | Item 14 table; Annexures E, G, Y |
| **15** | Undertaking by the firm (Indian-perimeter) | §15 | Signed undertaking; covering letter |
| **16** | Organization structure, legal status, shareholding | §16.a–§16.c | Shareholding table; incorporation records; foreign / land-border declarations |
| **17** | Financial capabilities (positive net worth; audited) | §17 | Audited financial statements (financial annexure) |
| **18** | Litigation / arbitration history | §18 | Nil-litigation table |
| **Undertakings** | Sovereignty, indigenous content, no commercials, conformance | Covering letter | Annexures C, M; Executive Summary |

**Table 118.** EOI item-to-response crosswalk. *Source:* EOI Part-II Items 1–18; this response. *Interpretation:* Every EOI item maps to a specific section and a set of supporting artifacts, giving the committee a single navigational index from requirement to treatment across the whole document.

This concludes the annexures. Together, Items 1–18 and Annexures A–AC provide a complete, traceable and independently-verifiable technical response: the problem and solution (§4), a fully resourced 24-month delivery plan with binding gates (§5), academic engagement and existing support (§6–§7), indigenous content (§8), a comprehensive risk plan (§9) and the funded-infrastructure requirement (§10) — with no commercial information at any point and all data and intellectual property retained within the Indian perimeter.

CYBERULTRON CONSULTING PRIVATE LIMITED

C3iHub, 2nd Floor, Technopark Phase I, IIT Kanpur, Kanpur - 208016, Uttar Pradesh, India

Ph - +91 - 94574 54866 | www.cyberultron.ai

— End of Part-II response (Items 1–18). —